

NCSA CTF Boot Camp

Network Security & Cryptography & Mobile Security

Responsible: Mr. Tanakorn Sookkul
Version (Date): 1.0 (2025-06-28)
Confidentiality class: Public



whoami



Pichaya (LongCat) Morimoto

Lead Penetration Tester

Siam Thanat Hack Co., Ltd.



Tanakorn (chin) Sookkul

Penetration Tester

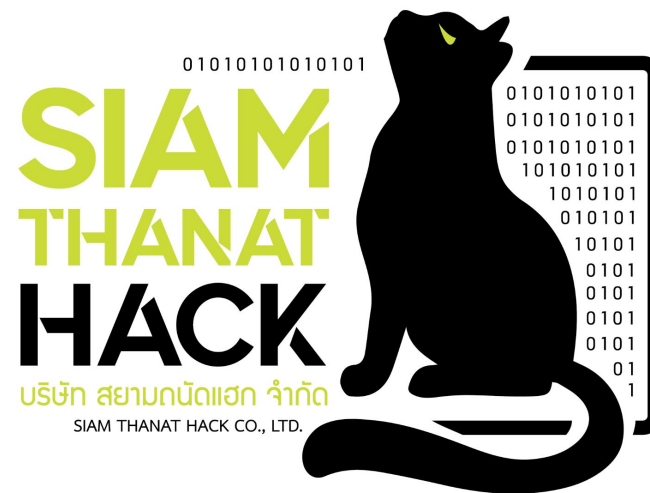
Siam Thanat Hack Co., Ltd.



Kittitat (F) Nopparat

Penetration Tester

Siam Thanat Hack Co., Ltd.



Disclaimer

- จุดประสงค์ของการบรรยาย นี้เพื่อแบ่งปันความรู้ ทางด้านความปลอดภัยระบบสารสนเทศ
- ไม่สนับสนุนการนำความรู้ทางด้านความปลอดภัยฯ ไปใช้ในทางที่ผิดกฎหมายทั้งหมด
- ตัวอย่างโค้ด และรูปใน การบรรยาย นี้ เป็นระบบจำลองของทางผู้บรรยาย ไม่ใช่ระบบลูกค้า



Agenda (Day 1)

15.15 – 17.00 น. Workshop หัวข้อ Network Security, Cryptography และ Mobile Security (1 ชั่วโมง 45 นาที)

- ความรู้ด้าน Network Security, Cryptography และ Mobile Security
- ทดลองฝึกปฏิบัติหัวข้อ Network Security, Cryptography และ Mobile Security
- ตัวอย่างโจทย์การแข่งขัน

Content Overview

Workshop หัวข้อ Network Security

- #Lab 1: Plaintext HTTP (Easy)
- #Lab 2: Plaintext FTP (Easy)
- #Lab 3: Uncommon TCP Port (Medium)
- #Lab bonus: Encoded C2 (Hard)

Workshop หัวข้อ Cryptography

- #Lab 4: PGP Encryption (Easy)
- #Lab 5: RSA Fermat (Medium)
- #Lab 6: ECB Block shuffling (Hard)

Workshop หัวข้อ Mobile Security

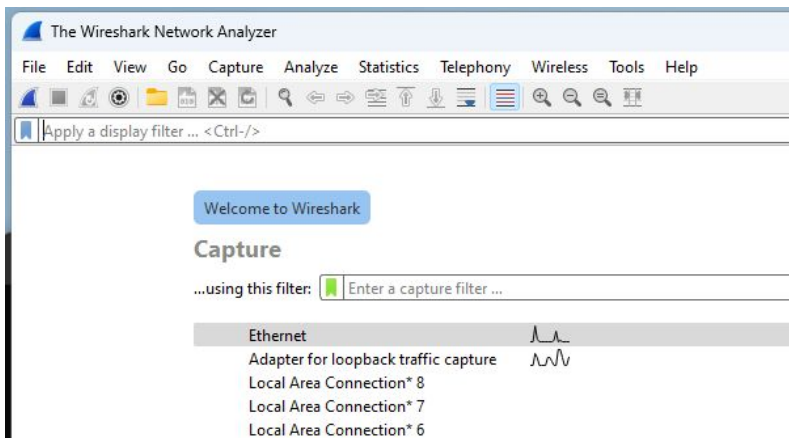
- #Lab 7: Parameter Tampering (Digital Wallet) (Easy)
- #Lab 8: Hard coded Secret (Digital Wallet v2) (Medium)



บจก.สยามถนัดแฮก

Workshop: Network Security

Network Packet Analyzer (การวิเคราะห์ข้อมูล Packet)



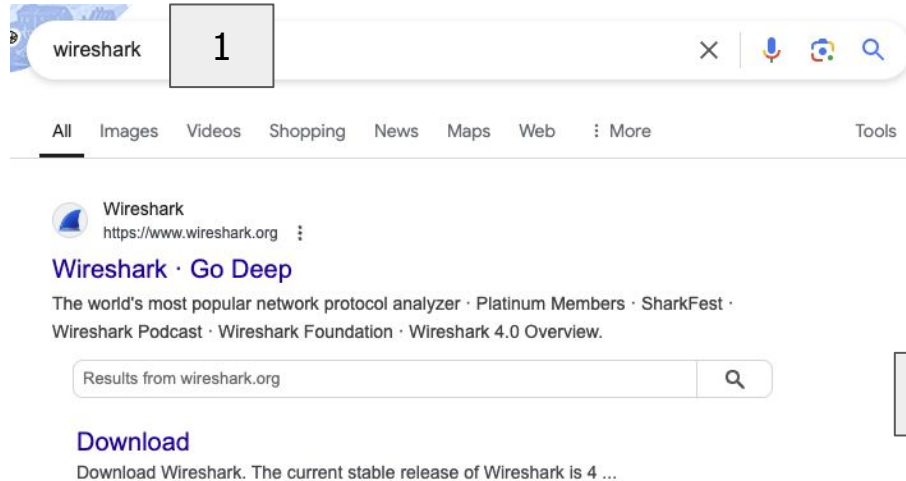
ไฟล์ PCAP

ประเภทไฟล์ที่เก็บบันทึก Network Packet ที่เคยถูกรับ-ส่ง ระหว่างคอมพิวเตอร์ ในอดีต

	netsec_lab1.pcap	8/28/2024 10:55 PM	Wireshark capture...
	netsec_lab2.pcap	4 11:05 PM	Wireshark capture...
	netsec_lab3.pcap	Date modified: 8/28/2024 10:55 PM 4 12:06 AM	Wireshark capture...
	netsec1.pcap	8/28/2024 11:48 PM	Wireshark capture...

Install Wireshark

ติดตั้ง Wireshark



Download Wireshark

The current stable release of Wireshark is 4.2.6. It supersedes all previous development release (4.4.0rc1) and documentation.

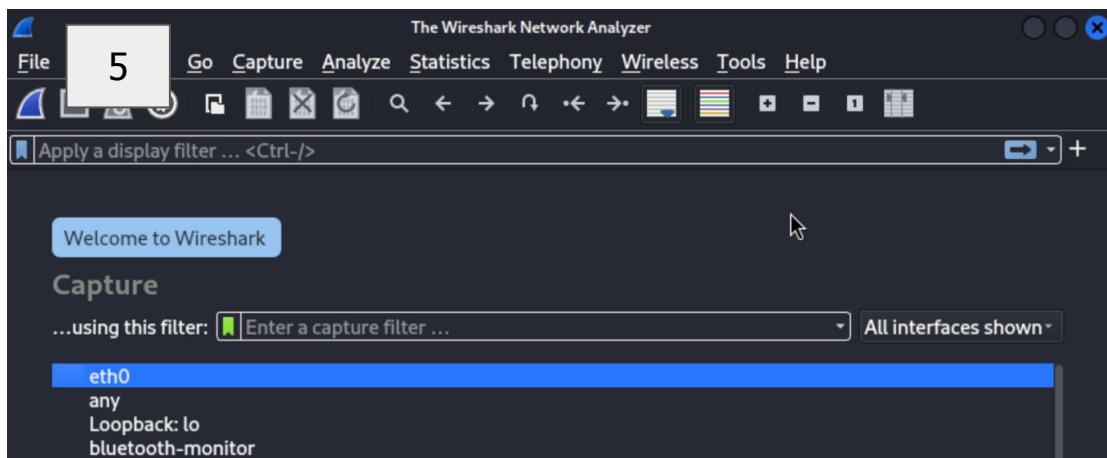
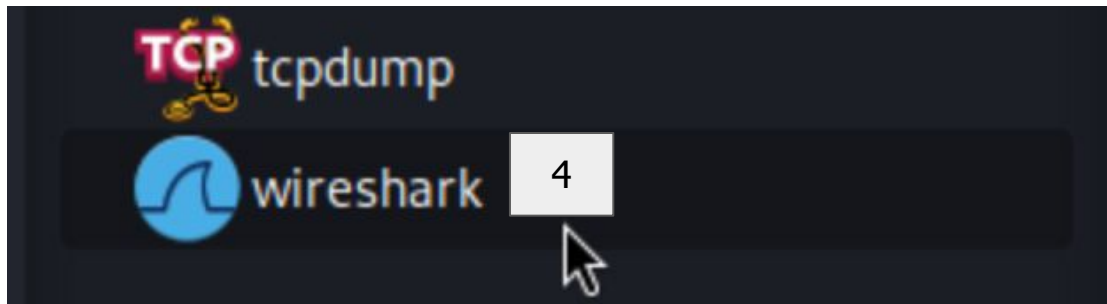
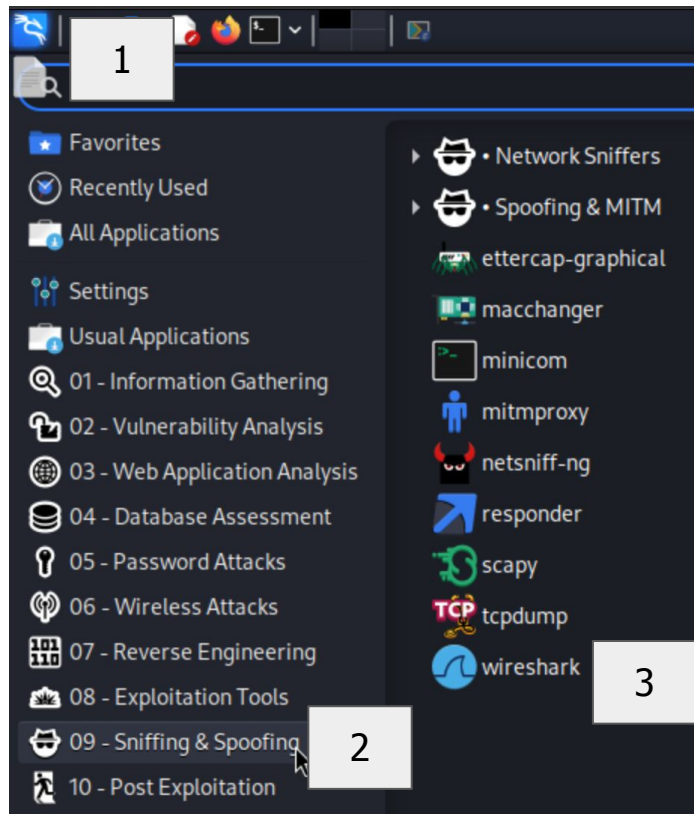
▼ Stable Release: 4.2.6

-  **Windows x64 Installer**
-  **Windows Arm64 Installer**
-  **Windows x64 PortableApps®**
-  **macOS Arm Disk Image**
-  **macOS Intel Disk Image**



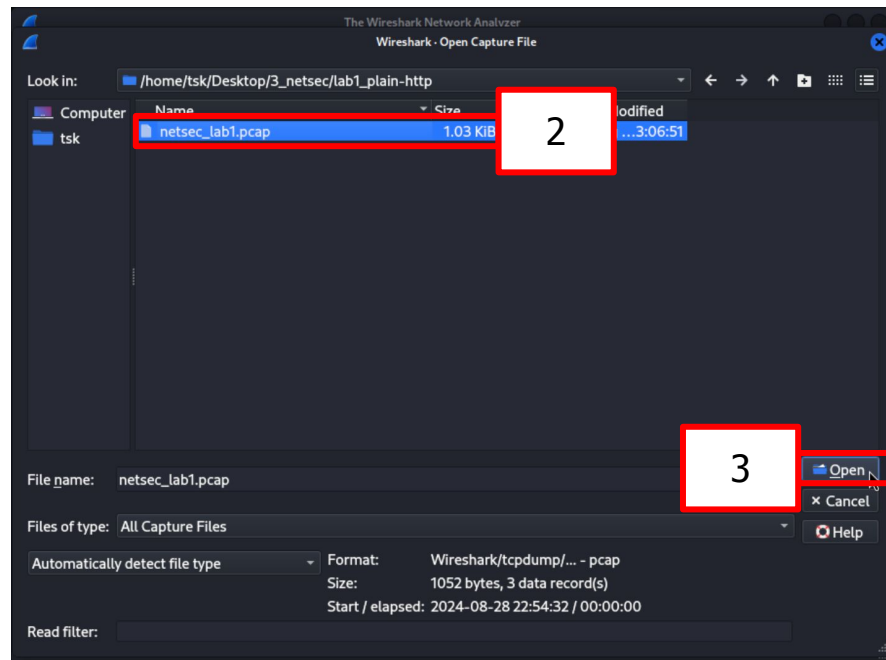
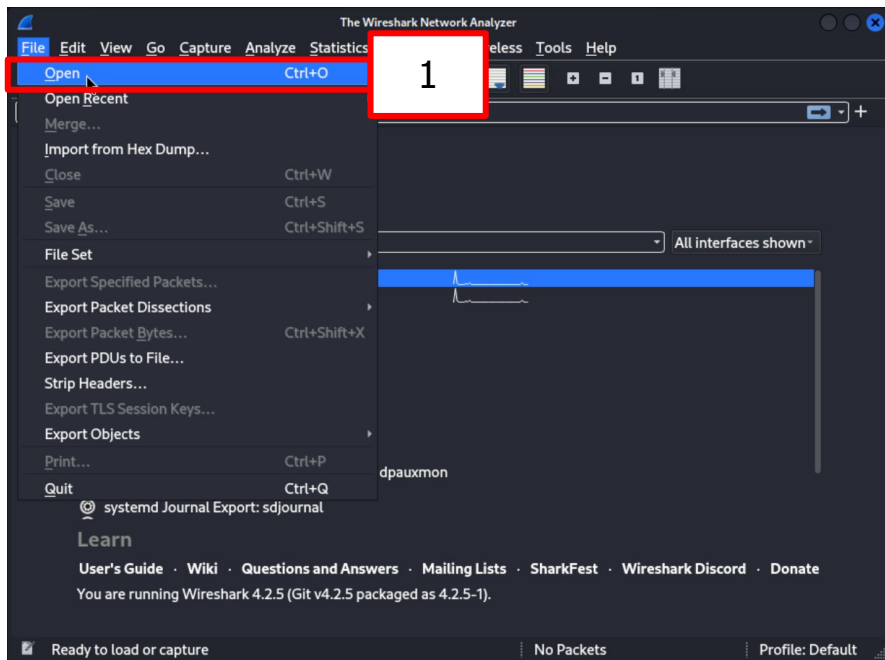
<https://www.wireshark.org/download.html>

โปรแกรม Wireshark ใน Kali



Lab 1 - Plaintext HTTP (easy)

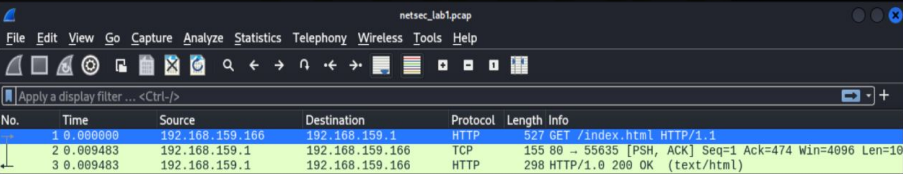
Lab 1 - Plaintext HTTP (easy)



Lab 1 - Plaintext HTTP (easy)

\$ wireshark netsec_lab1.pcap

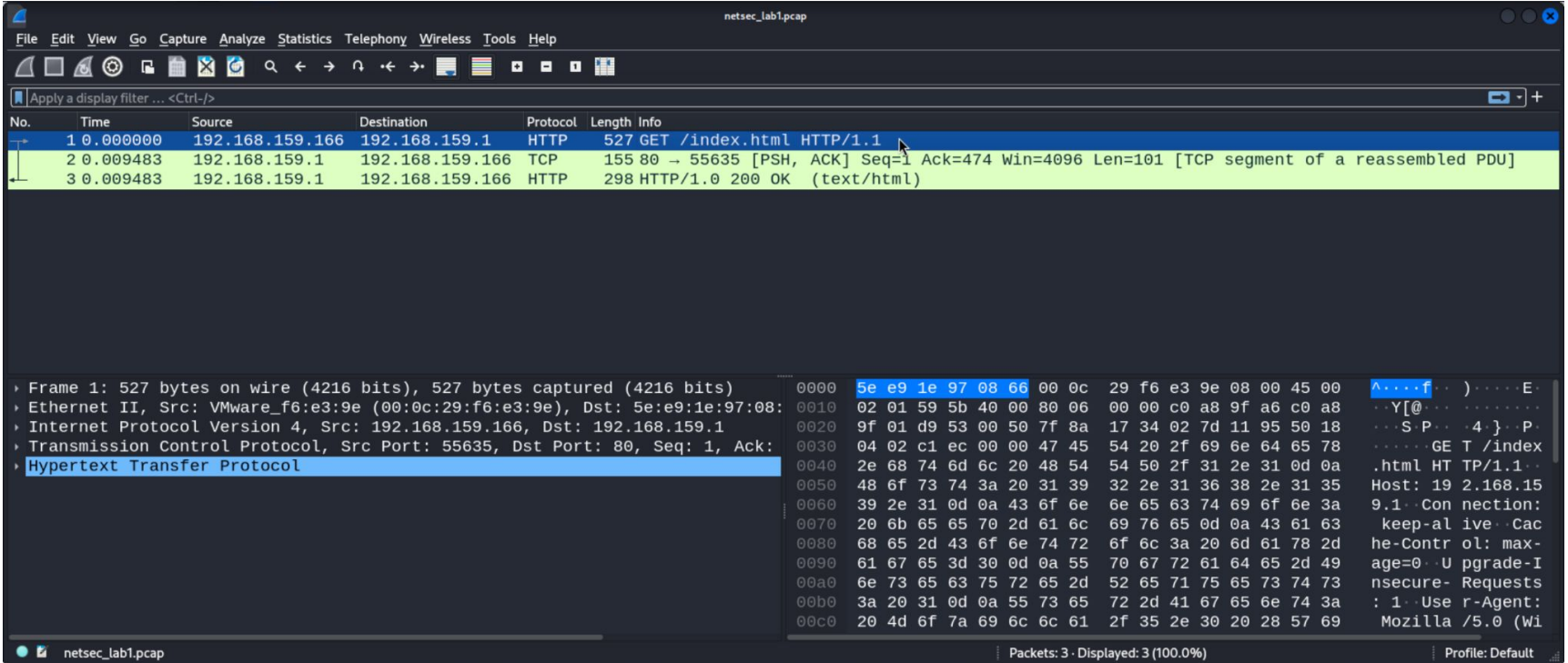
```
tsk@kali: ~/Desktop/3_netsec/lab1_plain-http
$ wireshark netsec_lab1.pcap
** (wireshark:1524802) 13:40:27.164291 [WSUtil WARNING] ./wsutil/filter_files.c:242 -
- read_filter_list(): '/usr/share/wireshark/cfilters' line 1 doesn't have a quoted fil
ter name.
** (wireshark:1524802) 13:40:27.164332 [WSUtil WARNING] ./wsutil/filter_files.c:242 -
- read_filter_list(): '/usr/share/wireshark/cfilters' line 2 doesn't have a quoted fil
ter name.
```



netsec_lab1.pcap

No.	Time	Source	Destination	Protocol	Length	Info
1	0.000000	192.168.159.166	192.168.159.1	HTTP	527	GET /index.html HTTP/1.1
2	0.009483	192.168.159.1	192.168.159.166	TCP	155	80 → 55635 [PSH, ACK] Seq=1 Ack=474 Win=4896 Len=0
3	0.009483	192.168.159.1	192.168.159.166	HTTP	298	HTTP/1.0 200 OK (text/html)

Lab 1 - Plaintext HTTP (easy)



The image shows a Wireshark packet capture of a plaintext HTTP GET request. The packet list at the top shows three packets: an HTTP GET request (No. 1), a TCP segment (No. 2), and the HTTP response (No. 3). The selected packet (No. 1) is expanded in the packet details pane, showing the Ethernet II, Internet Protocol Version 4, and Hypertext Transfer Protocol layers. The packet bytes pane at the bottom shows the raw data in hexadecimal and ASCII.

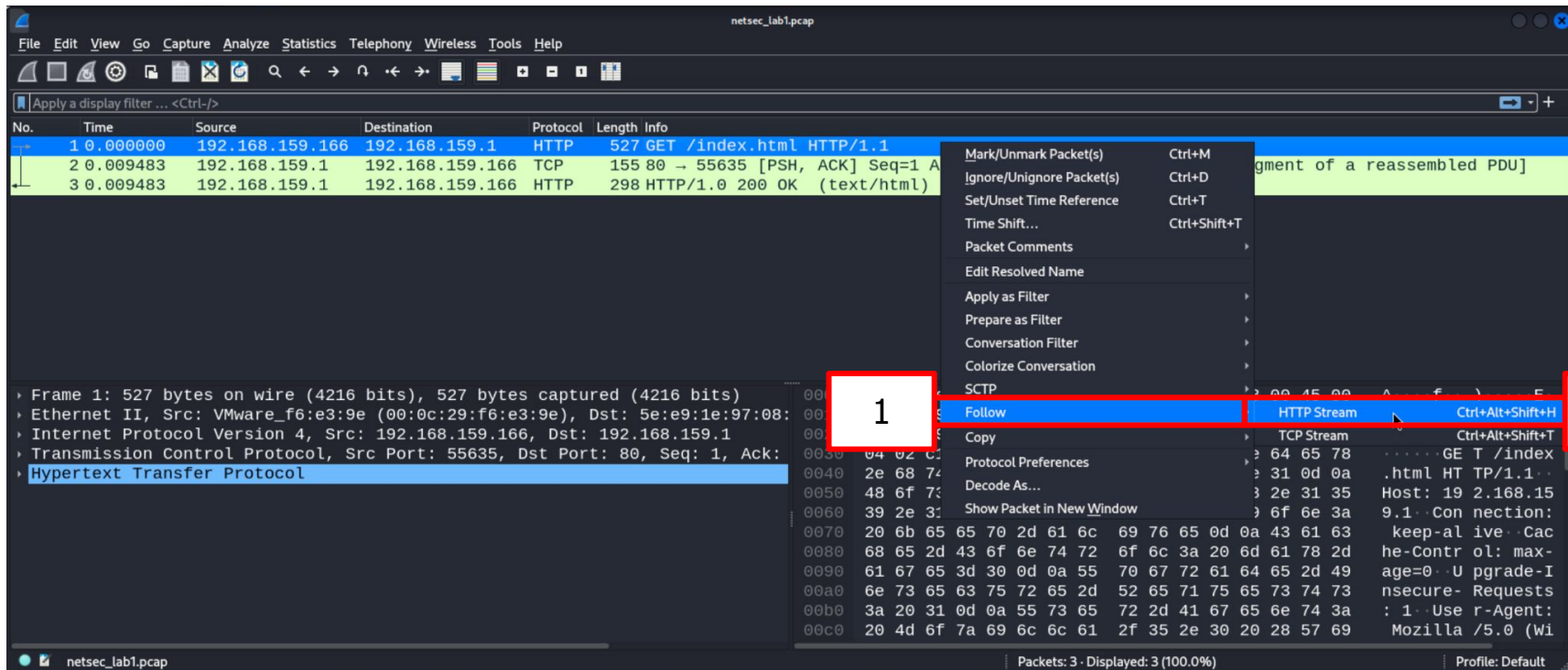
No.	Time	Source	Destination	Protocol	Length	Info
1	0.000000	192.168.159.166	192.168.159.1	HTTP	527	GET /index.html HTTP/1.1
2	0.009483	192.168.159.1	192.168.159.166	TCP	155	80 → 55635 [PSH, ACK] Seq=1 Ack=474 Win=4096 Len=101 [TCP segment of a reassembled PDU]
3	0.009483	192.168.159.1	192.168.159.166	HTTP	298	HTTP/1.0 200 OK (text/html)

Frame 1: 527 bytes on wire (4216 bits), 527 bytes captured (4216 bits) on interface 0
 Ethernet II, Src: VMware_f6:e3:9e (00:0c:29:f6:e3:9e), Dst: 5e:e9:1e:97:08:66
 Internet Protocol Version 4, Src: 192.168.159.166, Dst: 192.168.159.1
 Transmission Control Protocol, Src Port: 55635, Dst Port: 80, Seq: 1, Ack: 474, Win: 4096, Len: 101
 Hypertext Transfer Protocol

Packet bytes (hex): 5e e9 1e 97 08 66 00 0c 29 f6 e3 9e 08 00 45 00 00 00 c0 a8 9f a6 c0 a8 9f 01 d9 53 00 50 7f 8a 17 34 02 7d 11 95 50 18 04 02 c1 ec 00 00 47 45 54 20 2f 69 6e 64 65 78 2e 68 74 6d 6c 20 48 54 54 50 2f 31 2e 31 0d 0a 48 6f 73 74 3a 20 31 39 32 2e 31 36 38 2e 31 35 39 2e 31 0d 0a 43 6f 6e 6e 65 63 74 69 6f 6e 3a 20 6b 65 65 70 2d 61 6c 69 76 65 0d 0a 43 61 63 68 65 2d 43 6f 6e 74 72 6f 6c 3a 20 6d 61 78 2d 61 67 65 3d 30 0d 0a 55 70 67 72 61 64 65 2d 49 6e 73 65 63 75 72 65 2d 52 65 71 75 65 73 74 73 3a 20 31 0d 0a 55 73 65 72 2d 41 67 65 6e 74 3a 20 4d 6f 7a 69 6c 6c 61 2f 35 2e 30 20 28 57 69

Packet bytes (ASCII): .Y[0... ..E...
 ...S.P...4...P...
 ...GE T /index...
 .html HT TP/1.1...
 Host: 19 2.168.15...
 9.1..Con nection:
 keep-al ive..Cac...
 he-Contr ol: max-...
 age=0..U pgrade-I...
 nsecure- Requests...
 : 1..Use r-Agent:
 Mozilla /5.0 (Wi...

Lab 1 - Plaintext HTTP (easy)



netsec_lab1.pcap

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

Apply a display filter ... <Ctrl-/>

No.	Time	Source	Destination	Protocol	Length	Info
1	0.000000	192.168.159.166	192.168.159.1	HTTP	527	GET /index.html HTTP/1.1
2	0.009483	192.168.159.1	192.168.159.166	TCP	155	80 → 55635 [PSH, ACK] Seq=1 A
3	0.009483	192.168.159.1	192.168.159.166	HTTP	298	HTTP/1.0 200 OK (text/html)

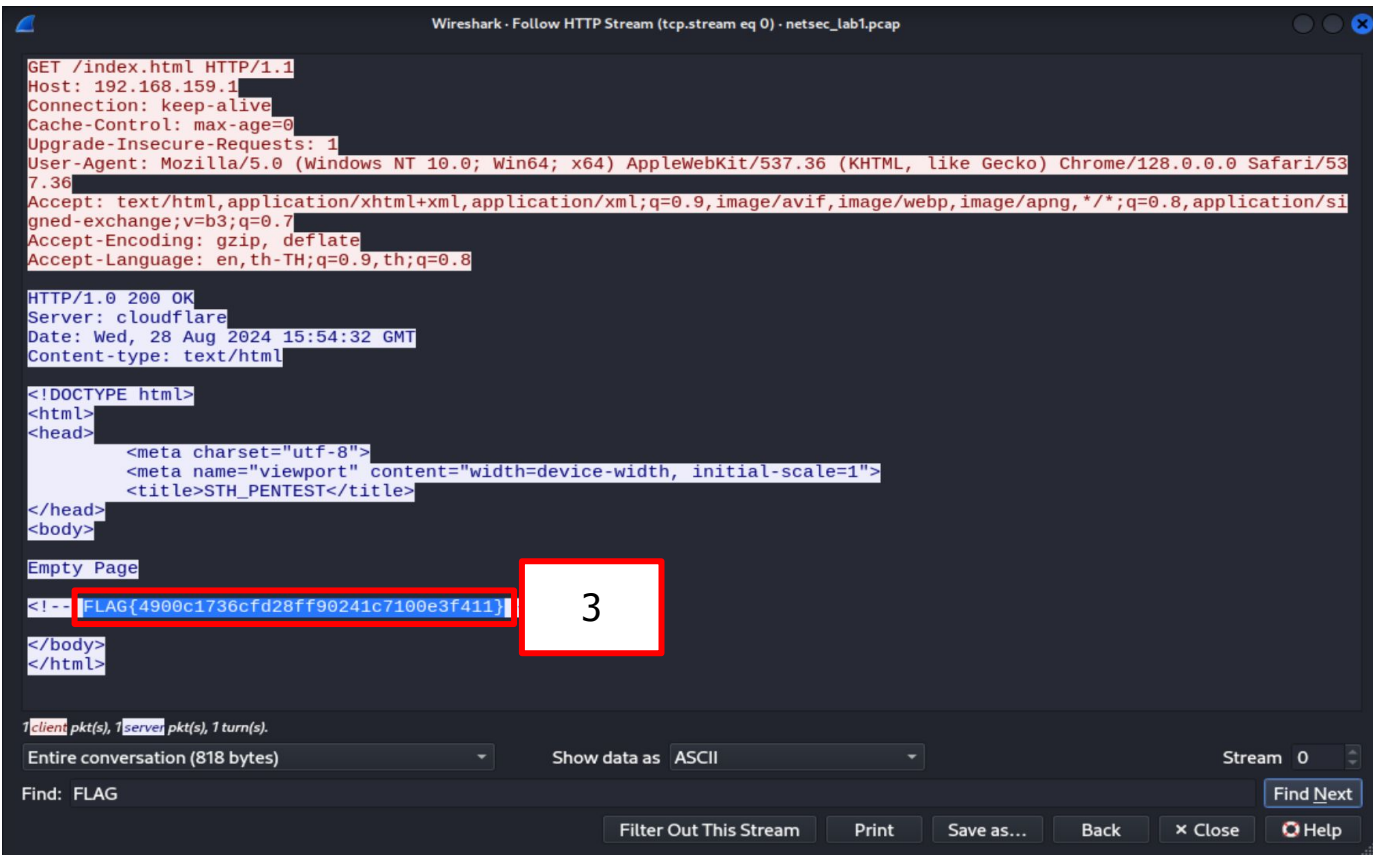
Frame 1: 527 bytes on wire (4216 bits), 527 bytes captured (4216 bits)
 Ethernet II, Src: VMware_f6:e3:9e (00:0c:29:f6:e3:9e), Dst: 5e:e9:1e:97:08:
 Internet Protocol Version 4, Src: 192.168.159.166, Dst: 192.168.159.1
 Transmission Control Protocol, Src Port: 55635, Dst Port: 80, Seq: 1, Ack:
 Hypertext Transfer Protocol

Follow HTTP Stream Ctrl+Alt+Shift+H

1 2

Packets: 3 · Displayed: 3 (100.0%) Profile: Default

Lab 1 - Plaintext HTTP (easy)



Wireshark - Follow HTTP Stream (tcp.stream eq 0) - netsec_lab1.pcap

```
GET /index.html HTTP/1.1
Host: 192.168.159.1
Connection: keep-alive
Cache-Control: max-age=0
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/128.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;q=0.7
Accept-Encoding: gzip, deflate
Accept-Language: en,th-TH;q=0.9,th;q=0.8

HTTP/1.0 200 OK
Server: cloudflare
Date: Wed, 28 Aug 2024 15:54:32 GMT
Content-type: text/html

<!DOCTYPE html>
<html>
<head>
  <meta charset="utf-8">
  <meta name="viewport" content="width=device-width, initial-scale=1">
  <title>STH_PENTEST</title>
</head>
<body>
  Empty Page
  <!-- FLAG{4900c1736cfd28ff90241c7100e3f411} -->
</body>
</html>
```

1 client pkt(s), 1 server pkt(s), 1 turn(s).

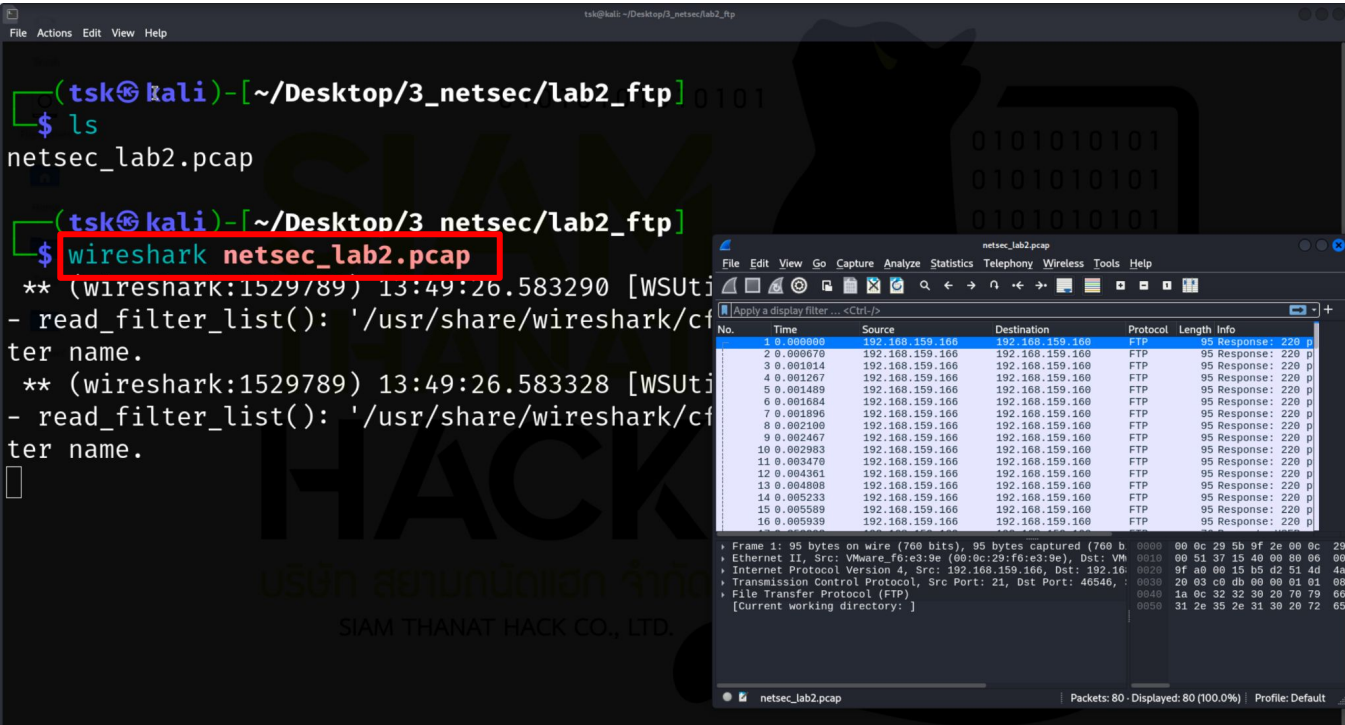
Entire conversation (818 bytes) Show data as ASCII Stream 0

Find: FLAG Find Next

Filter Out This Stream Print Save as... Back × Close Help

Lab 2 - Plaintext FTP (easy)

lab 2 - Plaintext FTP (easy)



The screenshot shows a Kali Linux terminal window with the following commands and output:

```

tsk@kali: ~/Desktop/3_netsec/lab2_ftp
$ ls
netsec_lab2.pcap

tsk@kali: ~/Desktop/3_netsec/lab2_ftp
$ wireshark netsec_lab2.pcap
** (Wireshark:1529789) 13:49:26.583290 [WSUI]
- read_filter_list(): '/usr/share/wireshark/cf
ter name.
** (Wireshark:1529789) 13:49:26.583328 [WSUI]
- read_filter_list(): '/usr/share/wireshark/cf
ter name.

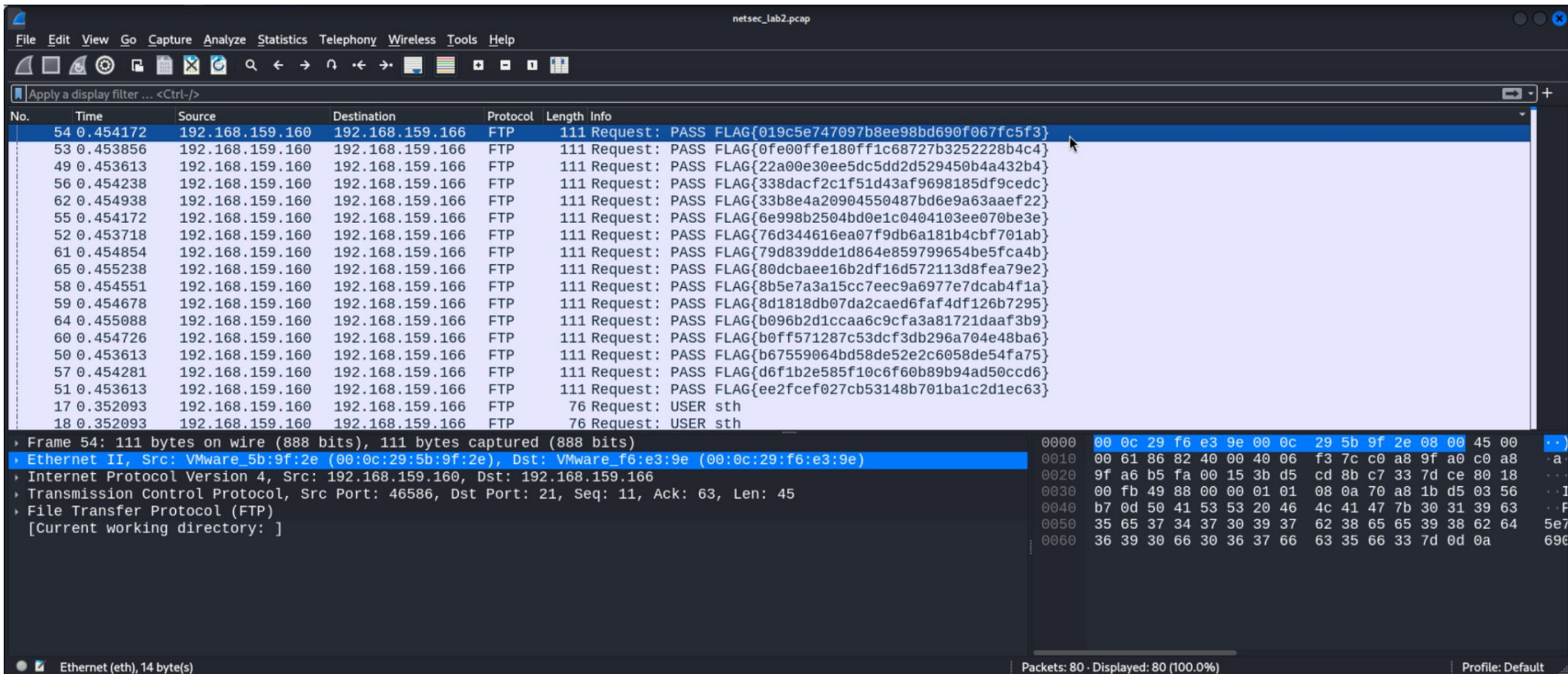
```

The Wireshark window shows the captured network traffic for the file netsec_lab2.pcap. The display filter is set to 'Apply a display filter ... <Ctrl-/>'. The packet list shows 16 packets, all of which are FTP responses from 192.168.159.166 to 192.168.159.166. The packet details pane shows the structure of the first packet (Frame 1):

- Frame 1: 95 bytes on wire (760 bits), 95 bytes captured (760 b) on interface 0
- Ethernet II, Src: VMware_f6:e3:9e (08:0c:29:f6:e3:9e), Dst: VM_00:10:00:00:00:00
- Internet Protocol Version 4, Src: 192.168.159.166, Dst: 192.168.159.166
- Transmission Control Protocol, Src Port: 21, Dst Port: 40546
- File Transfer Protocol (FTP)

The packet bytes pane shows the raw data of the first packet, which is a 95-byte FTP response.

lab 2 - Plaintext FTP (easy)



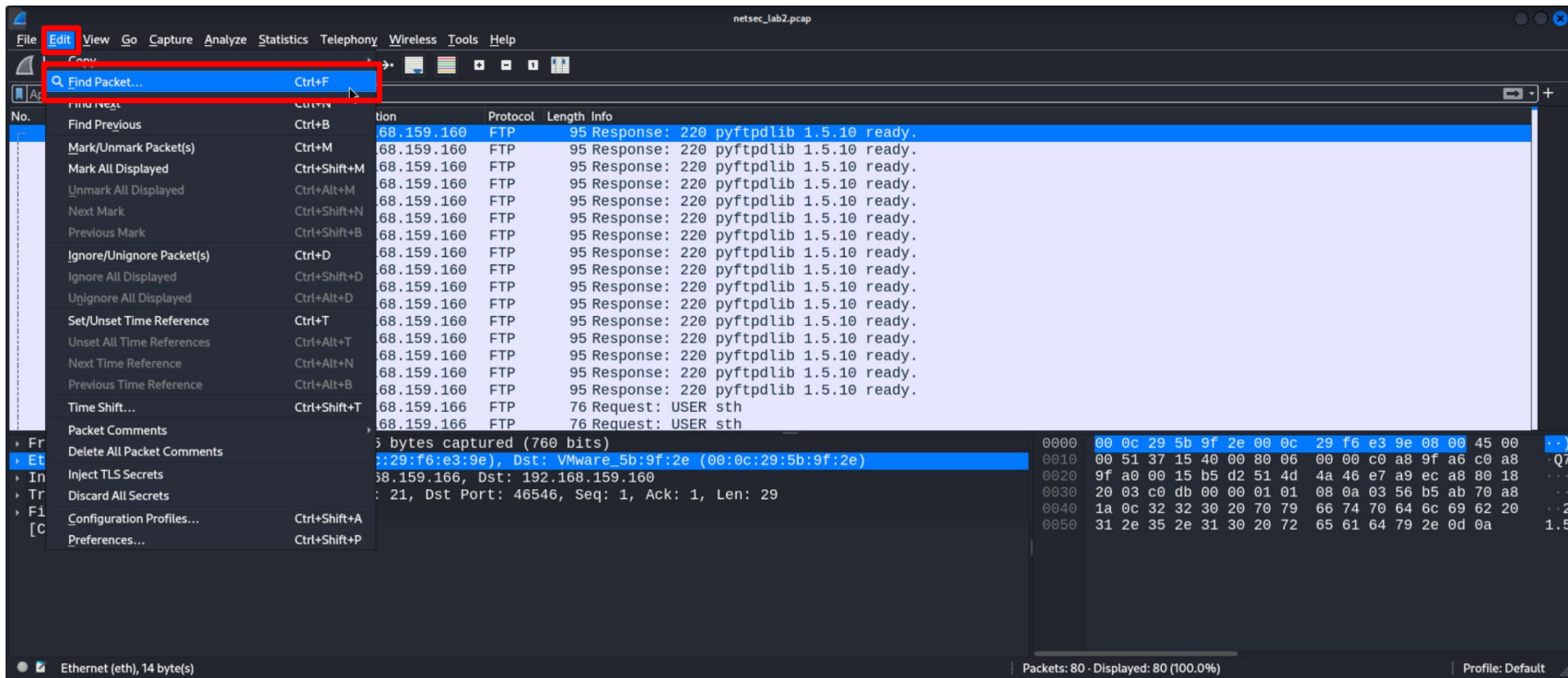
The image shows a Wireshark capture of a plaintext FTP session. The packet list on the left shows a series of FTP requests (111 Request: PASS FLAG{...}) and a final USER sth request. The packet details on the right show the structure of the FTP protocol, including the Ethernet II, Internet Protocol Version 4, Transmission Control Protocol, and File Transfer Protocol (FTP) layers. The FTP layer details show the current working directory as '/'. The packet bytes on the right show the raw data of the selected packet.

No.	Time	Source	Destination	Protocol	Length	Info
54	0.454172	192.168.159.160	192.168.159.166	FTP	111	Request: PASS FLAG{019c5e747097b8ee98bd690f067fc5f3}
53	0.453856	192.168.159.160	192.168.159.166	FTP	111	Request: PASS FLAG{0fe0ffe180ffc68727b325228b4c4}
49	0.453613	192.168.159.160	192.168.159.166	FTP	111	Request: PASS FLAG{22a00e30ee5dc5dd2d529450b4a432b4}
56	0.454238	192.168.159.160	192.168.159.166	FTP	111	Request: PASS FLAG{338dacf2c1f51d43af9698185df9cedc}
62	0.454938	192.168.159.160	192.168.159.166	FTP	111	Request: PASS FLAG{33b8e4a20904550487bd6e9a63aaef22}
55	0.454172	192.168.159.160	192.168.159.166	FTP	111	Request: PASS FLAG{6e998b2504bd0e1c0404103ee070be3e}
52	0.453718	192.168.159.160	192.168.159.166	FTP	111	Request: PASS FLAG{76d344616ea07f9db6a181b4cbf701ab}
61	0.454854	192.168.159.160	192.168.159.166	FTP	111	Request: PASS FLAG{79d839dde1d864e859799654be5fca4b}
65	0.455238	192.168.159.160	192.168.159.166	FTP	111	Request: PASS FLAG{80dcbaee16b2df16d572113d8fea79e2}
58	0.454551	192.168.159.160	192.168.159.166	FTP	111	Request: PASS FLAG{8b5e7a3a15cc7eec9a6977e7dcab4f1a}
59	0.454678	192.168.159.160	192.168.159.166	FTP	111	Request: PASS FLAG{8d1818db07da2caed6faf4df126b7295}
64	0.455088	192.168.159.160	192.168.159.166	FTP	111	Request: PASS FLAG{b096b2d1ccaa6c9cfa3a81721daaf3b9}
60	0.454726	192.168.159.160	192.168.159.166	FTP	111	Request: PASS FLAG{b0ff571287c53dcf3db296a704e48ba6}
50	0.453613	192.168.159.160	192.168.159.166	FTP	111	Request: PASS FLAG{b67559064bd58de52e2c6058de54fa75}
57	0.454281	192.168.159.160	192.168.159.166	FTP	111	Request: PASS FLAG{d6f1b2e585f10c6f60b89b94ad50ccd6}
51	0.453613	192.168.159.160	192.168.159.166	FTP	111	Request: PASS FLAG{ee2fcef027cb53148b701ba1c2d1ec63}
17	0.352093	192.168.159.160	192.168.159.166	FTP	76	Request: USER sth
18	0.352093	192.168.159.160	192.168.159.166	FTP	76	Request: USER sth

Frame 54: 111 bytes on wire (888 bits), 111 bytes captured (888 bits) on interface 0
 Ethernet II, Src: VMware 5b:9f:2e (00:0c:29:5b:9f:2e), Dst: VMware f6:e3:9e (00:0c:29:f6:e3:9e)
 Internet Protocol Version 4, Src: 192.168.159.160, Dst: 192.168.159.166
 Transmission Control Protocol, Src Port: 46586, Dst Port: 21, Seq: 11, Ack: 63, Len: 45
 File Transfer Protocol (FTP)
 [Current working directory:]

Packets: 80 - Displayed: 80 (100.0%)

lab 2 - Plaintext FTP (easy)

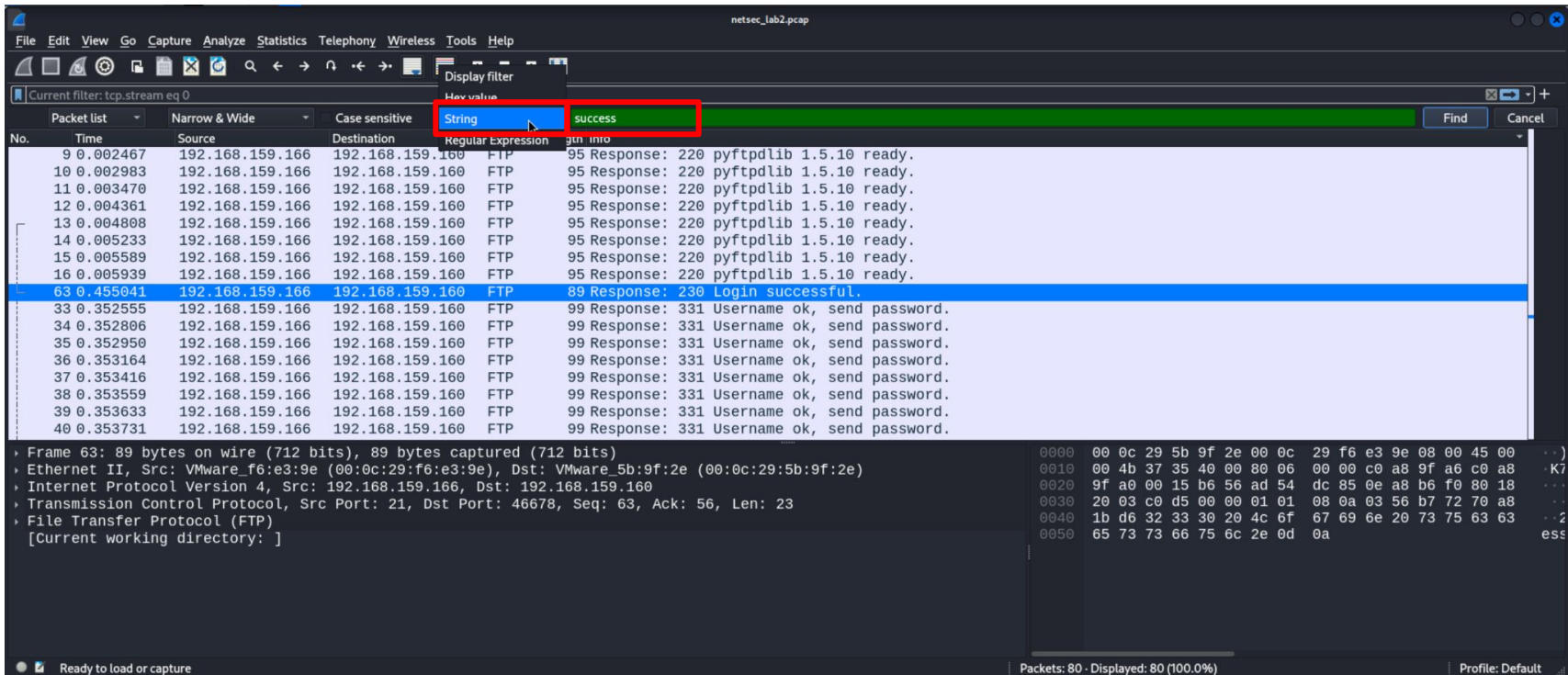


The image shows a Wireshark capture of an FTP session. The 'Edit' menu is open, highlighting the 'Find Packet...' option (Ctrl+F). The packet list shows several FTP responses (95 Response: 220 pyftplib 1.5.10 ready.) and one request (76 Request: USER sth). The packet details pane shows the selected packet (No. 21) with the following details:

- Ethernet II, Src: VMware_5b:9f:2e (00:0c:29:5b:9f:2e), Dst: 192.168.159.160
- TCP, Src Port: 21, Dst Port: 46546, Seq: 1, Ack: 1, Len: 29
- FTP, Command: USER sth

The packet bytes pane shows the raw data of the captured packet, which is the 'USER sth' command in plaintext.

lab 2 - Plaintext FTP (easy)



The image shows a Wireshark packet capture of an FTP session. The packet list on the left shows several packets, with packet 63 (89 bytes) selected. The packet details pane on the right shows the structure of the selected packet, which is an FTP response (230) indicating a successful login. The packet bytes pane at the bottom shows the raw data in hexadecimal and ASCII.

No.	Time	Source	Destination	Protocol	Length	Info
9	0.002467	192.168.159.166	192.168.159.160	FTP	95	Response: 220 pyftplib 1.5.10 ready.
10	0.002983	192.168.159.166	192.168.159.160	FTP	95	Response: 220 pyftplib 1.5.10 ready.
11	0.003470	192.168.159.166	192.168.159.160	FTP	95	Response: 220 pyftplib 1.5.10 ready.
12	0.004361	192.168.159.166	192.168.159.160	FTP	95	Response: 220 pyftplib 1.5.10 ready.
13	0.004808	192.168.159.166	192.168.159.160	FTP	95	Response: 220 pyftplib 1.5.10 ready.
14	0.005233	192.168.159.166	192.168.159.160	FTP	95	Response: 220 pyftplib 1.5.10 ready.
15	0.005589	192.168.159.166	192.168.159.160	FTP	95	Response: 220 pyftplib 1.5.10 ready.
16	0.005939	192.168.159.166	192.168.159.160	FTP	95	Response: 220 pyftplib 1.5.10 ready.
63	0.455041	192.168.159.166	192.168.159.160	FTP	89	Response: 230 Login successful.
33	0.352555	192.168.159.166	192.168.159.160	FTP	99	Response: 331 Username ok, send password.
34	0.352806	192.168.159.166	192.168.159.160	FTP	99	Response: 331 Username ok, send password.
35	0.352950	192.168.159.166	192.168.159.160	FTP	99	Response: 331 Username ok, send password.
36	0.353164	192.168.159.166	192.168.159.160	FTP	99	Response: 331 Username ok, send password.
37	0.353416	192.168.159.166	192.168.159.160	FTP	99	Response: 331 Username ok, send password.
38	0.353559	192.168.159.166	192.168.159.160	FTP	99	Response: 331 Username ok, send password.
39	0.353633	192.168.159.166	192.168.159.160	FTP	99	Response: 331 Username ok, send password.
40	0.353731	192.168.159.166	192.168.159.160	FTP	99	Response: 331 Username ok, send password.

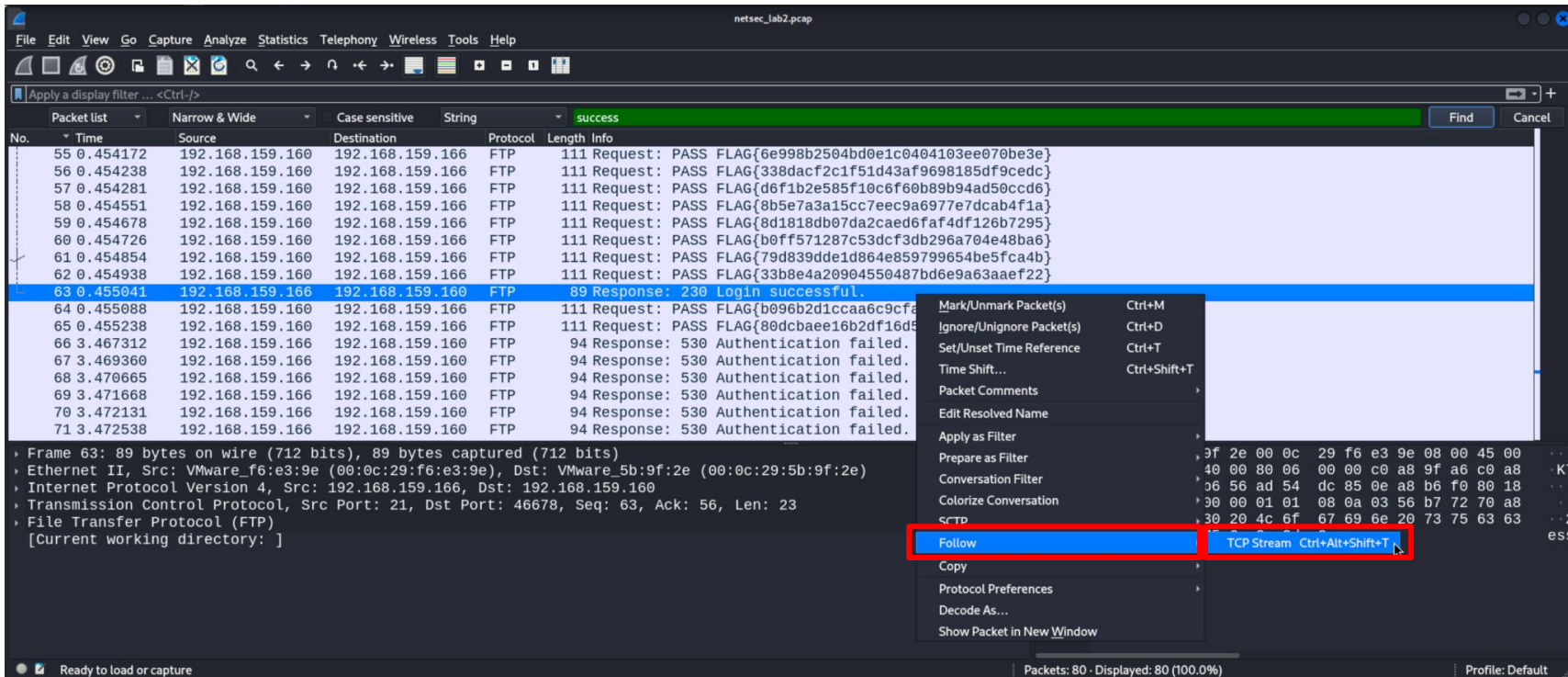
Frame 63: 89 bytes on wire (712 bits), 89 bytes captured (712 bits)
 Ethernet II, Src: VMware_f6:e3:9e (00:0c:29:f6:e3:9e), Dst: VMware_5b:9f:2e (00:0c:29:5b:9f:2e)
 Internet Protocol Version 4, Src: 192.168.159.166, Dst: 192.168.159.160
 Transmission Control Protocol, Src Port: 21, Dst Port: 46678, Seq: 63, Ack: 56, Len: 23
 File Transfer Protocol (FTP)
 [Current working directory:]

Packet bytes pane (Hex and ASCII):

```

0000  00 0c 29 5b 9f 2e 00 0c 29 f6 e3 9e 00 00 45 00
0010  00 4b 37 35 40 00 80 06 00 00 c0 a8 9f a6 c0 a8
0020  9f a0 00 15 b6 56 ad 54 dc 85 0e a8 b6 f0 80 18
0030  20 03 c0 d5 00 00 01 01 08 0a 03 56 b7 72 70 a8
0040  1b d6 32 33 30 20 4c 6f 67 69 e2 20 73 75 63 63
0050  65 73 73 66 75 6c 2e 0d 0a
  
```

lab 2 - Plaintext FTP (easy)



netser_lab2.pcap

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

Apply a display filter ... <Ctrl-/>

Packet list Narrow & Wide Case sensitive String success Find Cancel

No.	Time	Source	Destination	Protocol	Length	Info
55	0.454172	192.168.159.160	192.168.159.166	FTP	111	Request: PASS FLAG{6e998b2504bd0e1c0404103ee070be3e}
56	0.454238	192.168.159.160	192.168.159.166	FTP	111	Request: PASS FLAG{338dacf2c1f51d43af9698185df9cedc}
57	0.454281	192.168.159.160	192.168.159.166	FTP	111	Request: PASS FLAG{d6f1b2e585f10c6f60b89b94ad50ccd6}
58	0.454551	192.168.159.160	192.168.159.166	FTP	111	Request: PASS FLAG{8b5e7a3a15cc7eec9a6977e7dcab4f1a}
59	0.454678	192.168.159.160	192.168.159.166	FTP	111	Request: PASS FLAG{8d1818db07da2caed6faf4df126b7295}
60	0.454726	192.168.159.160	192.168.159.166	FTP	111	Request: PASS FLAG{b0ff571287c53dcf3db296a704e48ba6}
61	0.454854	192.168.159.160	192.168.159.166	FTP	111	Request: PASS FLAG{79d839dde1d864e859799654be5fca4b}
62	0.454938	192.168.159.160	192.168.159.166	FTP	111	Request: PASS FLAG{33b8e4a20904550487bd6e9a63aaef22}
63	0.455041	192.168.159.166	192.168.159.160	FTP	89	Response: 230 Login successful.
64	0.455088	192.168.159.160	192.168.159.166	FTP	111	Request: PASS FLAG{b096b2d1ccaa6c9cf}
65	0.455238	192.168.159.160	192.168.159.166	FTP	111	Request: PASS FLAG{80dcbaee16b2df16d5}
66	3.467312	192.168.159.166	192.168.159.160	FTP	94	Response: 530 Authentication failed.
67	3.469360	192.168.159.166	192.168.159.160	FTP	94	Response: 530 Authentication failed.
68	3.470665	192.168.159.166	192.168.159.160	FTP	94	Response: 530 Authentication failed.
69	3.471668	192.168.159.166	192.168.159.160	FTP	94	Response: 530 Authentication failed.
70	3.472131	192.168.159.166	192.168.159.160	FTP	94	Response: 530 Authentication failed.
71	3.472538	192.168.159.166	192.168.159.160	FTP	94	Response: 530 Authentication failed.

Frame 63: 89 bytes on wire (712 bits), 89 bytes captured (712 bits)

Ethernet II, Src: VMware_f6:e3:9e (00:0c:29:f6:e3:9e), Dst: VMware_5b:9f:2e (00:0c:29:5b:9f:2e)

Internet Protocol Version 4, Src: 192.168.159.166, Dst: 192.168.159.160

Transmission Control Protocol, Src Port: 21, Dst Port: 46678, Seq: 63, Ack: 56, Len: 23

File Transfer Protocol (FTP)

[Current working directory:]

Mark/Unmark Packet(s) Ctrl+M

Ignore/Unignore Packet(s) Ctrl+D

Set/Unset Time Reference Ctrl+T

Time Shift... Ctrl+Shift+T

Packet Comments

Edit Resolved Name

Apply as Filter

Prepare as Filter

Conversation Filter

Colorize Conversation

SCTP

Follow TCP Stream Ctrl+Alt+Shift+T

Copy

Protocol Preferences

Decode As...

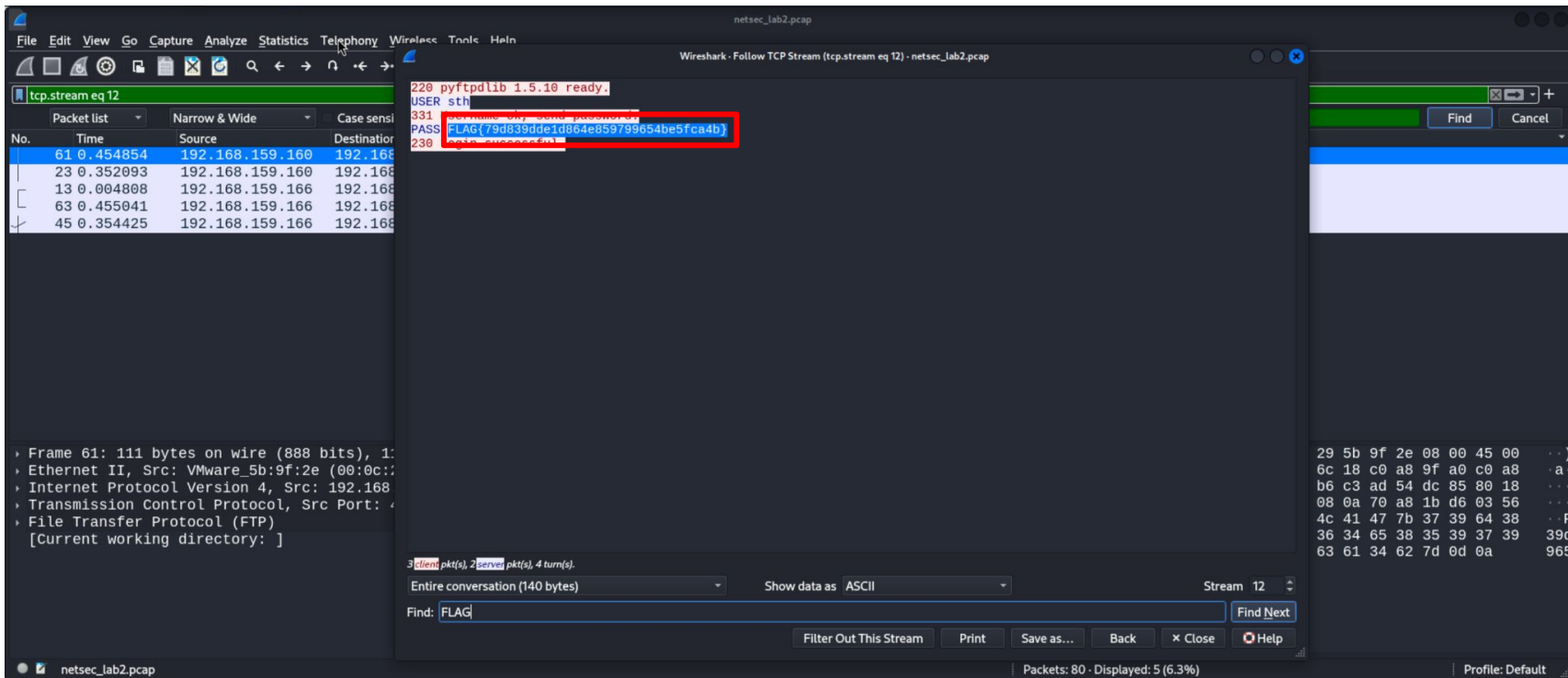
Show Packet in New Window

Ready to load or capture

Packets: 80 · Displayed: 80 (100.0%)

Profile: Default

lab 2 - Plaintext FTP (easy)



The image shows a Wireshark capture of an FTP session. The packet list on the left shows several packets, with packet 61 selected. The packet details pane on the right shows the structure of packet 61, which is an FTP PASS command. The password field is highlighted with a red box and contains the value: `FLAG(79d839dde1d864e859799654be5fca4b)`. The packet bytes pane on the right shows the raw data of the packet, which is the ASCII representation of the password.

Packet list:

No.	Time	Source	Destination
61	0.454854	192.168.159.160	192.168.159.166
23	0.352093	192.168.159.160	192.168.159.166
13	0.004808	192.168.159.166	192.168.159.160
63	0.455041	192.168.159.166	192.168.159.160
45	0.354425	192.168.159.166	192.168.159.160

Packet details (Packet 61):

- Frame 61: 111 bytes on wire (888 bits), 100 captured (880 bits) on interface
- Ethernet II, Src: VMware_5b:9f:2e (00:0c:29:5b:9f:2e), Dst: 192.168.159.166
- Internet Protocol Version 4, Src: 192.168.159.160, Dst: 192.168.159.166
- Transmission Control Protocol, Src Port: 21, Dst Port: 21
- File Transfer Protocol (FTP)
 - Current working directory:]

Packet bytes (Packet 61):

```

29 5b 9f 2e 08 00 45 00  ...
6c 18 c0 a8 9f a0 c0 a8  ...
b6 c3 ad 54 dc 85 80 18  ...
08 0a 70 a8 1b d6 03 56  ...
4c 41 47 7b 37 39 64 38  ...
36 34 65 38 35 39 37 39  ...
63 61 34 62 7d 0d 0a 96
  
```

Wireshark Follow TCP Stream (tcp.stream eq 12) - netsec_lab2.pcap:

```

220 pyftplib 1.5.10 ready.
USER sth
PASS FLAG(79d839dde1d864e859799654be5fca4b)
230
  
```

Find: FLAG

Stream 12

Filter Out This Stream | Print | Save as... | Back | × Close | Help

Packets: 80 · Displayed: 5 (6.3%)

Profile: Default

What is Nmap?

Nmap หรือ **Network Mapper** เป็นเครื่องมือแบบ Command Line และเป็น Software Open-source ที่ใช้ในการสแกนที่อยู่ IP และพอร์ตในเครือข่าย



```

[User]@[Host]:~/Desktop$ sudo nmap -ss 192.168.0.239
Starting Nmap 7.80 ( https://nmap.org ) at 2020-11-28 06:02 CST
Nmap scan report for 192.168.0.239
Host is up (0.000081s latency).
Not shown: 977 closed ports
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 08:00:27:9F:F3:C9 (Oracle VirtualBox virtual NIC)

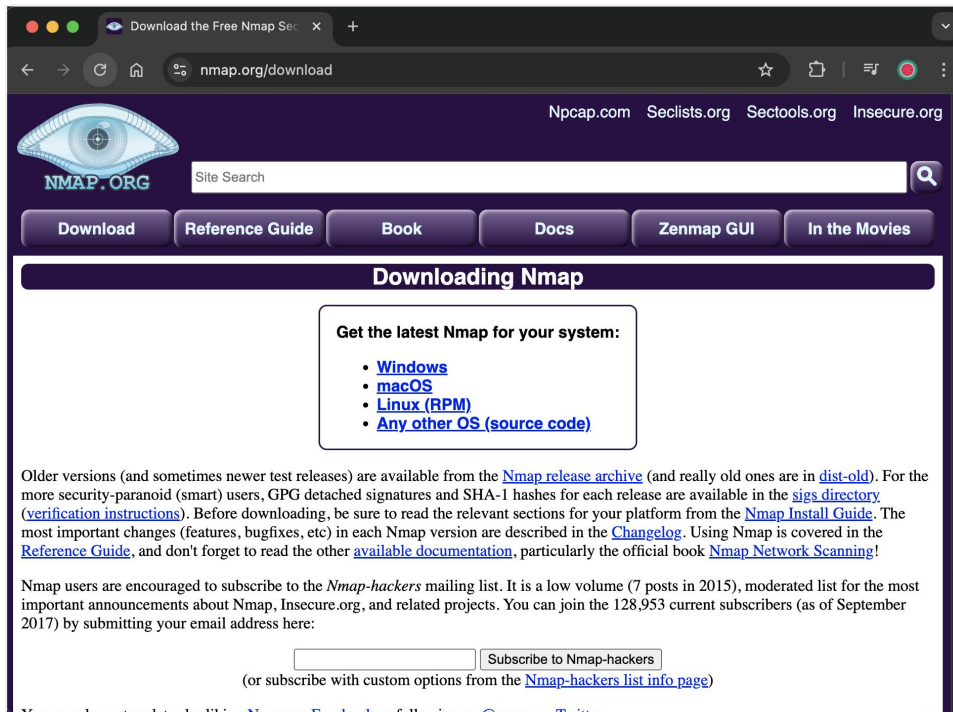
Nmap done: 1 IP address (1 host up) scanned in 11.39 seconds
[User]@[Host]:~/Desktop$
    
```


Download

สามารถดาวน์โหลดได้ที่:
<https://nmap.org/download>

ติดตั้งแบบ Command-Line

```
phoenixnap@phoenixnap-VirtualBox:~$ sudo apt-get install nmap
Reading package lists... Done
Building dependency tree
Reading state information... Done
The following additional packages will be installed:
  libblas3 liblinear3
Suggested packages:
  liblinear-tools liblinear-dev ndiff
The following NEW packages will be installed:
  libblas3 liblinear3 nmap
0 upgraded, 3 newly installed, 0 to remove and 254 not upgraded.
Need to get 5,353 kB of archives.
After this operation, 24.5 MB of additional disk space will be used.
Do you want to continue? [Y/n] y
```

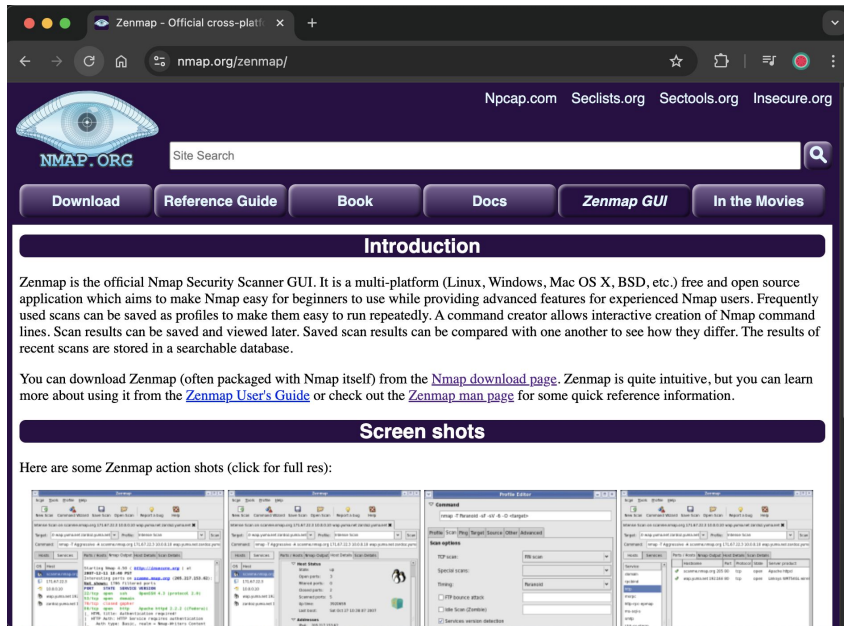


The screenshot shows the Nmap.org website's download page. At the top, there's a navigation bar with links to Npcap.com, Seclists.org, Sectools.org, and Insecure.org. Below this is a search bar and a row of buttons: Download, Reference Guide, Book, Docs, Zenmap GUI, and In the Movies. The main heading is "Downloading Nmap". A box titled "Get the latest Nmap for your system:" lists links for Windows, macOS, Linux (RPM), and Any other OS (source code). Below this, a paragraph explains that older versions are available from the Nmap release archive and that users should read the Nmap Install Guide and Changelog. It also mentions the Nmap Network Scanning book. At the bottom, there's a section for subscribing to the Nmap-hackers mailing list, with a form to enter an email address and a "Subscribe to Nmap-hackers" button. A note below the form says "(or subscribe with custom options from the Nmap-hackers list info page)".

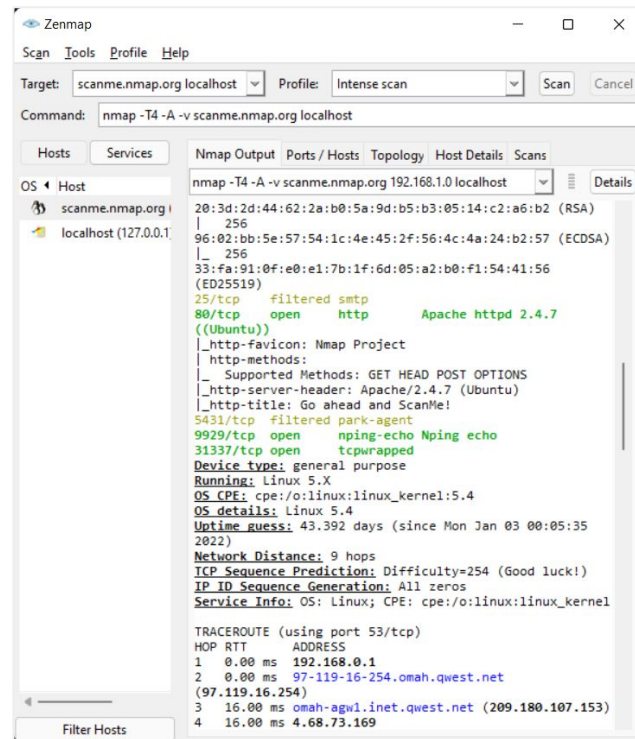
Zenmap สำหรับ Windows

สามารถดาวน์โหลดได้ที่:

<https://nmap.org/download.html#windows>



The screenshot shows the Zenmap website with a navigation bar including links to Npcap.com, Seclists.org, Sectools.org, and Insecure.org. Below the navigation bar is a search bar and buttons for Download, Reference Guide, Book, Docs, Zenmap GUI, and In the Movies. The main content area features an "Introduction" section stating that Zenmap is the official Nmap Security Scanner GUI, available for Linux, Windows, Mac OS X, BSD, etc. It is a free and open source application. The text continues: "Zenmap is the official Nmap Security Scanner GUI. It is a multi-platform (Linux, Windows, Mac OS X, BSD, etc.) free and open source application which aims to make Nmap easy for beginners to use while providing advanced features for experienced Nmap users. Frequently used scans can be saved as profiles to make them easy to run repeatedly. A command creator allows interactive creation of Nmap command lines. Scan results can be saved and viewed later. Saved scan results can be compared with one another to see how they differ. The results of recent scans are stored in a searchable database." Below this, it says: "You can download Zenmap (often packaged with Nmap itself) from the [Nmap download page](#). Zenmap is quite intuitive, but you can learn more about using it from the [Zenmap User's Guide](#) or check out the [Zenmap man page](#) for some quick reference information." At the bottom, there is a "Screen shots" section with the text: "Here are some Zenmap action shots (click for full res):" followed by four small thumbnail images of the Zenmap interface.



The screenshot shows the Zenmap application window. The "Target" field is set to "scanme.nmap.org localhost" and the "Profile" is "Intense scan". The "Command" field shows the command: "nmap -T4 -A -v scanme.nmap.org localhost". The "Hosts" tab is selected, showing a list of hosts: "scanme.nmap.org" and "localhost (127.0.0.1)". The "Nmap Output" tab is selected, displaying the scan results for "scanme.nmap.org". The output includes various details such as OS detection (Linux 5.X), supported methods (GET HEAD POST OPTIONS), and service information (Apache/2.4.7 (Ubuntu)). At the bottom, the "TRACEROUTE" section shows the path to the destination IP (192.168.0.1) with hop times and addresses.

ตัวอย่างการใช้ nmap

```
$ nmap {domain_or_ip}
```

```
admin@ip-172-26-0-73:~$ nmap scanme.nmap.org

Starting Nmap 7.40 ( https://nmap.org ) at 2020-07-22 02:48 UTC
Nmap scan report for scanme.nmap.org (45.33.32.156)
Host is up (0.078s latency).
Other addresses for scanme.nmap.org (not scanned): 2600:3c01::f03c:91ff:fe18:bb2f
Not shown: 995 closed ports
PORT      STATE      SERVICE
22/tcp    open      ssh
25/tcp    filtered  smtp
80/tcp    open      http
9929/tcp  open      nping-echo
31337/tcp open      Elite

Nmap done: 1 IP address (1 host up) scanned in 2.40 seconds
admin@ip-172-26-0-73:~$ █
```


Lab 3 - Uncommon TCP Port (medium)

lab 3 - Uncommon TCP Port (medium)

```
(tsk@kali)-[~/Desktop/3_netsec/lab3_uncommon-tcp-port/netsec_lab3_nmap-high-port]
```

```
$ nmap --open -p- localhost
```

```
Starting Nmap 7.95 ( https://nmap.org ) at 2025-06-27 13:59 +07
```

```
Nmap scan report for localhost (127.0.0.1)
```

```
Host is up (0.0000010s latency).
```

```
Other addresses for localhost (not scanned): ::1
```

```
Not shown: 65533 closed tcp ports (reset)
```

```
PORT      STATE SERVICE
```

```
1337/tcp  open  waste
```

```
33821/tcp open  unknown
```

```
Nmap done: 1 IP address (1 host up) scanned in 0.37 seconds
```

lab 3 - Uncommon TCP Port (medium)

```
(tsk@kali)-[~/Desktop/3_netsec/lab3_uncommon-tcp-port/netsec_lab3_nmap-high-port]
$ curl localhost:1337
curl: (1) Received HTTP/0.9 when not allowed

(tsk@kali)-[~/Desktop/3_netsec/lab3_uncommon-tcp-port/netsec_lab3_nmap-high-port]
$ curl --http0.9 localhost:1337
FLAG{NMAP_HIGH_PORT}
```

lab 3 - Uncommon TCP Port (medium)

```
(tsk@kali) - [~/Desktop/3_netsec/lab3_uncommon-tcp-port/netsec_lab3_nmap-high-port]
$ nmap --open -sV -p 1337 localhost
Starting Nmap 7.95 ( https://nmap.org ) at 2025-06-27 14:00 +07
Nmap scan report for localhost (127.0.0.1)
Host is up (0.000080s latency).
Other addresses for localhost (not scanned): ::1

PORT      STATE SERVICE VERSION
1337/tcp  open  waste?
1 service unrecognized despite returning data. If you know the service/version, please submit the following fingerprint at https://nmap.org/cgi-bin/submit.cgi?new-service :
_
SF:Port1337-TCP:V=7.95%I=7%D=6/27%Time=685E41A3%P=aarch64-unknown-linux-gn
SF:u%r(NULL,15,"FLAG{NMAP_HIGH_PORT}\n")%r(GenericLines,15,"FLAG{NMAP_HIGH
SF:_PORT}\n")%r(GetRequest,15,"FLAG{NMAP_HIGH_PORT}\n")%r(HTTPOptions,15,"
SF:FLAG{NMAP_HIGH_PORT}\n")%r(RTSPRequest,15,"FLAG{NMAP_HIGH_PORT}\n")%r(R
SF:PCCheck,15,"FLAG{NMAP_HIGH_PORT}\n")%r(DNSVersionBindReqTCP,15,"FLAG{NM
SF:AP_HIGH_PORT}\n")%r(DNSStatusRequestTCP,15,"FLAG{NMAP_HIGH_PORT}\n")%r(
SF:Help,15,"FLAG{NMAP_HIGH_PORT}\n")%r(SSLSessionReq,15,"FLAG{NMAP_HIGH_PO
SF:RT}\n")%r(TerminalServerCookie,15,"FLAG{NMAP_HIGH_PORT}\n")%r(TLSSessio
SF:nReq,15,"FLAG{NMAP_HIGH_PORT}\n")%r(Kerberos,15,"FLAG{NMAP_HIGH_PORT}\n
SF:")%r(SMBProgNeg,15,"FLAG{NMAP_HIGH_PORT}\n")%r(X11Probe,15,"FLAG{NMAP_H
SF:IGH_PORT}\n")%r(FourOhFourRequest,15,"FLAG{NMAP_HIGH_PORT}\n")%r(LPDStr
SF:ing,15,"FLAG{NMAP_HIGH_PORT}\n")%r(LDAPSearchReq,15,"FLAG{NMAP_HIGH_POR
SF:T}\n")%r(LDAPBindReq,15,"FLAG{NMAP_HIGH_PORT}\n")%r(SIPOptions,15,"FLAG
SF:{NMAP_HIGH_PORT}\n")%r(LANDesk-RC,15,"FLAG{NMAP_HIGH_PORT}\n")%r(Termin
SF:alServer,15,"FLAG{NMAP_HIGH_PORT}\n")%r(NCP,15,"FLAG{NMAP_HIGH_PORT}\n"
SF:)%r(NotesRPC,15,"FLAG{NMAP_HIGH_PORT}\n")%r(JavaRMI,15,"FLAG{NMAP_HIGH_
SF:PORT}\n")%r(WMSRequest,15,"FLAG{NMAP_HIGH_PORT}\n")%r(oracle-tns,15,"FL
SF:AG{NMAP_HIGH_PORT}\n")%r(ms-sql-s,15,"FLAG{NMAP_HIGH_PORT}\n")%r(afp,15
SF:,"FLAG{NMAP_HIGH_PORT}\n")%r(giop,15,"FLAG{NMAP_HIGH_PORT}\n");

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
```

Edit -> lab 3 - Uncommon TCP Port (medium)

```
$ sudo nmap scanme.p7z.pw -Pn --open -p-
```

```
Starting Nmap 7.95 ( https://nmap.org ) at 2025-06-28 09:55 +07
```

```
sendto in send_ip_packet_sd: sendto(6, packet, 44, 0, 165.22.62.59, 16) => Protocol wrong type for socket
```

```
Nmap scan report for scanme.p7z.pw (165.22.62.59)
```

```
Host is up (0.0081s latency).
```

```
Not shown: 65531 filtered tcp ports (no-response)
```

```
Some closed ports may be reported as filtered due to --defeat-rst-ratelimit
```

PORT	STATE	SERVICE
25/tcp	open	smtp
53/tcp	open	domain
80/tcp	open	http
11337/tcp	open	unknown

Edit -> lab 3 - Uncommon TCP Port (medium)

```
$ nc scanme.p7z.pw 11337
```

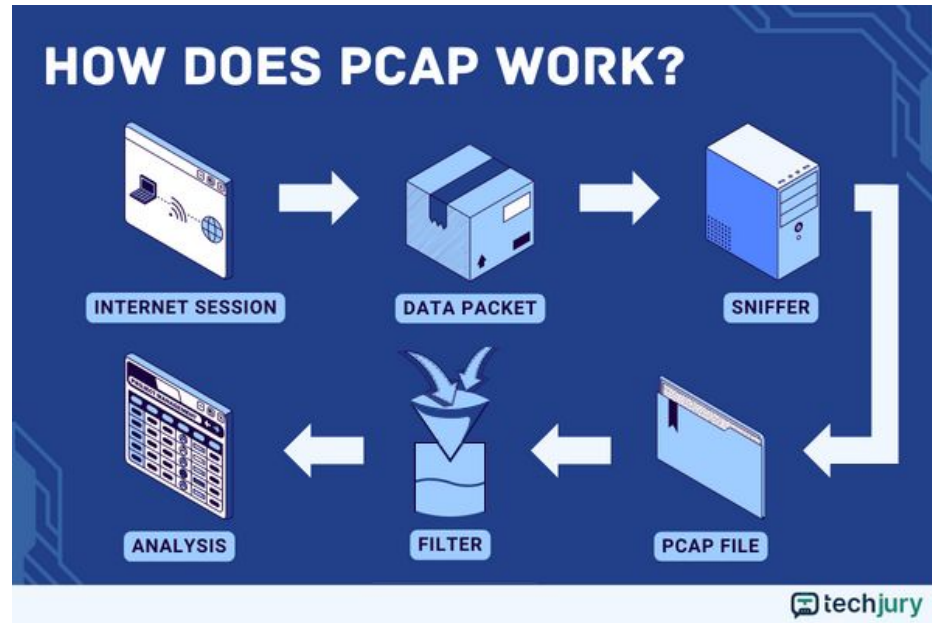


```
(tsk@kali)-[~]  
$ nc scanme.p7z.pw 11337  
FLAG{NMAP_HIGH_PORT}
```

SIAM THANAT HACK CO., LTD.

PCAPNG to PCAP

```
$ tshark -F pcap -r ${pcapng_file} -w ${pcap_file}
```



<https://techjury.net>

Lab bonus - Encoded C2 (hard)

lab bonus - Encoded C2 (hard)

```
(tsk@kali)-[~/Desktop/3_netsec/lab-bonus_Encoded-C2]
$ ls -lha
total 24K
drwxrwxr-x 2 tsk tsk 4.0K Jun 28 00:04 .
drwxrwxr-x 6 tsk tsk 4.0K Jun 28 00:06 ..
-rw-r--r-- 1 tsk tsk 14K Jun 15 2024 netsec_bonus.pcapng

(tsk@kali)-[~/Desktop/3_netsec/lab-bonus_Encoded-C2]
$ tshark -F pcap -r netsec_bonus.pcapng -w netsec_bonus.pcap
```

\$ tshark -F pcap -r netsec_bonus.pcapng -w netsec_bonus.pcap

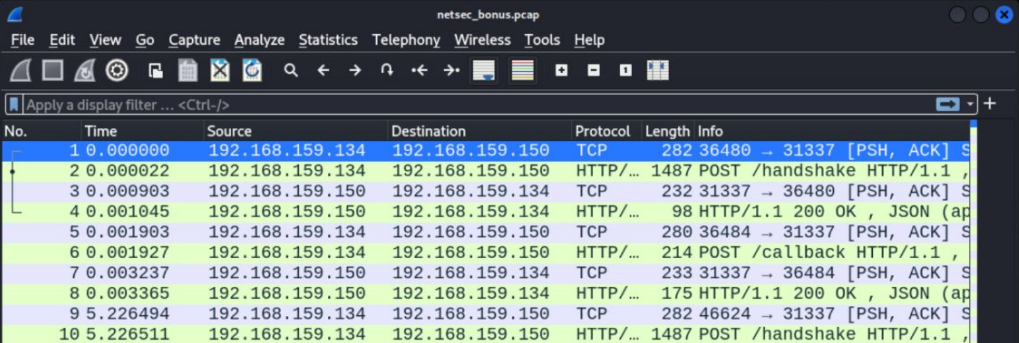
lab bonus - Encoded C2 (hard)

```

(tsk@kali)-[~/Desktop/3_netsec/lab-bonus_Encoded-C2]
$ tshark -F pcap -r netsec_bonus.pcapng -w netsec_bonus.pcap
** (tshark:2118661) 00:13:33.812671 [WSUtil WARNING] ./wsutil/filter_files.c:242 -- read_filter_list():
'/usr/share/wireshark/cfilters' line 1 doesn't have a quoted filter name.
** (tshark:2118661) 00:13:33.812723 [WSUtil WARNING] ./wsutil/filter_files.c:242 -- read_filter_list():
'/usr/share/wireshark/cfilters' line 2 doesn't have a quoted filter name.
[Checksum status: Unverified]
(tsk@kali)-[~/Desktop/3_netsec/lab-bonus_Encoded-C2]
$ ls -lha
total 40K
drwxrwxr-x 2 tsk tsk 4.0K Jun 28 00:13 .
drwxrwxr-x 6 tsk tsk 4.0K Jun 28 00:06 ..
-rw-rw-r-- 1 tsk tsk 14K Jun 28 00:13 netsec_bonus.pcap
-rw-r--r-- 1 tsk tsk 14K Jun 15 2024 netsec_bonus.pcapng
  
```

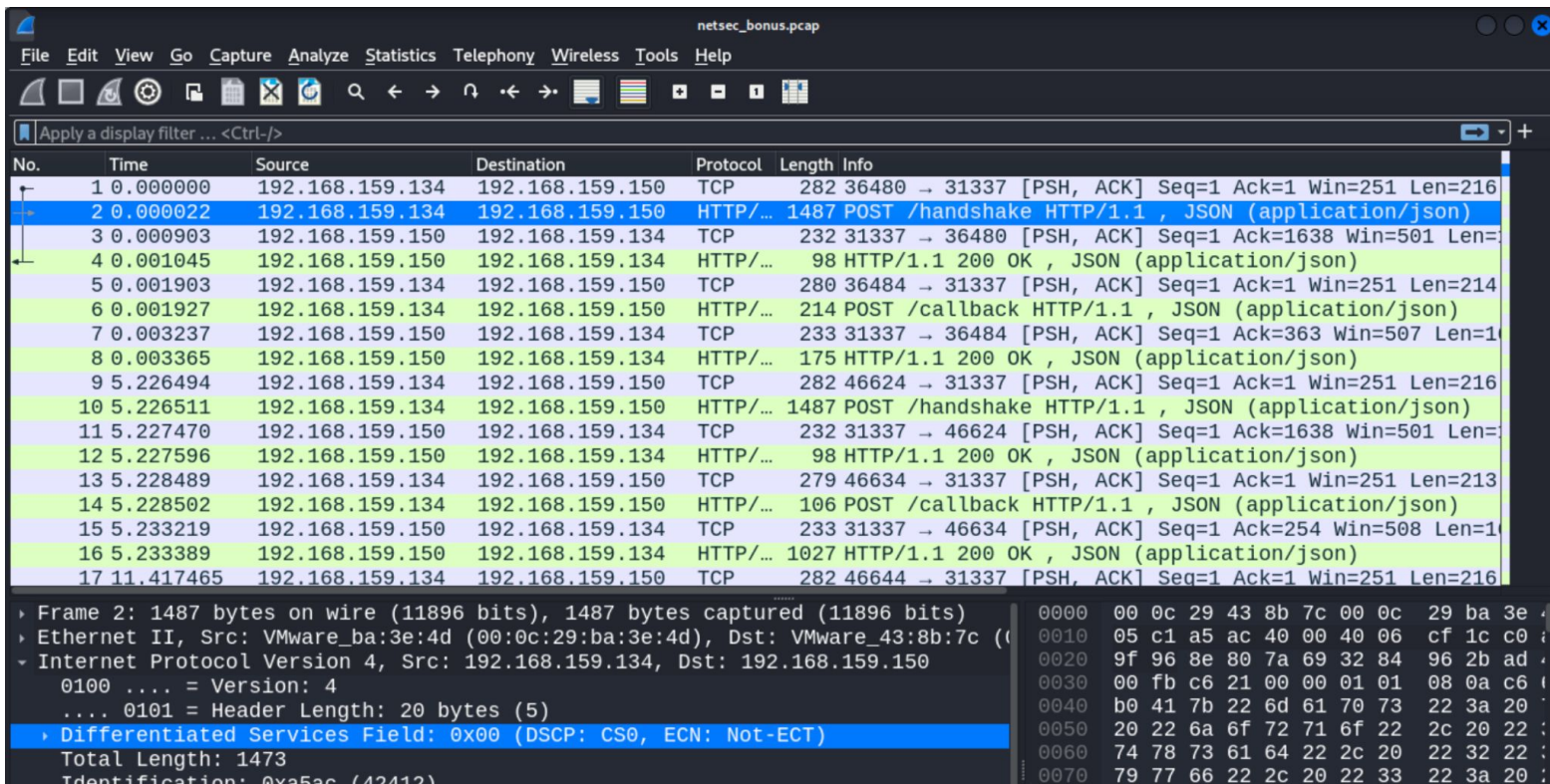
lab bonus - Encoded C2 (hard)

```
(tsk@kali)-[~/Desktop/3 netsec/lab-bonus_Encoded-C2]
$ wireshark netsec_bonus.pcap
** (wireshark:2119393) 00:14:30.302875 [WSUtil WARNING] ./wsutil/filter_files.c:242 -- read_filter_list
(:) '/usr/share/wireshark/cfilters' line 1 doesn't have a quoted filter name.
** (wireshark:2119393) 00:14:30.302935 [WSUtil WARNING] ./wsutil/filter_files.c:242 -- read_filter_list
(:) '/usr/share/wireshark/cfilters' line 2 doesn't have a quoted filter name.
```



No.	Time	Source	Destination	Protocol	Length	Info
1	0.000000	192.168.159.134	192.168.159.150	TCP	282	36480 → 31337 [PSH, ACK] S
2	0.000022	192.168.159.134	192.168.159.150	HTTP/...	1487	POST /handshake HTTP/1.1 ,
3	0.000903	192.168.159.150	192.168.159.134	TCP	232	31337 → 36480 [PSH, ACK] S
4	0.001045	192.168.159.150	192.168.159.134	HTTP/...	98	HTTP/1.1 200 OK , JSON (ap
5	0.001903	192.168.159.134	192.168.159.150	TCP	280	36484 → 31337 [PSH, ACK] S
6	0.001927	192.168.159.134	192.168.159.150	HTTP/...	214	POST /callback HTTP/1.1 ,
7	0.003237	192.168.159.150	192.168.159.134	TCP	233	31337 → 36484 [PSH, ACK] S
8	0.003365	192.168.159.150	192.168.159.134	HTTP/...	175	HTTP/1.1 200 OK , JSON (ap
9	5.226494	192.168.159.134	192.168.159.150	TCP	282	46624 → 31337 [PSH, ACK] S
10	5.226511	192.168.159.134	192.168.159.150	HTTP/...	1487	POST /handshake HTTP/1.1 ,

lab bonus - Encoded C2 (hard)



netsec_bonus.pcap

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

Apply a display filter ... <Ctrl-F>

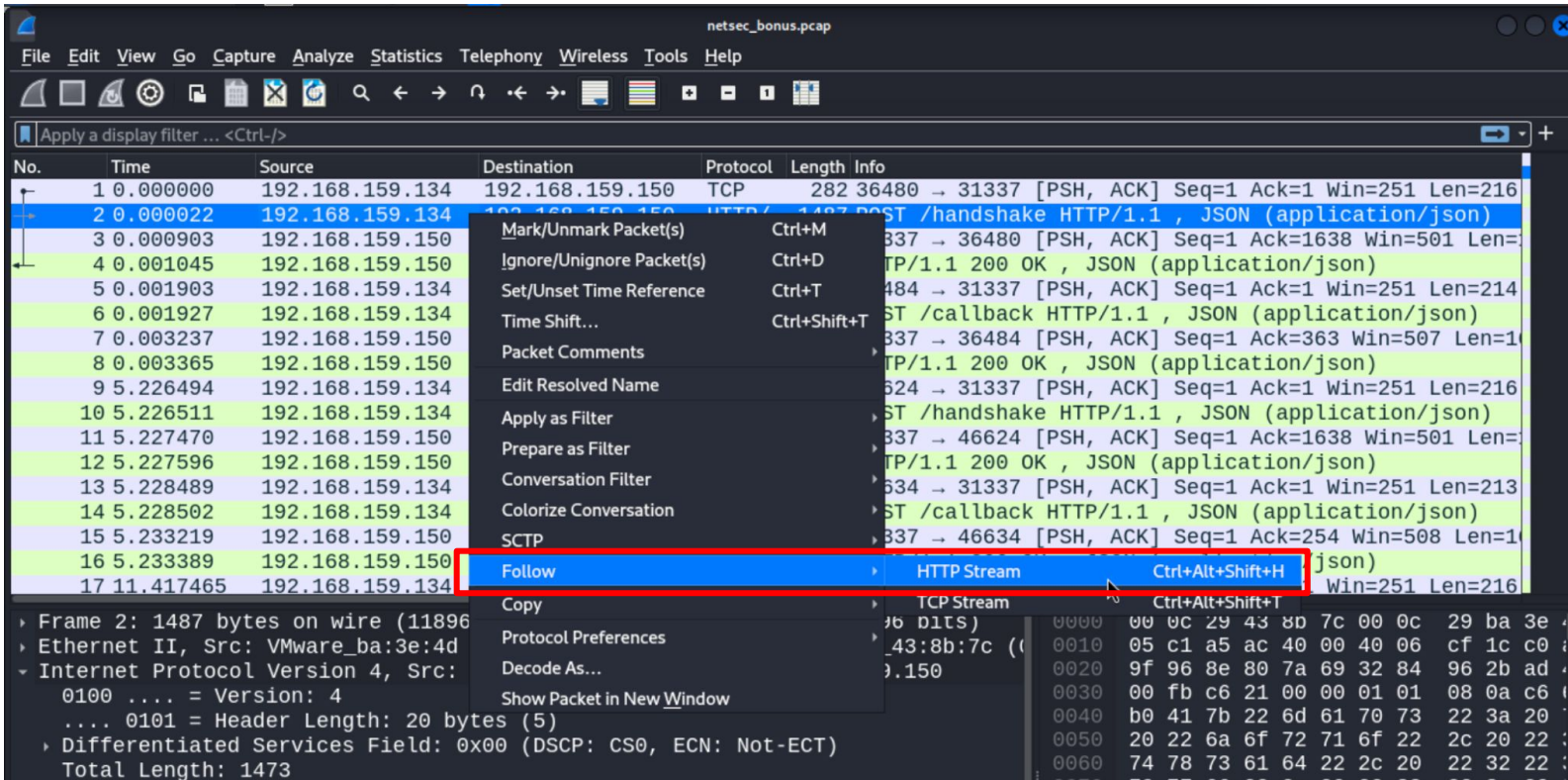
No.	Time	Source	Destination	Protocol	Length	Info
1	0.000000	192.168.159.134	192.168.159.150	TCP	282	36480 → 31337 [PSH, ACK] Seq=1 Ack=1 Win=251 Len=216
2	0.000022	192.168.159.134	192.168.159.150	HTTP/...	1487	POST /handshake HTTP/1.1 , JSON (application/json)
3	0.000903	192.168.159.150	192.168.159.134	TCP	232	31337 → 36480 [PSH, ACK] Seq=1 Ack=1638 Win=501 Len=
4	0.001045	192.168.159.150	192.168.159.134	HTTP/...	98	HTTP/1.1 200 OK , JSON (application/json)
5	0.001903	192.168.159.134	192.168.159.150	TCP	280	36484 → 31337 [PSH, ACK] Seq=1 Ack=1 Win=251 Len=214
6	0.001927	192.168.159.134	192.168.159.150	HTTP/...	214	POST /callback HTTP/1.1 , JSON (application/json)
7	0.003237	192.168.159.150	192.168.159.134	TCP	233	31337 → 36484 [PSH, ACK] Seq=1 Ack=363 Win=507 Len=1
8	0.003365	192.168.159.150	192.168.159.134	HTTP/...	175	HTTP/1.1 200 OK , JSON (application/json)
9	5.226494	192.168.159.134	192.168.159.150	TCP	282	46624 → 31337 [PSH, ACK] Seq=1 Ack=1 Win=251 Len=216
10	5.226511	192.168.159.134	192.168.159.150	HTTP/...	1487	POST /handshake HTTP/1.1 , JSON (application/json)
11	5.227470	192.168.159.150	192.168.159.134	TCP	232	31337 → 46624 [PSH, ACK] Seq=1 Ack=1638 Win=501 Len=
12	5.227596	192.168.159.150	192.168.159.134	HTTP/...	98	HTTP/1.1 200 OK , JSON (application/json)
13	5.228489	192.168.159.134	192.168.159.150	TCP	279	46634 → 31337 [PSH, ACK] Seq=1 Ack=1 Win=251 Len=213
14	5.228502	192.168.159.134	192.168.159.150	HTTP/...	106	POST /callback HTTP/1.1 , JSON (application/json)
15	5.233219	192.168.159.150	192.168.159.134	TCP	233	31337 → 46634 [PSH, ACK] Seq=1 Ack=254 Win=508 Len=1
16	5.233389	192.168.159.150	192.168.159.134	HTTP/...	1027	HTTP/1.1 200 OK , JSON (application/json)
17	11.417465	192.168.159.134	192.168.159.150	TCP	282	46644 → 31337 [PSH, ACK] Seq=1 Ack=1 Win=251 Len=216

▶ Frame 2: 1487 bytes on wire (11896 bits), 1487 bytes captured (11896 bits)
 ▶ Ethernet II, Src: VMware_ba:3e:4d (00:0c:29:ba:3e:4d), Dst: VMware_43:8b:7c (00:0c:29:43:8b:7c)
 ▶ Internet Protocol Version 4, Src: 192.168.159.134, Dst: 192.168.159.150
 0100 = Version: 4
 0101 = Header Length: 20 bytes (5)
 ▶ Differentiated Services Field: 0x00 (DSCP: CS0, ECN: Not-ECT)
 Total Length: 1473
 Identification: 0xa5ac (42412)

```

0000  00 0c 29 43 8b 7c 00 0c 29 ba 3e 4d 00 0c 29 43 8b 7c
0010  05 c1 a5 ac 40 00 40 06 cf 1c c0 00 00 00 00 00 00
0020  9f 96 8e 80 7a 69 32 84 96 2b ad 00 00 00 00 00 00
0030  00 fb c6 21 00 00 01 01 08 0a c6 00 00 00 00 00 00
0040  b0 41 7b 22 6d 61 70 73 22 3a 20 00 00 00 00 00 00
0050  20 22 6a 6f 72 71 6f 22 2c 20 22 2c 20 22 2c 20 22
0060  74 78 73 61 64 22 2c 20 22 32 22 2c 20 22 32 22 2c
0070  79 77 66 22 2c 20 22 33 22 3a 20 22 3a 20 22 3a 20
  
```


lab bonus - Encoded C2 (hard)



The image shows a Wireshark capture of a network packet. The packet list pane shows 17 packets. Packet 17 is selected, and a context menu is open over it. The menu options are:

- Mark/Unmark Packet(s) Ctrl+M
- Ignore/Unignore Packet(s) Ctrl+D
- Set/Unset Time Reference Ctrl+T
- Time Shift... Ctrl+Shift+T
- Packet Comments
- Edit Resolved Name
- Apply as Filter
- Prepare as Filter
- Conversation Filter
- Colorize Conversation
- SCTP
- Follow** (highlighted with a red box)
 - HTTP Stream Ctrl+Alt+Shift+H
 - TCP Stream Ctrl+Alt+Shift+T
- Copy
- Protocol Preferences
- Decode As...
- Show Packet in New Window

The packet details pane shows the following information:

- Frame 2: 1487 bytes on wire (11896 bits)
- Ethernet II, Src: VMware_ba:3e:4d
- Internet Protocol Version 4, Src: 192.168.159.134, Destination: 192.168.159.150
- Differentiated Services Field: 0x00 (DSCP: CS0, ECN: Not-ECT)
- Total Length: 1473

The packet bytes pane shows the raw data of the packet, including the IP header and the application/json payload.

lab bonus - Encoded C2 (hard)

Wireshark - Follow HTTP Stream (tcp.stream eq 0) - netsec_bonus.pcap

```
POST /handshake HTTP/1.1
Host: 192.168.159.150:31337
User-Agent: python-requests/2.32.2
Accept-Encoding: gzip, deflate
Accept: */*
Connection: keep-alive
Content-Length: 1421
Content-Type: application/json

{"maps": {"0": "jorqo", "1": "txsad", "2": "zqywf", "3": "vykaf", "4": "cayxr", "5": "eambl", "6": "odjsx", "7": "gtajs", "8": "kfjdw", "9": "tjsax", "a": "zobfd", "b": "pbkaj", "c": "gyyjo", "d": "qrzgs", "e": "ynfwu", "f": "ievya", "g": "plohn", "h": "bqcrq", "i": "rrlld", "j": "jwtdt", "k": "burrx", "l": "dsxdw", "m": "qqcue", "n": "vgsri", "o": "tjwtp", "p": "yfkmv", "q": "epmus", "r": "yrtvw", "s": "zymcr", "t": "myjxh", "u": "cueev", "v": "qwnzw", "w": "oomff", "x": "wiyuq", "y": "ubatu", "z": "lnbbu", "A": "qflo", "B": "xoqnn", "C": "gaqxg", "D": "frvyx", "E": "whdnh", "F": "bdvfv", "G": "ralnz", "H": "eglbh", "I": "ljccp", "J": "ndsni", "K": "ickzp", "L": "dvtat", "M": "jnnrs", "N": "lkmwf", "O": "ecqyv", "P": "phzhz", "Q": "bwxtu", "R": "qiyhj", "S": "vdnja", "T": "baome", "U": "ybhof", "V": "kgivi", "W": "uaimi", "X": "jgvnh", "Y": "vzsgx", "Z": "raffw", "0": "smvgw", "1": "hhdhi", "2": "najdn", "3": "vbjpk", "4": "vzsjc", "5": "zogh", "6": "dwrgb", "7": "dympe", "8": "qvshp", "9": "gaxoj", "a": "rlein", "b": "shuyd", "c": "pitvd", "d": "fhtag", "e": "uphnt", "f": "sahba", "g": "qxlt", "h": "axwvl", "i": "uhfai", "j": "gqufc", "k": "offfr", "l": "ionmm", "m": "msypz", "n": "yfdsk", "o": "qkpsi", "p": "imvyv", "q": "iyaeu", "r": "tomho", "s": "gmuli", "t": "sddq", "u": "uirce", "v": "xqkuw", "w": "rxwvx", "x": "ygxlg", "y": "ozppf", "z": "acfq", "A": "u000b", "B": "iqdak", "C": "rgdku"}}HTTP/1.1
200 OK
Server: Werkzeug/3.0.3 Python/3.10.12
Date: Sat, 15 Jun 2024 10:11:37 GMT
Content-Type: application/json
Content-Length: 32
Connection: close

{"status": "handshake received"}
```

Packet 2: client pkt(s), server pkt(s), 1 turn(s). Click to select.

Entire conversation (1835 bytes) Show data as ASCII Stream 0

Wireshark - Follow HTTP Stream (tcp.stream eq 1) - netsec_bonus.pcap

```
POST /callback HTTP/1.1
Host: 192.168.159.150:31337
User-Agent: python-requests/2.32.2
Accept-Encoding: gzip, deflate
Accept: */*
Connection: keep-alive
Content-Length: 148
Content-Type: application/json

{"cmd": "ynfwu gyyjo bqcrq tjwtp rxwvx hhdhi dsxdw tjwtp vgsri plohn gyyjo zobfd myjxh rxwvx oomff zobfd zymcr rxwvx bqcrq ynfwu yrtvw ynfwu hhdhi"}HTTP/1.1 200 OK
Server: Werkzeug/3.0.3 Python/3.10.12
Date: Sat, 15 Jun 2024 10:11:37 GMT
Content-Type: application/json
Content-Length: 109
Connection: close

{"answer": "dsxdw tjwtp vgsri plohn gyyjo zobfd myjxh rxwvx oomff zobfd zymcr rxwvx bqcrq ynfwu yrtvw ynfwu"}
```

Packet 8: client pkt(s), server pkt(s), 1 turn(s). Click to select.

Entire conversation (638 bytes) Show data as ASCII Stream 1

lab bonus - Encoded C2 (hard)

Wireshark - Follow HTTP Stream (tcp.stream eq 0) - netsec_bonus.pcap

```
POST /handshake HTTP/1.1
Host: 192.168.159.150:31337
User-Agent: python-requests/2.32.2
Accept-Encoding: gzip, deflate
Accept: */*
Connection: keep-alive
Content-Length: 1421
Content-Type: application/json

{"maps": {"0": "jorqo", "1": "txsad", "2": "zqywf", "3": "vykaf", "4": "cayxi", "5": "eambl", "6": "odjx", "7": "gtajs", "8": "kfjdw", "9": "tjsax", "a": "zobfd", "b": "pbkaj", "c": "qzgs", "d": "ynfwu", "e": "ievy", "f": "ploh", "g": "yfkvw", "h": "bqcrq", "i": "rrlld", "j": "jwtd", "k": "burx", "l": "dsxdw", "m": "qqcue", "n": "vgsri", "o": "tjwtp", "p": "yfkvw", "q": "emus", "r": "yrtvw", "s": "zymcr", "t": "ajj", "u": "cueev", "v": "qwnzw", "w": "oomff", "x": "wiyuq", "y": "ubatu", "z": "lnbbu", "A": "qfloh", "B": "xoqnn", "C": "jaqxg", "D": "frvyx", "E": "whdnh", "F": "bdvfv", "G": "ralnz", "H": "eglbh", "I": "ljccp", "J": "ndsni", "K": "ickzp", "L": "dvtat", "M": "jnnrs", "N": "lkmwf", "O": "ecqyv", "P": "phzhz", "Q": "bwxtu", "R": "qiyhj", "S": "vdnja", "T": "baome", "U": "ybhof", "V": "kgivi", "W": "uaimi", "X": "jgvnh", "Y": "vzsgx", "Z": "raffw", "0": "smvgw", "1": "hhdhi", "2": "najdn", "3": "vbjkg", "4": "vzsjc", "5": "zogh", "6": "dwrgb", "7": "dympe", "8": "qvshp", "9": "gaxoj", "a": "lein", "b": "shuyd", "c": "pitvd", "d": "fhtag", "e": "uphnt", "f": "sahba", "g": "qxlto", "h": "axwvl", "i": "uhfai", "j": "gqufc", "k": "offfr", "l": "ionmm", "m": "msypz", "n": "yfdsk", "o": "qkpsi", "p": "imyyv", "q": "iyaeu", "r": "tomho", "s": "gmuli", "t": "sddq", "u": "uirce", "v": "xqkuw", "w": "rxwvx", "x": "ygxlg", "y": "ozppf", "z": "acp", "A": "u000b", "B": "iqdak", "C": "rgdku"}, "HTTP/1.1"}

200 OK
Server: Werkzeug/3.0.3 Python/3.10.12
Date: Sat, 15 Jun 2024 10:11:37 GMT
Content-Type: application/json
Content-Length: 32
Connection: close

{"status": "handshake received"}
```

Packet 2. 1 client pkt(s), 1 server pkt(s), 1 turn(s). Click to select.

Entire conversation (1835 bytes) Show data as ASCII Stream 0

Wireshark - Follow HTTP Stream (tcp.stream eq 1) - netsec_bonus.pcap

```
POST /callback HTTP/1.1
Host: 192.168.159.150:31337
User-Agent: python-requests/2.32.2
Accept-Encoding: gzip, deflate
Accept: */*
Connection: keep-alive
Content-Length: 148
Content-Type: application/json

{"cmd": "ynfwu gyyjo bqcrq tjwtp rxwvx hhdhi dsxdw tjwtp vgsri plohn gyyjo zobfd myjxh rxwvx oomff zobfd zymcr rxwvx bqcrq ynfwu yrtvw ynfwu hhdhi"}HTTP/1.1 200 OK
Server: Werkzeug/3.0.3 Python/3.10.12
Date: Sat, 15 Jun 2024 10:11:37 GMT
Content-Type: application/json
Content-Length: 109
Connection: close

{"answer": "dsxdw tjwtp vgsri plohn gyyjo zobfd myjxh rxwvx oomff zobfd zymcr rxwvx bqcrq ynfwu yrtvw ynfwu"}
```

Packet 8. 1 client pkt(s), 1 server pkt(s), 1 turn(s). Click to select.

Entire conversation (638 bytes) Show data as ASCII Stream 1

lab bonus - Encoded C2 (hard)

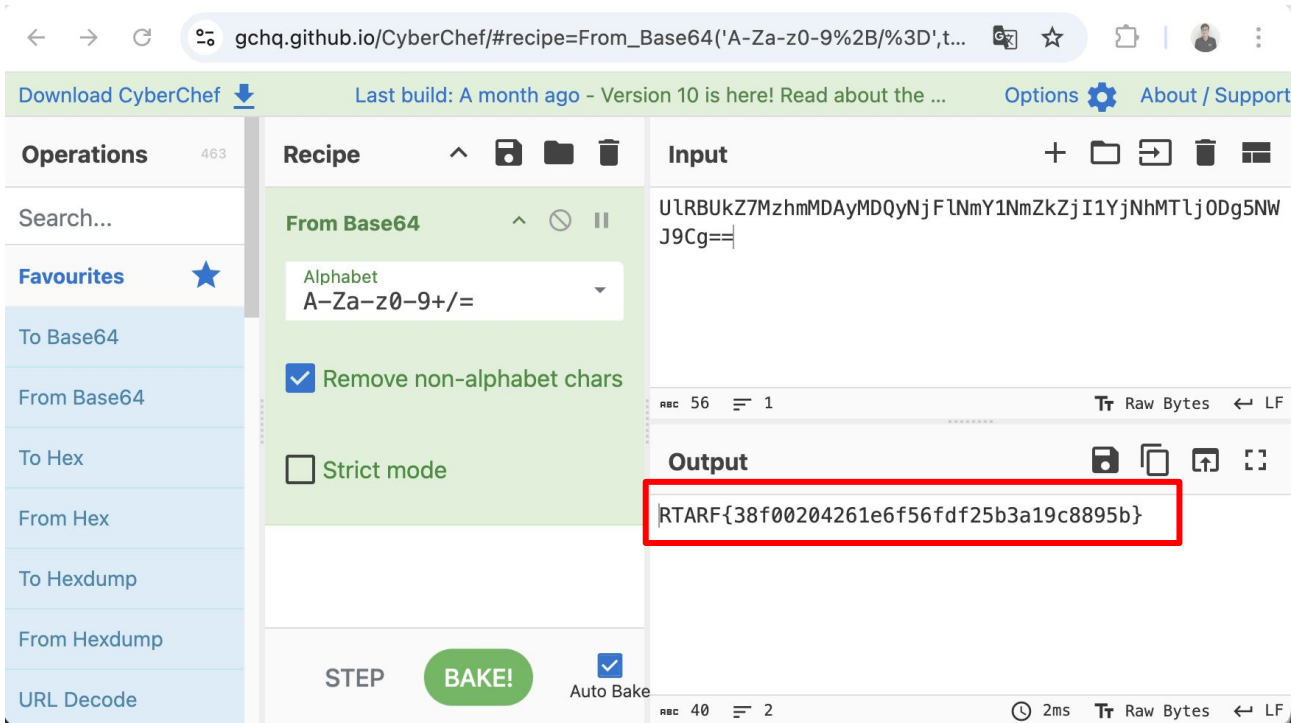
```
(tsk@kali)-[~/Desktop/3_netsec/lab-bonus_Encoded-C2]
$ python solve.py netsec_bonus.pcap
stream: 1
Decoded Callback Command (cmd): echo "longcat was here"
Decoded Callback Response (answer): longcat was here
stream: 3
Decoded Callback Command (cmd): ps -a
Decoded Callback Response (answer): PID TTY          TIME CMD
 1568 tty2      00:00:00 gnome-session-b
 2684 pts/0      00:00:00 python
 3580 pts/0      00:00:00 sh
 3581 pts/0      00:00:00 ps
stream: 5
Decoded Callback Command (cmd): cat /flag.txt | base64
Decoded Callback Response (answer): UIRBUkZ7MzhmMDAyMDQyNjFlNmY1NmZkZjI1YjNhMTljODg5NWJ9Cg==
```

\$ echo UIRBUkZ7MzhmMDAyMDQyNjFlNmY1NmZkZjI1YjNhMTljODg5NWJ9Cg== | base64 --decode

```
(tsk@kali)-[~/Desktop/3_netsec/lab-bonus_Encoded-C2]
$ echo UIRBUkZ7MzhmMDAyMDQyNjFlNmY1NmZkZjI1YjNhMTljODg5NWJ9Cg== | base64 --decode
RTARF{38f00204261e6f56fdf25b3a19c8895b}
```


แนะนำ Tool พื้นฐานสำหรับการเข้ารหัส - ถอดรหัส

<https://gchq.github.io/CyberChef/>



The screenshot shows the CyberChef web application interface. The browser address bar displays the URL: `gchq.github.io/CyberChef/#recipe=From_Base64('A-Za-z0-9%2B/%3D',t...`. The interface includes a sidebar with 'Operations' (463) and 'Favourites' (star icon). The 'Favourites' list includes: 'To Base64', 'From Base64', 'To Hex', 'From Hex', 'To Hexdump', 'From Hexdump', and 'URL Decode'. The main area is divided into three panels: 'Recipe', 'Input', and 'Output'. The 'Recipe' panel shows a 'From Base64' operation with a dropdown menu set to 'Alphabet A-Za-z0-9+/' and a checked 'Remove non-alphabet chars' option. The 'Input' panel shows the text: `U1RBUKZ7MzhmMDAyMDQyNjF1NmY1NmZkZjI1YjNhMTljODg5NWJ9Cg==`. The 'Output' panel shows the result: `RTARF{38f00204261e6f56fdf25b3a19c8895b}`, which is highlighted with a red rectangle. At the bottom, there is a 'STEP' button, a green 'BAKE!' button, and an 'Auto Bake' checkbox.

แนะนำ Tool พื้นฐานสำหรับการเข้ารหัส - ถอดรหัส

<https://www.dcode.fr/>



← → ↺ dcode.fr/tools-list

Search for a tool

★ SEARCH A TOOL ON DCODE

e.g. type 'sudoku'

★ BROWSE THE FULL DCODE TOOLS' LIST

1

dCODE's TOOLS LIST

ALL TOOLS LIST

List of all dCode's tools, available online, sorted by categories (click to expand). To be used in addition to the search bar which allows you to find tools by keywords.

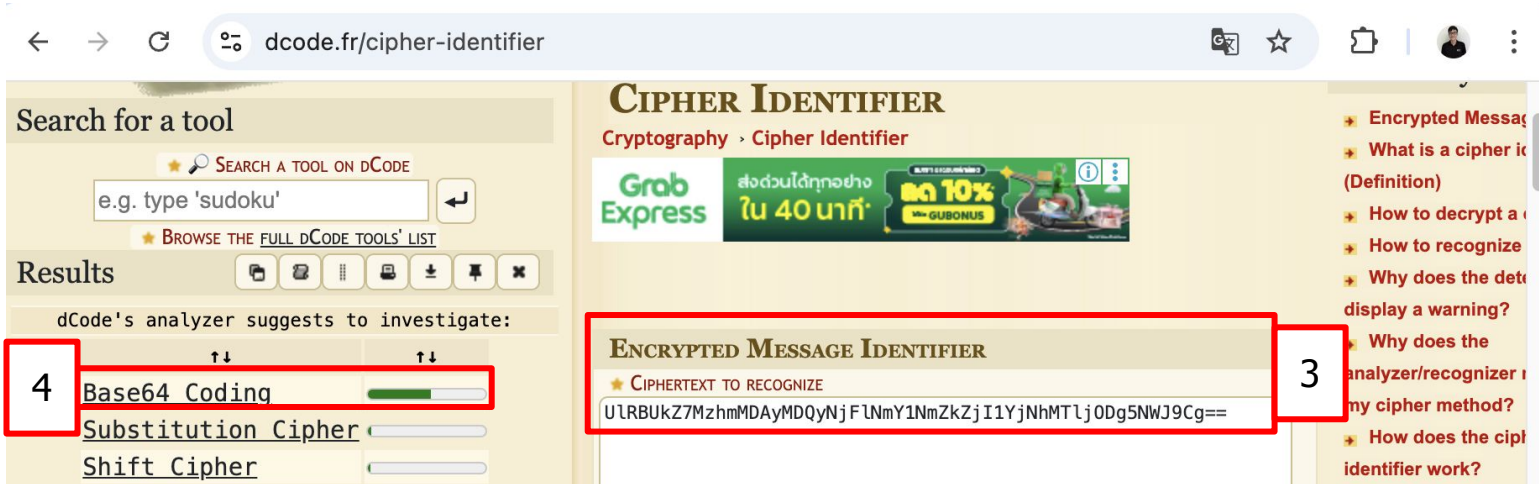
Reminder: dCode has a powerful **cipher identifier!**

2

▼ GAMES AND SOLVERS

- ★ All Tools List
- ★ What is a tool on dCode (Definition)
- ★ How to get the list of dCode tools?
- ★ Where to get a list of cryptographic tools?
- ★ How to use a tool

Tools (Exhaustive List) available on dCode. The tool categories are sorted and categorized by categories.



← → ↺ dcode.fr/cipher-identifier

Search for a tool

★ SEARCH A TOOL ON DCODE

e.g. type 'sudoku'

★ BROWSE THE FULL DCODE TOOLS' LIST

CIPHER IDENTIFIER

Cryptography > Cipher Identifier

Grab Express

ส่งด่วนได้ทุกอย่าง
ใน 40 นาที

ลด 10%
GUBONUS

Results

dCode's analyzer suggests to investigate:

4

Base64 Coding

Substitution Cipher

Shift Cipher

ENCRYPTED MESSAGE IDENTIFIER

★ CIPHERTEXT TO RECOGNIZE

U1RBUKZ7MzhmMDAyMDQyNjFlNmY1NmZkZjI1YjNhMTljODg5NWJ9Cg==

3

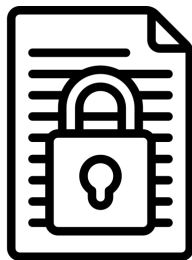
- ★ Encrypted Message
- ★ What is a cipher identifier (Definition)
- ★ How to decrypt a cipher
- ★ How to recognize a cipher
- ★ Why does the detector display a warning?
- ★ Why does the analyzer/recognizer suggest a cipher method?
- ★ How does the cipher identifier work?

Workshop: Cryptography

ศัพท์น่ารู้ หมวด Cryptography !!!



Plaintext



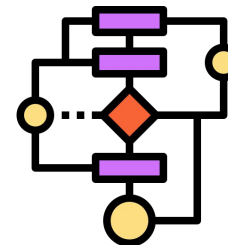
Ciphertext



Encryption



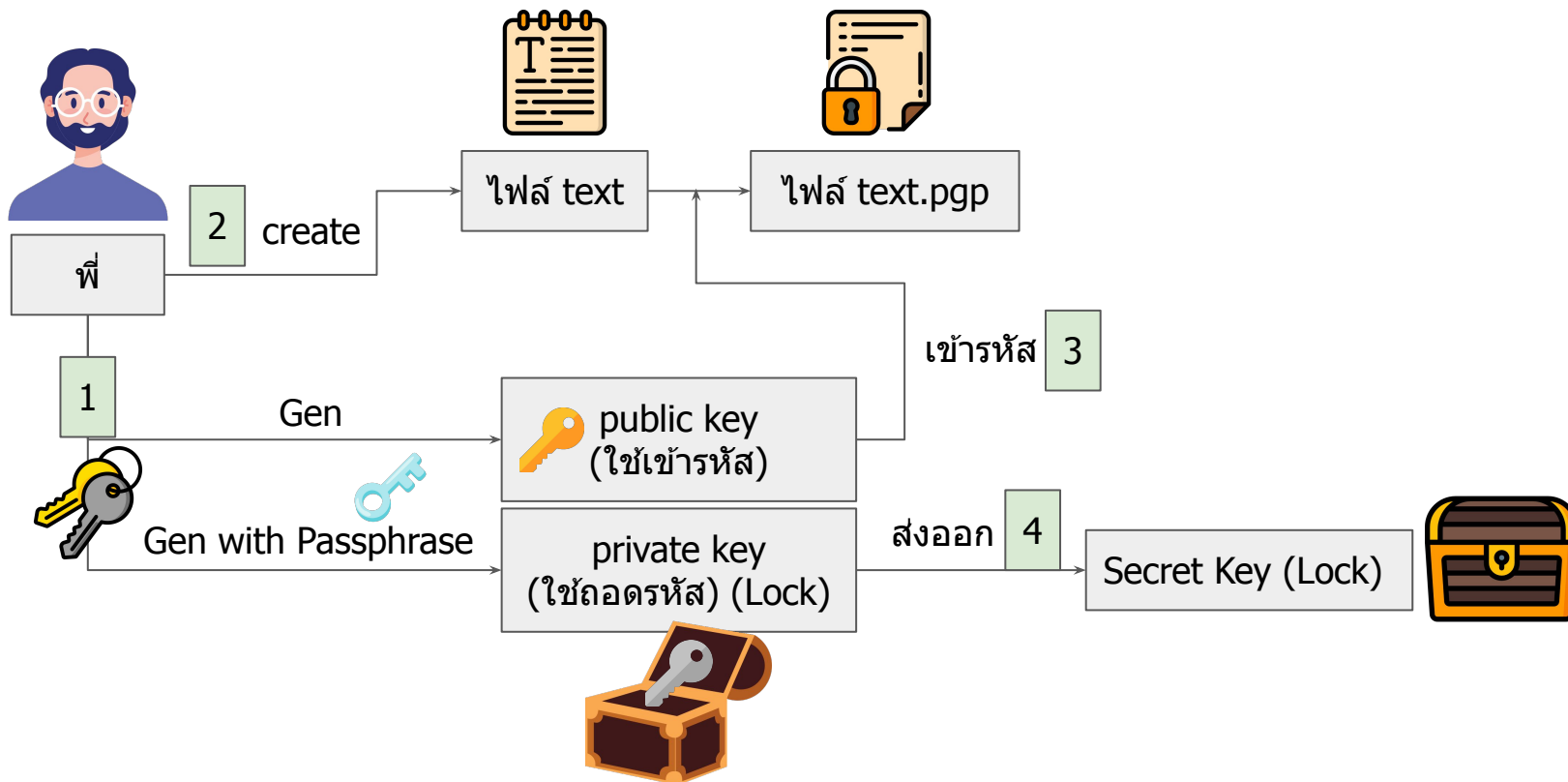
Decryption



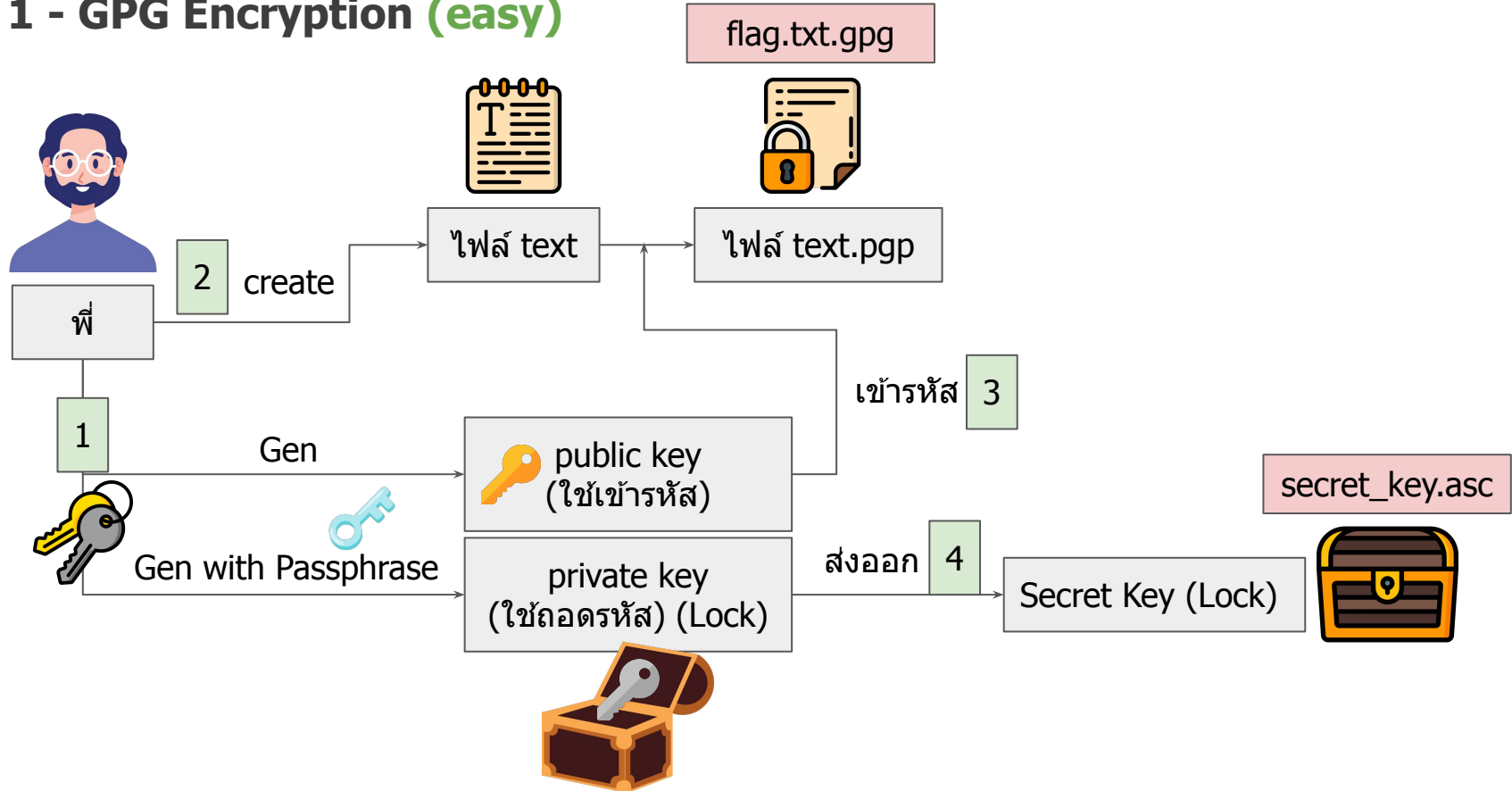
Algorithm

Lab 1 - GPG Encryption (easy)

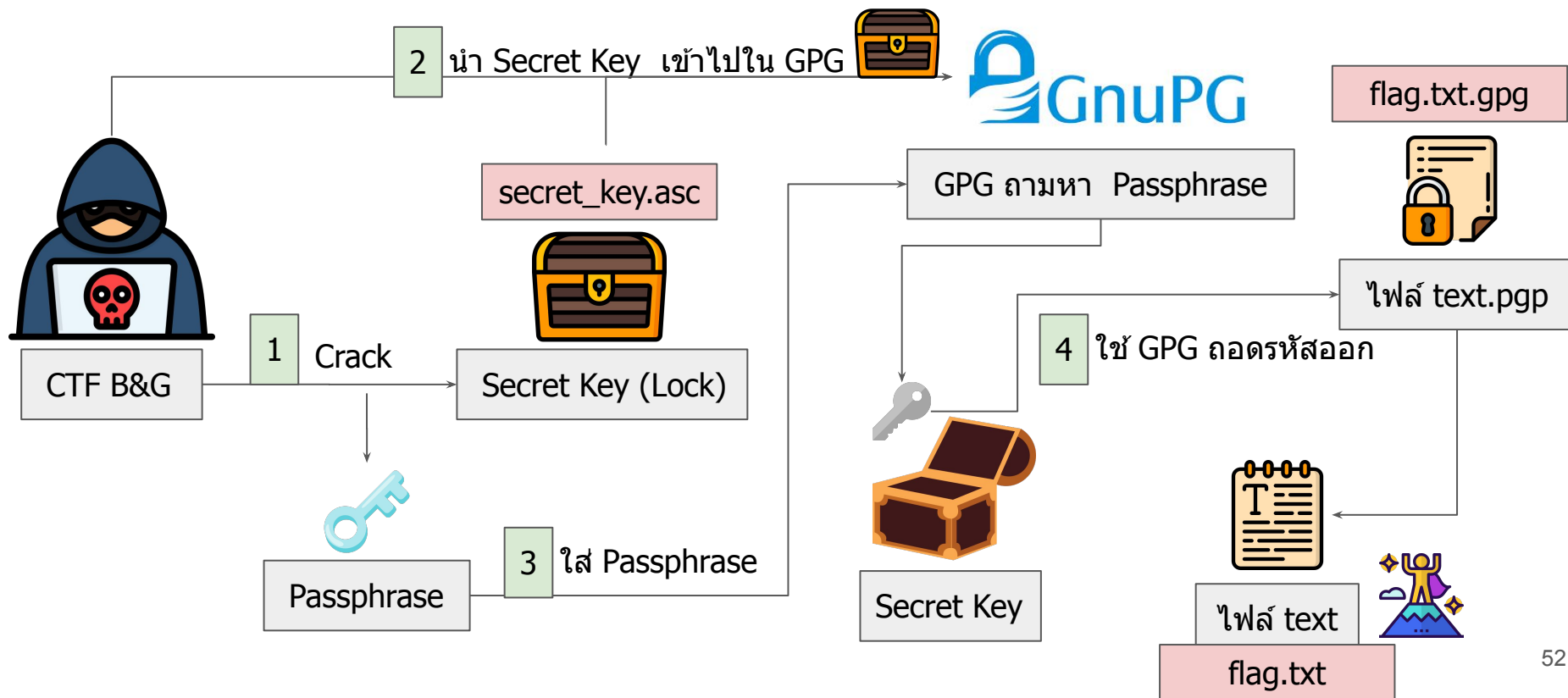
Lab 1 - GPG Encryption (easy)



Lab 1 - GPG Encryption (easy)



Lab 1 - GPG Encryption (easy)



Lab 1 - GPG Encryption (easy)

\$ gpg2john secret_key.asc > secret_key.asc.john

```

tsk@kali: ~/Desktop/4_crypto/lab1_pgp
File Actions Edit View Help
tsk@kali: ~/Desktop/4_crypto/lab1_pgp x tsk@kali: /usr/share/wordlists x

(tsk@kali)~[~/Desktop/4_crypto/lab1_pgp]
$ ls -lha
total 16K
drwxrwxr-x 2 tsk tsk 4.0K Jun 26 20:53 .
drwxrwxr-x 6 tsk tsk 4.0K Jun 26 20:51 ..
-rw-r--r-- 1 tsk tsk 634 Jun 25 23:43 flag.txt.gpg
-rw-r--r-- 1 tsk tsk 3.4K Jun 26 18:29 secret_key.asc

(tsk@kali)~[~/Desktop/4_crypto/lab1_pgp]
$ gpg2john secret_key.asc > secret_key.asc.john

File secret_key.asc

```

Lab 1 - GPG Encryption (easy)

\$ john --wordlist=/usr/share/wordlists/rockyou.txt -format=pgp secret_key.asc.john

```

tsk@kali: ~/Desktop/4_crypto/lab1_pgp
File Actions Edit View Help
tsk@kali: ~/Desktop/4_crypto/lab1_pgp x tsk@kali: /usr/share/wordlists x

(tsk@kali)-[~/Desktop/4_crypto/lab1_pgp]
$ john --wordlist=/usr/share/wordlists/rockyou.txt -format=pgp secret_key.asc.john
Using default input encoding: UTF-8
Loaded 1 password hash (pgp, OpenPGP / GnuPG Secret Key [32/64])
Cost 1 (s2k-count) is 65011712 for all loaded hashes
Cost 2 (hash algorithm [1:MD5 2:SHA1 3:RIPEMD160 8:SHA256 9:SHA384 10:SHA512 11:SHA224]) is 2 for all loaded hashes
Cost 3 (cipher algorithm [1:IDEA 2:3DES 3:CAST5 4:Blowfish 7:AES128 8:AES192 9:AES256 10:Twofish 11:Camellia128 12:Camellia192 13:Camellia256]) is 7 for all loaded hashes
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
123456 (Easy Crypto)
1g 0:00:00:00 DONE (2025-06-26 20:58) 1.098g/s 140.6p/s 140.6c/s 140.6C/s 123456..diamond
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
  
```

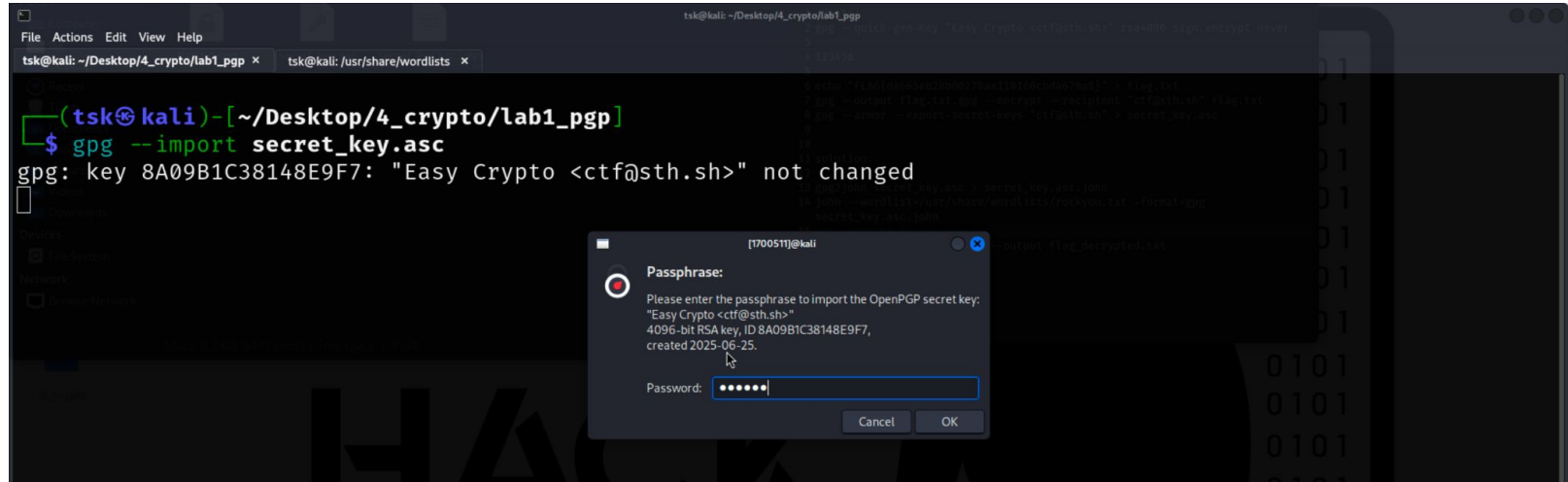
Lab 1 - GPG Encryption (easy)

```

tsk@kali: /usr/share/wordlists
File Actions Edit View Help
tsk@kali: ~/Desktop/4_crypto/lab1_pgp x tsk@kali: /usr/share/wordlists x
(tsk@kali)-[~/Desktop/4_crypto/lab1_pgp]
$ wordlists
> wordlists ~ Contains the rockyou wordlist
/usr/share/wordlists
— amass → /usr/share/amass/wordlists
— dirb → /usr/share/dirb/wordlists
— dirbuster → /usr/share/dirbuster/wordlists
— dnsmap.txt → /usr/share/dnsmap/wordlist_TLAs.txt
— fasttrack.txt → /usr/share/set/src/fasttrack/wordlist.txt
— fern-wifi → /usr/share/fern-wifi-cracker/extras/wordlists
— john.lst → /usr/share/john/password.lst
— legion → /usr/share/legion/wordlists
— metasploit → /usr/share/metasploit-framework/data/wordlists
— nmap.lst → /usr/share/nmap/nselib/data/passwords.lst
— rockyou.txt
— seclists → /usr/share/seclists
— sqlmap.txt → /usr/share/sqlmap/data/txt/wordlist.txt
— wfuzz → /usr/share/wfuzz/wordlist
— wifite.txt → /usr/share/dict/wordlist-probable.txt
(tsk@kali)-[/usr/share/wordlists]
$
  
```

Lab 1 - GPG Encryption (easy)

\$ gpg --import secret_key.asc



Lab 1 - GPG Encryption (easy)

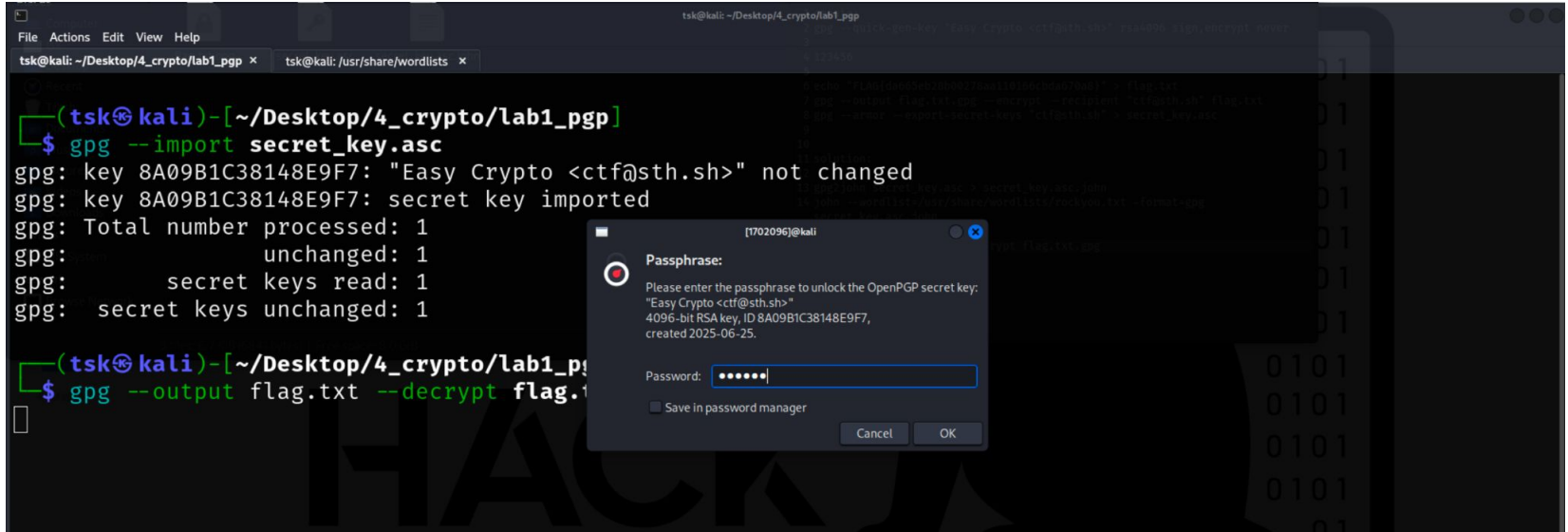
```
tsk@kali: ~/Desktop/4_crypto/lab1_pgp
File Actions Edit View Help
tsk@kali: ~/Desktop/4_crypto/lab1_pgp x tsk@kali: /usr/share/wordlists x

(tsk@kali)~[~/Desktop/4_crypto/lab1_pgp]
$ gpg --import secret_key.asc
gpg: key 8A09B1C38148E9F7: "Easy Crypto <ctf@sth.sh>" not changed
gpg: key 8A09B1C38148E9F7: secret key imported
gpg: Total number processed: 1
gpg:      unchanged: 1
gpg:      secret keys read: 1
gpg:      secret keys unchanged: 1

(tsk@kali)~[~/Desktop/4_crypto/lab1_pgp]
$ gpg --output flag.txt --decrypt flag.txt.gpg
```

\$ gpg --output flag.txt --decrypt flag.txt.gpg

Lab 1 - GPG Encryption (easy)



```
tsk@kali: ~/Desktop/4_crypto/lab1_pgp
File Actions Edit View Help
tsk@kali: ~/Desktop/4_crypto/lab1_pgp x tsk@kali: /usr/share/wordlists x

(tsk@kali)-[~/Desktop/4_crypto/lab1_pgp]
$ gpg --import secret_key.asc
gpg: key 8A09B1C38148E9F7: "Easy Crypto <ctf@sth.sh>" not changed
gpg: key 8A09B1C38148E9F7: secret key imported
gpg: Total number processed: 1
gpg:      unchanged: 1
gpg:      secret keys read: 1
gpg:      secret keys unchanged: 1

(tsk@kali)-[~/Desktop/4_crypto/lab1_pgp]
$ gpg --output flag.txt --decrypt flag.txt

[1702096]@kali
Passphrase:
Please enter the passphrase to unlock the OpenPGP secret key:
"Easy Crypto <ctf@sth.sh>"
4096-bit RSA key, ID 8A09B1C38148E9F7,
created 2025-06-25.
Password: [REDACTED]
☐ Save in password manager
[Cancel] [OK]
```

ระบุ Passphrase

Lab 1 - GPG Encryption (easy)

```
tsk@kali: ~/Desktop/4_crypto/lab1_pgp
File Actions Edit View Help
tsk@kali: ~/Desktop/4_crypto/lab1_pgp x tsk@kali: /usr/share/wordlists x
gpg: key 8A09B1C38148E9F7: "Easy Crypto <ctf@sth.sh>" not changed
gpg: key 8A09B1C38148E9F7: secret key imported
gpg: Total number processed: 1
gpg:      unchanged: 1
gpg:      secret keys read: 1
gpg:      secret keys unchanged: 1

(tsk@kali)-[~/Desktop/4_crypto/lab1_pgp]
$ gpg --output flag.txt --decrypt flag.txt.gpg
gpg: encrypted with 4096-bit RSA key, ID 8A09B1C38148E9F7, created 2025-06-25
      "Easy Crypto <ctf@sth.sh>"

(tsk@kali)-[~/Desktop/4_crypto/lab1_pgp]
$ ls -lha
total 24K
drwxrwxr-x 2 tsk tsk 4.0K Jun 26 21:00 .
drwxrwxr-x 6 tsk tsk 4.0K Jun 26 20:51 ..
-rw-rw-r-- 1 tsk tsk  39 Jun 26 21:00 flag.txt
-rw-r--r-- 1 tsk tsk  634 Jun 25 23:43 flag.txt.gpg
-rw-r--r-- 1 tsk tsk 3.4K Jun 26 18:29 secret_key.asc
-rw-rw-r-- 1 tsk tsk 2.7K Jun 26 20:54 secret_key.asc.john

(tsk@kali)-[~/Desktop/4_crypto/lab1_pgp]
$
```


Lab 1 - GPG Encryption (easy)

```
tsk@kali: ~/Desktop/4_crypto/lab1_pgp
gpg: secret keys read: 1
gpg: secret keys unchanged: 1

(tsk@kali)~[~/Desktop/4_crypto/lab1_pgp]
$ gpg --output flag.txt --decrypt flag.txt.gpg
gpg: encrypted with 4096-bit RSA key, ID 8A09B1C38148E9F7, created 2025-06-25
"Easy Crypto <ctf@sth.sh>"

(tsk@kali)~[~/Desktop/4_crypto/lab1_pgp]
$ ls -lha
total 24K
drwxrwxr-x 2 tsk tsk 4.0K Jun 26 21:00 .
drwxrwxr-x 6 tsk tsk 4.0K Jun 26 20:51 ..
-rw-rw-r-- 1 tsk tsk 39 Jun 26 21:00 flag.txt
-rw-r--r-- 1 tsk tsk 634 Jun 25 23:43 flag.txt.gpg
-rw-r--r-- 1 tsk tsk 3.4K Jun 26 18:29 secret_key.asc
-rw-rw-r-- 1 tsk tsk 2.7K Jun 26 20:54 secret_key.asc.john

(tsk@kali)~[~/Desktop/4_crypto/lab1_pgp]
$ cat flag.txt
FLAG{da665eb28b00278aa110166cbda670a8}

(tsk@kali)~[~/Desktop/4_crypto/lab1_pgp]
$
```

Lab 2 - RSA Fermat (medium)

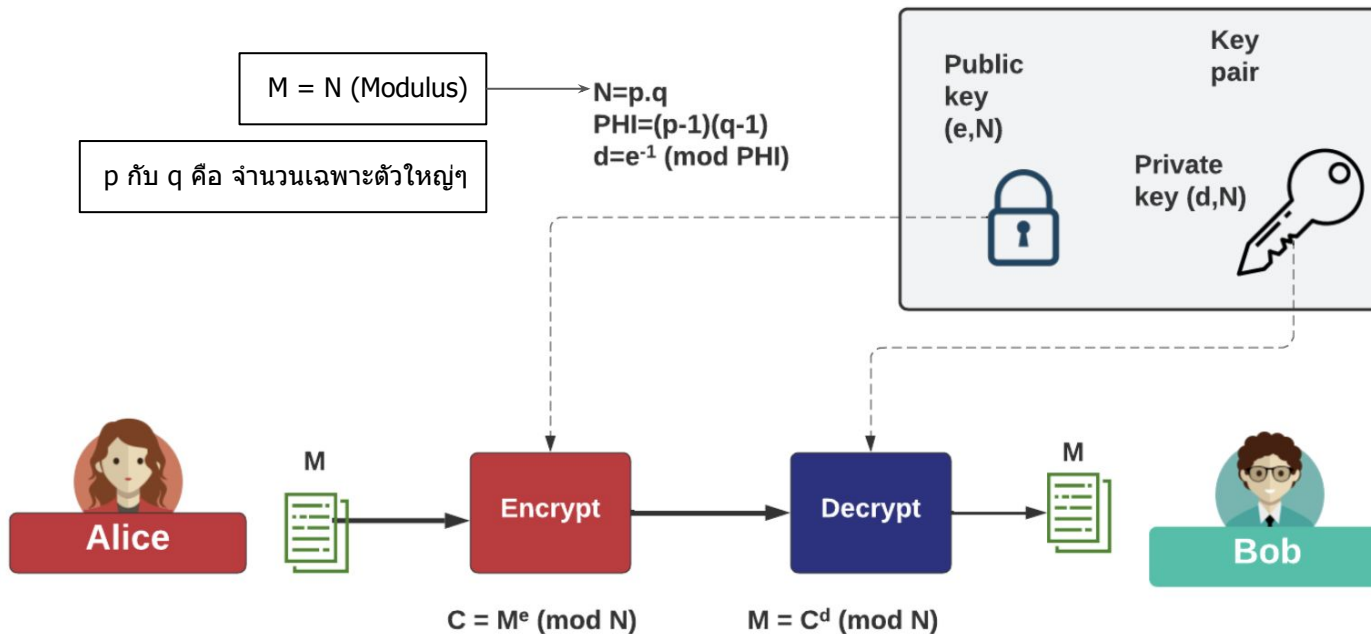
Lab 2 - RSA Fermat (medium)

```
(tsk@kali)-[~/Desktop/4_crypto/lab2_rsa-fermat]
$ ls -lha
total 12K
drwxrwxr-x 2 tsk tsk 4.0K Jun 27 14:15 .
drwxrwxr-x 7 tsk tsk 4.0K Jun 27 14:14 ..
-rw-r--r-- 1 tsk tsk 1.3K Jun 24 2024 crypto1_rtarf.txt
```

```
(tsk@kali)-[~/Desktop/4_crypto/lab2_rsa-fermat]
$ cat crypto1_rtarf.txt
```

```
M:1230344046594394735447209622236939028617581142302863540683074875016970898251203009446547444808693073055
574549891574756787161266753186435930255880982590543806940191377897063147982697841372370043755115222662339
55097430588069739367588851291475504514756382904670546960286160950603688381761592698261626329779035413, E:
65537, CT=10074486489993881584965306476116883180565337355452188251729822078897613167514860772514447211250
110116749135330093272912940595778799245764702874742936347719859819207094973488704701978026673626392364174
274467595899206664176202717973610639700842661853345182531988530243119049428151780072171186625989644736359
7879
M:7621704481602193723487254395970352401737783819368152822792412100123311687702226638326391035880064506662
613022048528532200251198751953806158986266562147084095078634418558163023693842602823600737137196952408090
5413095540798402414656634155306852937122155719309630161472852084868345484452652767213638133057951227, E:6
5537, CT=246682489734902279229986995129589718400894015451021582365485676988936971273137451436839859012922
368507024251144597067229241578123046822088226173078977870966761653228483631566756308438709060824957975583
673470805688170431723939673044769374897839986308057967308126015107116338881521166705290079651957034331975
54
```

Lab 2 - RSA Fermat (medium)



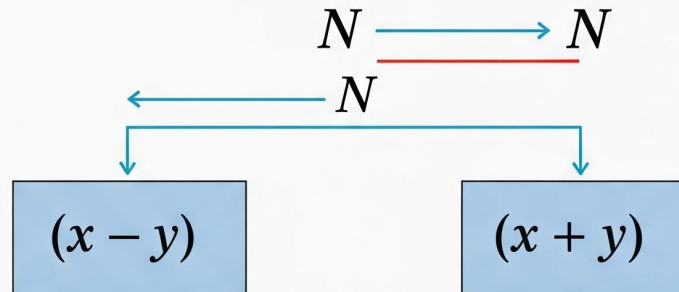
อ้างอิง: <https://asecuritysite.com/rsa>

Lab 2 - RSA Fermat (medium)

Fermat's Factorization method



$$N = x^2 - y^2 = (x - y)(x + y)$$

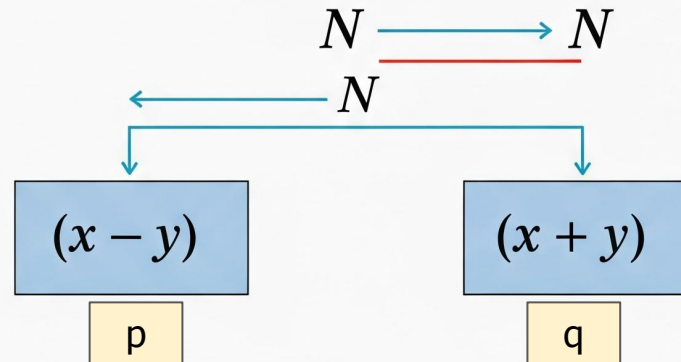


Lab 2 - RSA Fermat (medium)

Fermat's Factorization method



$$N = x^2 - y^2 = \overset{\boxed{p}}{(x - y)} \overset{\boxed{q}}{(x + y)}$$



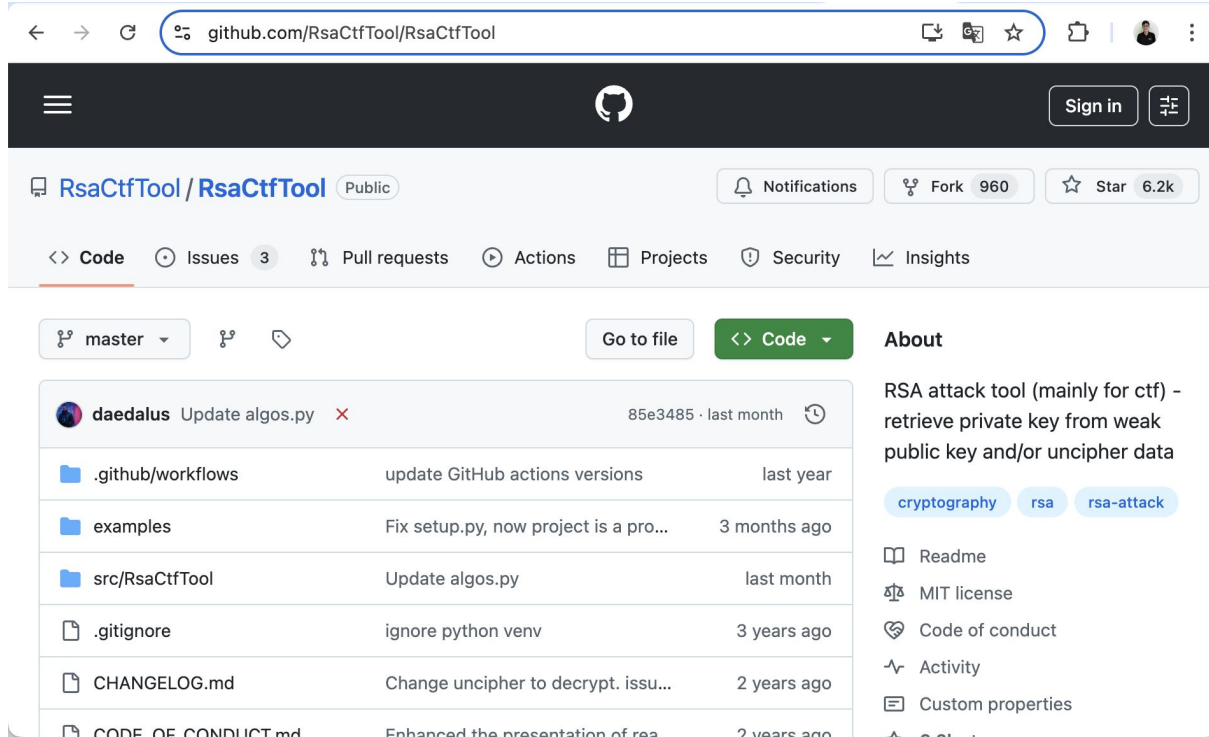
Lab 2 - RSA Fermat (medium)

```
(tsk@kali)-[~/Desktop/4_crypto/lab2_rsa-fermat/slove]
$ ls -lha
total 16K
drwxrwxr-x 2 tsk tsk 4.0K Jun 27 19:17 SIAM T
drwxrwxr-x 4 tsk tsk 4.0K Jun 27 19:20 ..
-rw-r--r-- 1 tsk tsk 1.3K Jun 24 2024 solve_1.py
-rw-r--r-- 1 tsk tsk 4.0K Jun 24 2024 solve_2.py
```

```
solve_1.py
1 import re
2
3 def n2b(n):
4     h = hex(n)[2:]
5     if len(h) % 2 == 1:
6         h = "0" + h
7
8     return bytes.fromhex(h)
9
10 def xgcd(a, b):
11     if a == 0: return 0, 1, b
12     if b == 0: return 1, 0, a
13
14     px, ppx = 0, 1
15     py, ppy = 1, 0
16
17     while b:
18         q = a // b
19         a, b = b, a % b
20         x = ppx - q * px
21         y = ppy - q * py
22         ppx, px = px, x
23         ppy, py = py, y
24
25     return ppx, ppy, a
```

```
solve_1.py
1 import re
2
3 def n2b(n):
4     h = hex(n)[2:]
5     if len(h) % 2 == 1:
6         h = "0" + h
7
8     return bytes.fromhex(h)
9
10 def xgcd(a, b):
11     if a == 0: return 0, 1, b
12     if b == 0: return 1, 0, a
13
14     px, ppx = 0, 1
15     py, ppy = 1, 0
16
17     while b:
18         q = a // b
19         a, b = b, a % b
20         x = ppx - q * px
21         y = ppy - q * py
22         ppx, px = px, x
23         ppy, py = py, y
24
25     return ppx, ppy, a
```

Lab 2 - RSA Fermat (medium)



The screenshot shows the GitHub repository page for `RsaCtfTool/RsaCtfTool`. The repository is public and has 960 forks and 6.2k stars. The main branch is `master`. The repository description is: "RSA attack tool (mainly for ctf) - retrieve private key from weak public key and/or uncipher data". The repository contains the following files and folders:

File/Folder	Description	Last Commit
<code>.github/workflows</code>	update GitHub actions versions	last year
<code>examples</code>	Fix setup.py, now project is a pro...	3 months ago
<code>src/RsaCtfTool</code>	Update algos.py	last month
<code>.gitignore</code>	ignore python venv	3 years ago
<code>CHANGELOG.md</code>	Change uncipher to decrypt. issu...	2 years ago
<code>CODE OF CONDUCT.md</code>	Enhanced the presentation of res...	2 years ago

The repository also includes a `Readme`, `MIT license`, `Code of conduct`, and `Activity`.

<https://github.com/RsaCtfTool/RsaCtfTool>

Lab 2 - RSA Fermat (medium)

Installation

Virtual environment run (Preferred method)

Setup the venv

```
apt install python3-virtualenv
virtualenv venv
source venv/bin/activate
pip install git+https://github.com/RsaCtfTool/RsaCtfTool
```



```
$ apt install python3-virtualenv
$ virtualenv RSA หรือ python3 -m venv RSA
$ source RSA/bin/activate
$ pip install git+https://github.com/RsaCtfTool/RsaCtfTool
```

```
$ deactivate
```

Lab 2 - RSA Fermat (medium)

```
(tsk@kali)-[~/Desktop/4_crypto/lab2_rsa-fermat]
$ RsaCtfTool -h
usage: RsaCtfTool [-h] [--publickey PUBLICKEY] [--output OUTPUT] [--timeout TIMEOUT] [--createpub]
                [--dumpkey] [--ext] [--decryptfile DECRYPTFILE] [--decrypt DECRYPT]
                [--verbosity {CRITICAL,ERROR,WARNING,DEBUG,INFO}] [--private] [--tests]
                [--ecmdigits ECMDIGITS] [-n N] [-p P] [-q Q] [-e E] [-d D] [--key KEY]
                [--password PASSWORD]

options:
  -h, --help                show this help message and exit
  --publickey PUBLICKEY      public key file. You can use wildcards for multiple keys.
  --output OUTPUT            output file for results (privates keys, plaintext data).
  --timeout TIMEOUT          Timeout for long attacks in seconds. default is 60s min: MIN_INT in C, max:
                             MAX_INT in C, values < 1 have the same effect as MAX_INT
  --createpub                Take n and e from cli and just print a public key then exit
  --dumpkey                  Just dump the RSA variables from a key - n,e,d,p,q
  --ext                      Extended dump of RSA private variables in --dumpkey mode - dp,dq,pinv,qinv).
  --decryptfile DECRYPTFILE  decrypt a file, using commas to separate multiple paths
  --decrypt DECRYPT           decrypt a cipher, using commas to separate multiple ciphers
  --verbosity {CRITICAL,ERROR,WARNING,DEBUG,INFO} verbose mode
  --private                  Display private key if recovered
  --tests                    Run tests on attacks
  --ecmdigits ECMDIGITS      Optionally an estimate as to how long one of the primes is for ECM method
  -n N                      Specify the modulus. format : int or 0xhex
  -p P                      Specify the first prime number. format : int or 0xhex
  -q Q                      Specify the second prime number. format : int or 0xhex
  -e E                      Specify the public exponent, using commas to separate multiple exponents.
                             format : int or 0xhex
  -d D                      Specify the private exponent. Format : int or 0xhex
  --key KEY                  Specify the private key file.
  --password PASSWORD        Private key password if needed.
  --attack {XYZZ,noveltyprimes,system_primes_gcd,factor_2PN,ecm,pollard_rho,lehmer,ecm2,neca,lucas_gcd,fi
                             bonacci_gcd,dixon,SQUFOF,pisano_period,nonRSA,lattice,wolframalpha,hart,roca,smallfraction,small_crt_exp,
```


Lab 3 - ECB Block shuffling (hard)

Lab 3 - ECB Block shuffling (hard)

```
$ nmap --open -p- {domain_target}
```

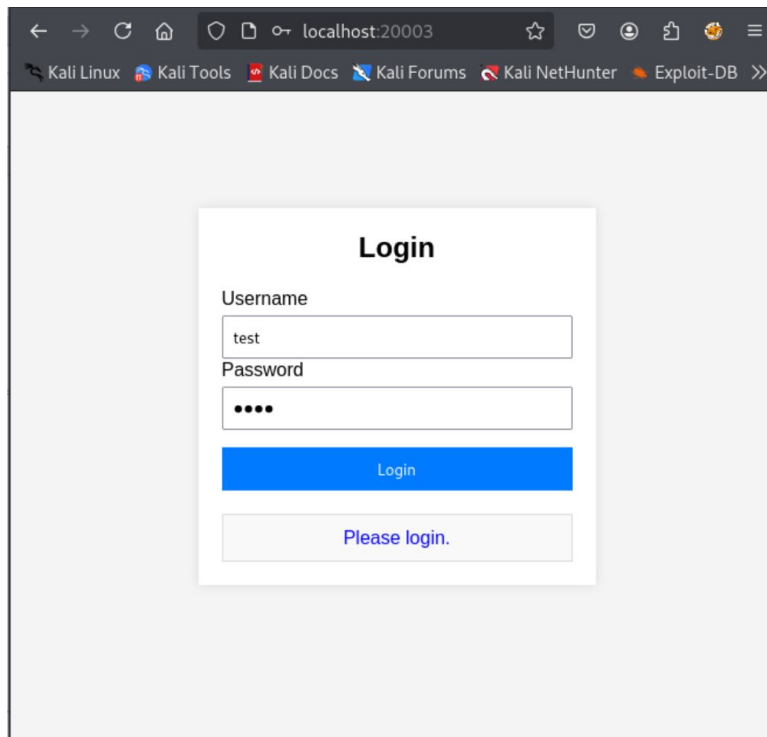
```
(tsk@kali)-[~/Desktop/4_crypto/lab3_ech-block-shuffling]
$ nmap --open -p- localhost
Starting Nmap 7.95 ( https://nmap.org ) at 2025-06-28 00:52 +07
Nmap scan report for localhost (127.0.0.1)
Host is up (0.0000020s latency).
Other addresses for localhost (not scanned): ::1
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE
20003/tcp  open  commtact-https
34499/tcp  open  unknown

Nmap done: 1 IP address (1 host up) scanned in 0.40 seconds
```

```
(tsk@kali)-[~/Desktop/4_crypto/lab3_ech-block-shuffling]
$ nmap -sV -p 20003 localhost
Starting Nmap 7.95 ( https://nmap.org ) at 2025-06-28 00:53 +07
Nmap scan report for localhost (127.0.0.1)
Host is up (0.000088s latency).
Other addresses for localhost (not scanned): ::1

PORT      STATE SERVICE VERSION
20003/tcp  open  http    nginx
```

Lab 3 - ECB Block shuffling (hard)



A screenshot of a web browser window showing a login form. The browser's address bar displays 'localhost:20003'. The page has a light gray background. In the center, there is a white box containing the login form. The form is titled 'Login' in bold black text. It has two input fields: 'Username' with the text 'test' and 'Password' with masked characters (dots). Below the password field is a blue button labeled 'Login'. At the bottom of the form box is a link that says 'Please login.' in blue text.

Lab 3 - ECB Block shuffling (hard)

Burp Project Intruder Repeater View Help

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Orga

Intercept HTTP history WebSockets history Match and replace Proxy settings

Filter settings: Hiding CSS, image and general binary content

#	Host	Method	URL	Params	Edited	Status code	Length	MIME type	Exten
1	http://localhost:20003	POST	/login.php		✓	200	728	JSON	php

Request

Pretty Raw Hex

```

3 User-Agent: Mozilla/5.0 (X11; Linux x86_64;
4 rv:128.0) Gecko/20100101 Firefox/128.0
5 Accept: */*
6 Accept-Language: en-US,en;q=0.5
7 Accept-Encoding: gzip, deflate, br
8 Referer: http://localhost:20003/
9 Content-Type: application/json
10 Content-Length: 37
11 Origin: http://localhost:20003
12 Connection: keep-alive
13 Sec-Fetch-Dest: empty
14 Sec-Fetch-Mode: cors
15 Sec-Fetch-Site: same-origin
16 Priority: u=0
17 {
  "username": "test",
  "password": "test"
}

```

Response

Pretty Raw Hex Render

```

3 Date: Fri, 27 Jun 2025 17:56:58 GMT
4 Content-Type: text/html; charset=UTF-8
5 Connection: keep-alive
6 Set-Cookie: access_token=
  52f2d2ee8bbb366c93e0ce06b2849b122b9578841b5068b40
  05441f94ef4db42b1030fd92be0142f42daff678b3a187c9
  beeedccc529092fb2659df61e42024; expires=Fri, 27
  Jun 2025 18:56:58 GMT; Max-Age=3600; path=/
7 X-Frame-Options: SAMEORIGIN
8 X-XSS-Protection: 1; mode=block
9 X-Content-Type-Options: nosniff
10 Referrer-Policy: no-referrer-when-downgrade
11 Content-Security-Policy: default-src * data:
  'unsafe-eval' 'unsafe-inline'
12 Content-Length: 140
13
14 {"token": "52f2d2ee8bbb366c93e0ce06b2849b122b95788
  41b5068b4005441f94ef4db42b1030fd92be0142f42daff6
  78b3a187c9beeedccc529092fb2659df61e42024"}

```

Event log (1) All issues

localhost:20003

Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB

Login

Username

Password

Login

Token generated:

```

52f2d2ee8bbb366c93e0ce06b2849b1
22b9578841b5068b4005441f94ef4db4
2b1030fd92be0142f42daff678b3a187
c9beeedccc529092fb2659df61e42024

```


Lab 3 - ECB Block shuffling (hard)

```
384e64000e652537e65de51da68df8b75dc92597066badb697
1 384e64000e652537e65de51da68df8b75dc92597066badb69735431247
8c63ef5dc92597066badb697354312478c63ef5dc92597066badb69735
4312478c63ef5dc92597066badb697354312478c63ef5dc92597066bad
b697354312478c63ef5dc92597066badb697354312478c63ef5dc92597
066badb697354312478c63ef5dc92597066badb697354312478c63ef92
6bbf07f37b24a1ca11495daadca7750dfb9d30533fab90d2a910792ae9
288f5dc92597066badb697354312478c63ef5dc92597066badb6973543
12478c63ef5dc92597066badb697354312478c63ef5dc92597066badb6
97354312478c63ef5dc92597066badb697354312478c63ef5dc9259706
6badb697354312478c63ef5dc92597066badb697354312478c63ef5dc9
2597066badb697354312478c63ef5dc92597066badb697354312478c63ef5dc9
6ec9beeedccc529092fb2659df61e42024
```

- ตัวอักษร **0–9a–f** เท่านั้น → **base16 (hex)** แน่นนอน
- ข้อมูล 5dc92597066badb697354312478c63ef ← ซ้ำ ๆ กันหลายรอบ
- เป็น pattern ความยาว **32 หลัก (16 byte)** → อาจเป็น **block** ที่เข้ารหัสแล้ว

จากประสบการณ์แล้ว นี่เป็นการเข้ารหัสแบบ **AES-ECB (Electronic Codebook)** แน่นนอน!!!

Lab 3 - ECB Block shuffling (hard)

384e64000e652537e65de51da68df8b7	{"username": " --> 384e64000e652537e65de51da68df8b7
1 384e64000e652537e65de51da68df8b7	1 {"username": " --> 384e64000e652537e65de51da68df8b7
2 5dc92597066badb697354312478c63ef	2 111111111111 --> 5dc92597066badb697354312478c63ef
3 5dc92597066badb697354312478c63ef	3 111111111111 --> 5dc92597066badb697354312478c63ef
4 5dc92597066badb697354312478c63ef	4 111111111111 --> 5dc92597066badb697354312478c63ef
5 5dc92597066badb697354312478c63ef	5 111111111111 --> 5dc92597066badb697354312478c63ef
6 5dc92597066badb697354312478c63ef	6 111111111111 --> 5dc92597066badb697354312478c63ef
7 5dc92597066badb697354312478c63ef	7 111111111111 --> 5dc92597066badb697354312478c63ef
8 5dc92597066badb697354312478c63ef	8 111111111111 --> 5dc92597066badb697354312478c63ef
9 5dc92597066badb697354312478c63ef	9 111111111111 --> 5dc92597066badb697354312478c63ef
10 926bbf07f37b24a1ca11495daadca775	10 111111111111", " --> 926bbf07f37b24a1ca11495daadca775
11 0dfb9d30533fab90d2a910792ae9288f	11 password": "11 --> 0dfb9d30533fab90d2a910792ae9288f
12 5dc92597066badb697354312478c63ef	12 111111111111 --> 5dc92597066badb697354312478c63ef
13 5dc92597066badb697354312478c63ef	13 111111111111 --> 5dc92597066badb697354312478c63ef
14 5dc92597066badb697354312478c63ef	14 111111111111 --> 5dc92597066badb697354312478c63ef
15 5dc92597066badb697354312478c63ef	15 111111111111 --> 5dc92597066badb697354312478c63ef
16 5dc92597066badb697354312478c63ef	16 111111111111 --> 5dc92597066badb697354312478c63ef
17 5dc92597066badb697354312478c63ef	17 111111111111 --> 5dc92597066badb697354312478c63ef
18 5dc92597066badb697354312478c63ef	18 111111111111 --> 5dc92597066badb697354312478c63ef
19 5dc92597066badb697354312478c63ef	19 111111111111 --> 5dc92597066badb697354312478c63ef
20 f89578f7de7262dc8d3a1adcb72d2a6e	20 111111111111", "is --> f89578f7de7262dc8d3a1adcb72d2a6e
21 c9beedccc529092fb2659df61e42024	21 _admin": 0} --> c9beedccc529092fb2659df61e42024

Lab 3 - ECB Block shuffling (hard)

Login Request



```

{"username":"111 --> 384e64000e652537e65de51da68df
1 {"username":"111 --> 384e64000e652537e65de51da68df8b7
2 1111111111111111 --> 5dc92597066badb697354312478c63ef
3 1111111111111111 --> 5dc92597066badb697354312478c63ef
4 1111111111111111 --> 5dc92597066badb697354312478c63ef
5 1111111111111111 --> 5dc92597066badb697354312478c63ef
6 1111111111111111 --> 5dc92597066badb697354312478c63ef
7 1111111111111111 --> 5dc92597066badb697354312478c63ef
8 1111111111111111 --> 5dc92597066badb697354312478c63ef
9 1111111111111111 --> 5dc92597066badb697354312478c63ef
10 1111111111111111 --> 5dc92597066badb697354312478c63ef
11 sword":"11111111 --> 926bbf07f37b24a1ca11495daadca775
12 1111111111111111 --> 0dfb9d30533fab90d2a910792ae9288f
13 1111111111111111 --> 5dc92597066badb697354312478c63ef
14 1111111111111111 --> 5dc92597066badb697354312478c63ef
15 1111111111111111 --> 5dc92597066badb697354312478c63ef
16 1111111111111111 --> 5dc92597066badb697354312478c63ef
17 1111111111111111 --> 5dc92597066badb697354312478c63ef
18 1111111111111111 --> 5dc92597066badb697354312478c63ef
19 1111111111111111 --> 5dc92597066badb697354312478c63ef
20 1111111111111111 --> f89578f7de7262dc8d3a1adcb72d2a6e
21 1111111111111111 --> c9beeedccc529092fb2659df61e42024

```

session_token_debug



```

{"username":"111 --> 384e64000e652537e65de51da68df
1 {"username":"111 --> 384e64000e652537e65de51da68df8b7
2 1111111111111111 --> 5dc92597066badb697354312478c63ef
3 1111111111111111 --> 5dc92597066badb697354312478c63ef
4 1111111111111111 --> 5dc92597066badb697354312478c63ef
5 1111111111111111 --> 5dc92597066badb697354312478c63ef
6 1111111111111111 --> 5dc92597066badb697354312478c63ef
7 1111111111111111 --> 5dc92597066badb697354312478c63ef
8 1111111111111111 --> 5dc92597066badb697354312478c63ef
9 1111111111111111 --> 5dc92597066badb697354312478c63ef
10 1111111111111111 --> 5dc92597066badb697354312478c63ef
11 sword":"11111111 --> 926bbf07f37b24a1ca11495daadca775
12 1111111111111111 --> 0dfb9d30533fab90d2a910792ae9288f
13 1111111111111111 --> 5dc92597066badb697354312478c63ef
14 1111111111111111 --> 5dc92597066badb697354312478c63ef
15 1111111111111111 --> 5dc92597066badb697354312478c63ef
16 1111111111111111 --> 5dc92597066badb697354312478c63ef
17 1111111111111111 --> 5dc92597066badb697354312478c63ef
18 1111111111111111 --> 5dc92597066badb697354312478c63ef
19 1111111111111111 --> 5dc92597066badb697354312478c63ef
20 1111111111111111 --> f89578f7de7262dc8d3a1adcb72d2a6e
21 1111111111111111 --> c9beeedccc529092fb2659df61e42024

```

Lab 3 - ECB Block shuffling (hard)

```

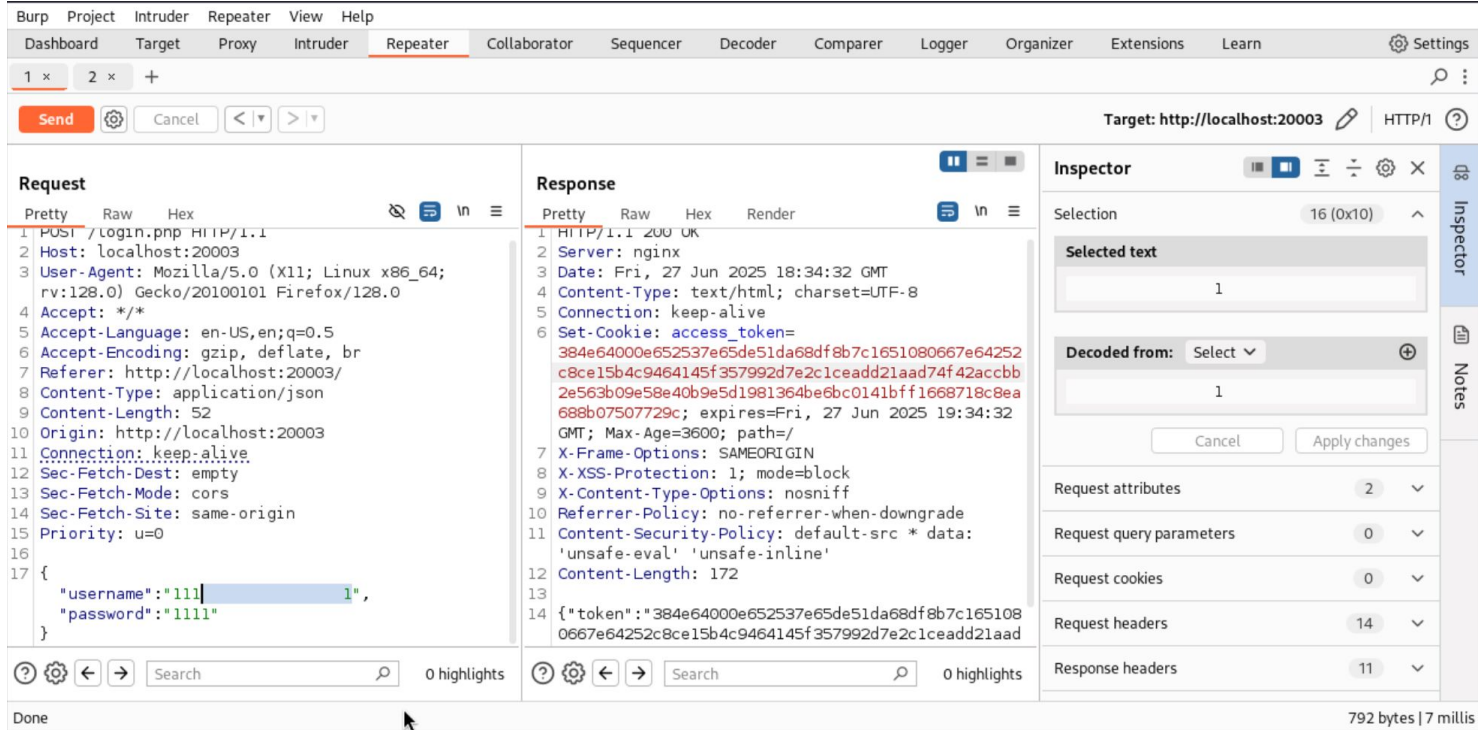
1  {"username": "111  --> block 1
2  " 1  --> block 2
3  ", "password": "11  --> block 3
4  11", "is_admin": 0  --> block 4
5  }  --> block 5
  
```



```

1  {"username": "111 1", "password": "1111", "is_admin": 0}
  
```


Lab 3 - ECB Block shuffling (hard)



Request

```

1 POST /login.php HTTP/1.1
2 Host: localhost:20003
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
4 Accept: */*
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Referer: http://localhost:20003/
8 Content-Type: application/json
9 Content-Length: 52
10 Origin: http://localhost:20003
11 Connection: keep-alive
12 Sec-Fetch-Dest: empty
13 Sec-Fetch-Mode: cors
14 Sec-Fetch-Site: same-origin
15 Priority: u=0
16
17 {
18   "username": "1111",
19   "password": "1111"
20 }
  
```

Response

```

1 HTTP/1.1 200 OK
2 Server: nginx
3 Date: Fri, 27 Jun 2025 18:34:32 GMT
4 Content-Type: text/html; charset=UTF-8
5 Connection: keep-alive
6 Set-Cookie: access_token=384e64000e652537e65de51da68df8b7c1651080667e64252c8ce15b4c9464145f357992d7e2c1ceadd21aad74f42accbb2e563b09e58e40b9e5d1981364be6bc0141bff1668718c8ea688b07507729c; expires=Fri, 27 Jun 2025 19:34:32 GMT; Max-Age=3600; path=/
7 X-Frame-Options: SAMEORIGIN
8 X-XSS-Protection: 1; mode=block
9 X-Content-Type-Options: nosniff
10 Referrer-Policy: no-referrer-when-downgrade
11 Content-Security-Policy: default-src * data: 'unsafe-eval' 'unsafe-inline'
12 Content-Length: 172
13
14 {"token": "384e64000e652537e65de51da68df8b7c1651080667e64252c8ce15b4c9464145f357992d7e2c1ceadd21aad
  
```

Inspector

Selection: 16 (0x10)

Selected text

1

Decoded from: Select

1

Cancel Apply changes

Request attributes 2

Request query parameters 0

Request cookies 0

Request headers 14

Response headers 11

Done 792 bytes | 7 millis

Lab 3 - ECB Block shuffling (hard)

```

1 {"username":"111 --> 384e64000e652537e65de51da68df8b7 (block 1)
2 | | | | | 1 --> c1651080667e64252c8ce15b4c946414 (block 2)
3 ", "password":"11 --> 5f357992d7e2c1ceadd21aad74f42acc (block 3)
4 11", "is_admin":0 --> bb2e563b09e58e40b9e5d1981364be6b (block 4)
5 } --> c0141bfff1668718c8ea688b07507729c (block 5)

```



```

1 {"username":"111 --> (new block 1)
2 ", "password":"11 --> (new block 2)
3 111", "is_admin": --> (new block 3)
4 | | | | | 1 --> c1651080667e64252c8ce15b4c946414 (block 2)
5 } --> c0141bfff1668718c8ea688b07507729c (block 5)

```



```

1 {"username":"111", "password":"11111", "is_admin": 1}

```

Lab 3 - ECB Block shuffling (hard)

Target: http://localhost:20003

Request

```

1 POST /login.php HTTP/1.1
2 Host: localhost:20003
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
4 Accept: */*
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Referer: http://localhost:20003/
8 Content-Type: application/json
9 Content-Length: 37
10 Origin: http://localhost:20003
11 Connection: keep-alive
12 Sec-Fetch-Dest: empty
13 Sec-Fetch-Mode: cors
14 Sec-Fetch-Site: same-origin
15 Priority: u=0
16 {
17   "username": "111",
18   "password": "11111"
19 }

```

Response

```

1 HTTP/1.1 200 OK
2 Server: nginx
3 Date: Fri, 27 Jun 2025 18:43:18 GMT
4 Content-Type: text/html; charset=UTF-8
5 Connection: keep-alive
6 Set-Cookie: access_token=
  384e64000e652537e65de51da68df8b75f357992d7e2c1cea
  dd21aad74f42accf89578f7de7262dc8d3a1adcb72d2a6ec9
  beeedccc529092fb2659df61e42024; expires=Fri, 27
  Jun 2025 19:43:18 GMT; Max-Age=3600; path=/
7 X-Frame-Options: SAMEORIGIN
8 X-XSS-Protection: 1; mode=block
9 X-Content-Type-Options: nosniff
10 Referrer-Policy: no-referrer-when-downgrade
11 Content-Security-Policy: default-src * data:
  'unsafe-eval' 'unsafe-inline'
12 Content-Length: 140
13
14 {"token": "384e64000e652537e65de51da68df8b75f35799
  2d7e2c1ceadd21aad74f42accf89578f7de7262dc8d3a1adc
  b72d2a6ec9beeedccc529092fb2659df61e42024"}

```

Inspector

Selection: 128 (0x80)

Selected text

```

384e64000e652537e65de51da68df8b75f35
7992d7e2c1ceadd21aad74f42accf89578f7
de7262dc8d3a1adcb72d2a6ec9beeedccc52
9092fb2659df61e42024

```

Request attributes: 2

Request query parameters: 0

Request cookies: 0

Request headers: 14

Response headers: 11

728 bytes | 11 millis

Lab 3 - ECB Block shuffling (hard)

```

1 {"username":"111 --> (new block 1)
2  ", "password":"11 --> (new block 2)
3  111", "is_admin": --> (new block 3)
4  | | | | | 1 --> c1651080667e64252c8ce15b4c946414 (block 2)
5  } --> c0141bfff1668718c8ea688b07507729c (block 5)
```



```

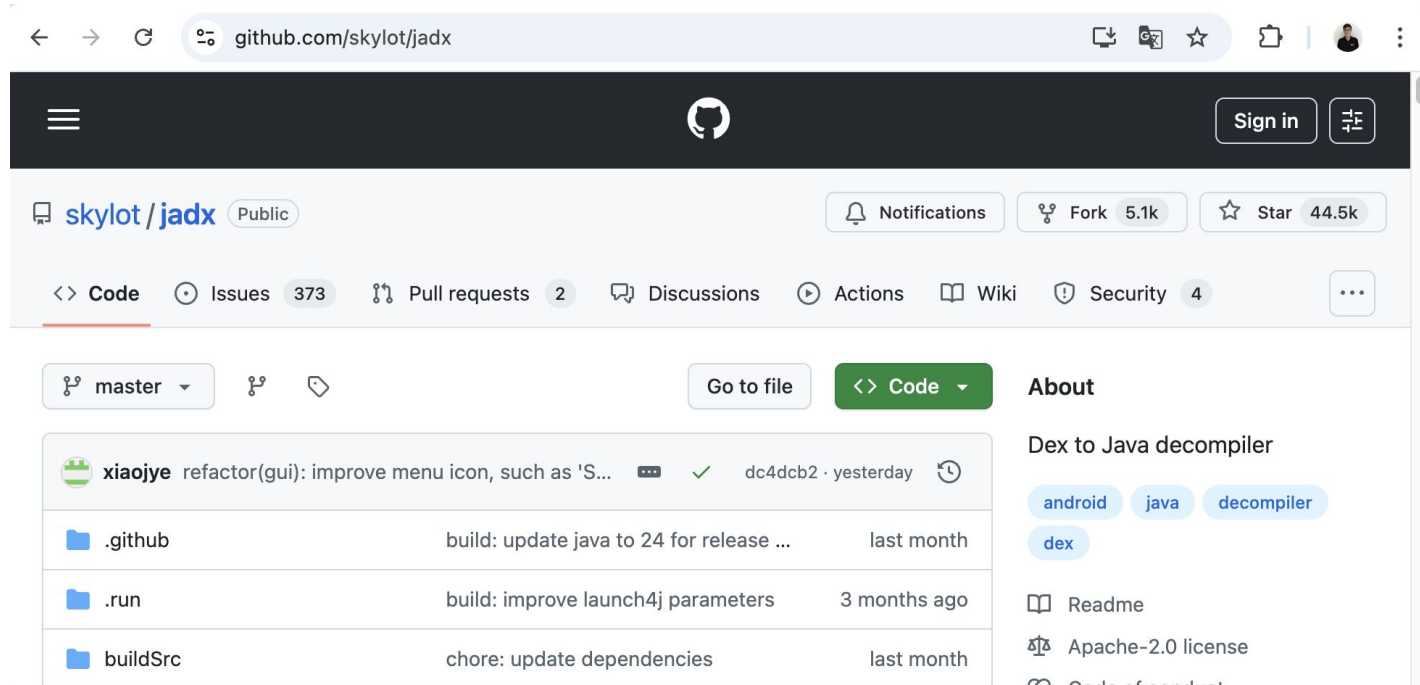
1 {"username":"111 --> 384e64000e652537e65de51da68df8b7 (new block 1)
2  ", "password":"11 --> 5f357992d7e2c1ceadd21aad74f42acc (new block 2)
3  111", "is_admin": --> f89578f7de7262dc8d3a1adcb72d2a6e (new block 3)
4  | | | | | 1 --> c1651080667e64252c8ce15b4c946414 (block 2)
5  } --> c0141bfff1668718c8ea688b07507729c (block 5)
```


Workshop: Mobile Security

Install jadx

ติดตั้ง jadx

<https://github.com/skylot/jadx>



The screenshot shows the GitHub repository page for `skylot/jadx`. The repository is public and has 5.1k forks and 44.5k stars. The main branch is `master`. The repository contains a `.github` directory, a `.run` file, and a `buildSrc` directory. The repository is a Dex to Java decompiler, licensed under Apache-2.0.

Repository: `skylot/jadx` (Public)

Notifications Fork 5.1k Star 44.5k

<> Code Issues 373 Pull requests 2 Discussions Actions Wiki Security 4

master Go to file <> Code

About

Dex to Java decompiler

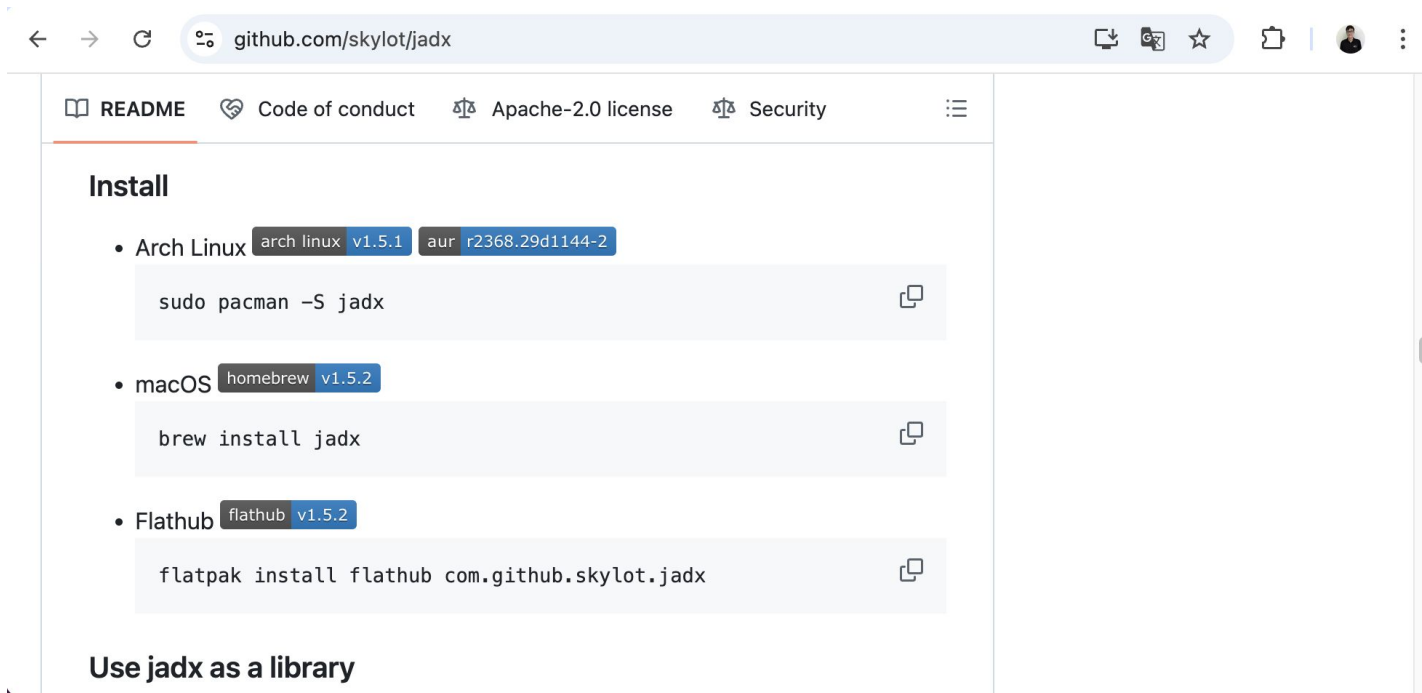
android java decompiler dex

Readme Apache-2.0 license Code of conduct

File	Commit Message	Time
.github	build: update java to 24 for release ...	last month
.run	build: improve launch4j parameters	3 months ago
buildSrc	chore: update dependencies	last month

ติดตั้ง jadx

<https://github.com/skylot/jadx>



The screenshot shows the GitHub repository page for `skylot/jadx`. The browser address bar displays `github.com/skylot/jadx`. The repository page includes navigation links for `README`, `Code of conduct`, `Apache-2.0 license`, and `Security`. The `Install` section provides instructions for three operating systems:

- Arch Linux**: `arch linux v1.5.1 aur r2368.29d1144-2`

```
sudo pacman -S jadx
```
- macOS**: `homebrew v1.5.2`

```
brew install jadx
```
- Flathub**: `flathub v1.5.2`

```
flatpak install flathub com.github.skylot.jadx
```

The `Use jadx as a library` section is partially visible at the bottom.

ติดตั้ง jadx ใน Kali

\$ jadx-gui

```
(tsk@kali)-[~/Desktop/5_mobilesec/mobilesec_lab1_Parameter_Tampering]
```

```
$ jadx-gui
```

Command 'jadx-gui' not found, but can be installed with:

```
sudo apt install jadx
```

```
Do you want to install it? (N/y)y
```

```
sudo apt install jadx
```

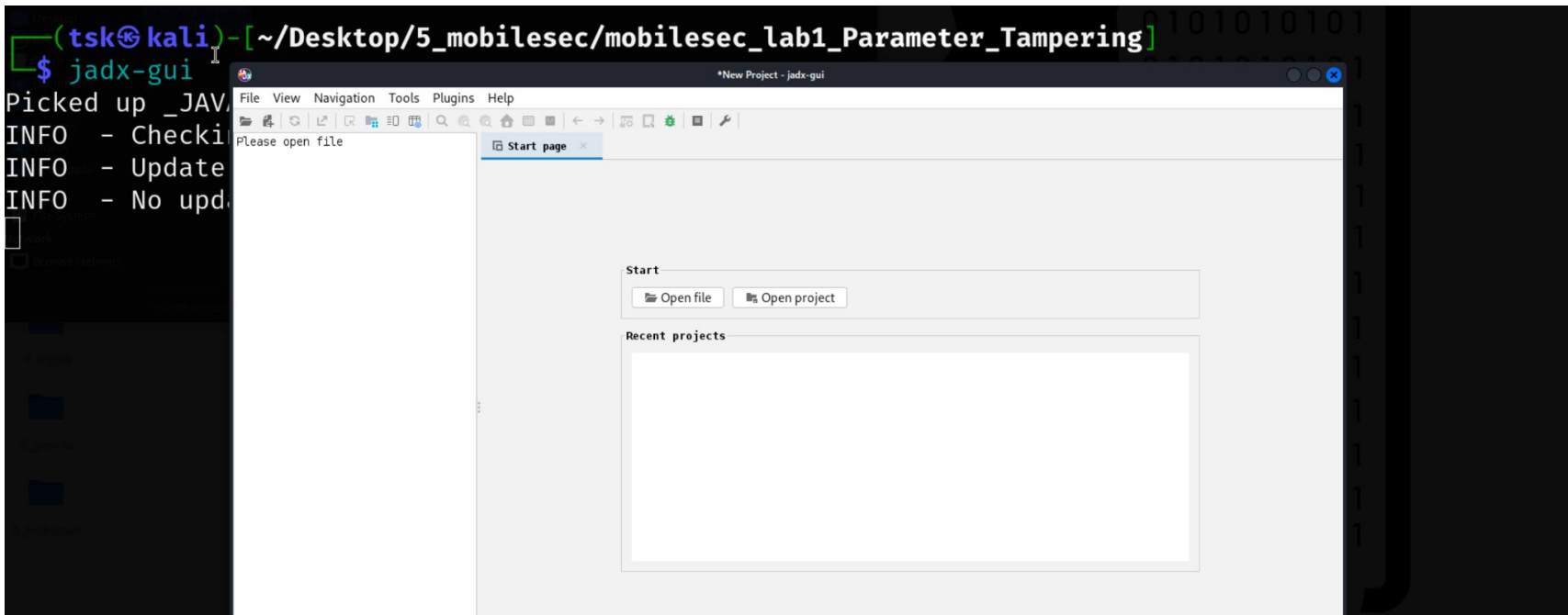
```
[sudo] password for tsak:
```

The following packages were automatically installed and are no longer required:

cpdb-backend-cups	libgfxdr0	libunwind-16t64
firmware-intel-sound	libgl1-mesa-dev	libusbmuxd6
firmware-sof-signed	libgles-dev	libwinpr2-2t64
fonts-liberation2	libgles1	libzip4t64
freerdp2-x11	libglusterfs0	linux-image-6.8.11-arm64
hydra-gtk	libglvnd-core-dev	openjdk-23-jre

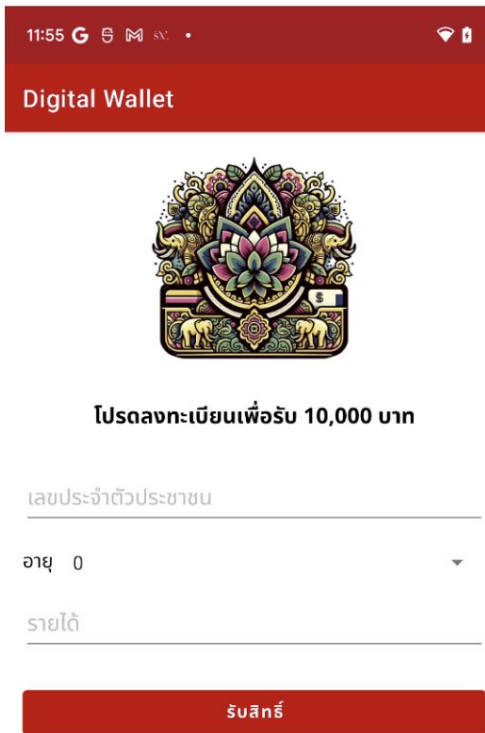
ติดตั้ง jadx ใน Kali

\$ jadx-gui



Lab 1 - Parameter Tampering (Digital Wallet) (easy)

Lab 1 - Parameter Tampering (Digital Wallet) (easy)



11:55 G S M SV •

Digital Wallet



โปรดลงทะเบียนเพื่อรับ 10,000 บาท

เลขประจำตัวประชาชน

อายุ 0

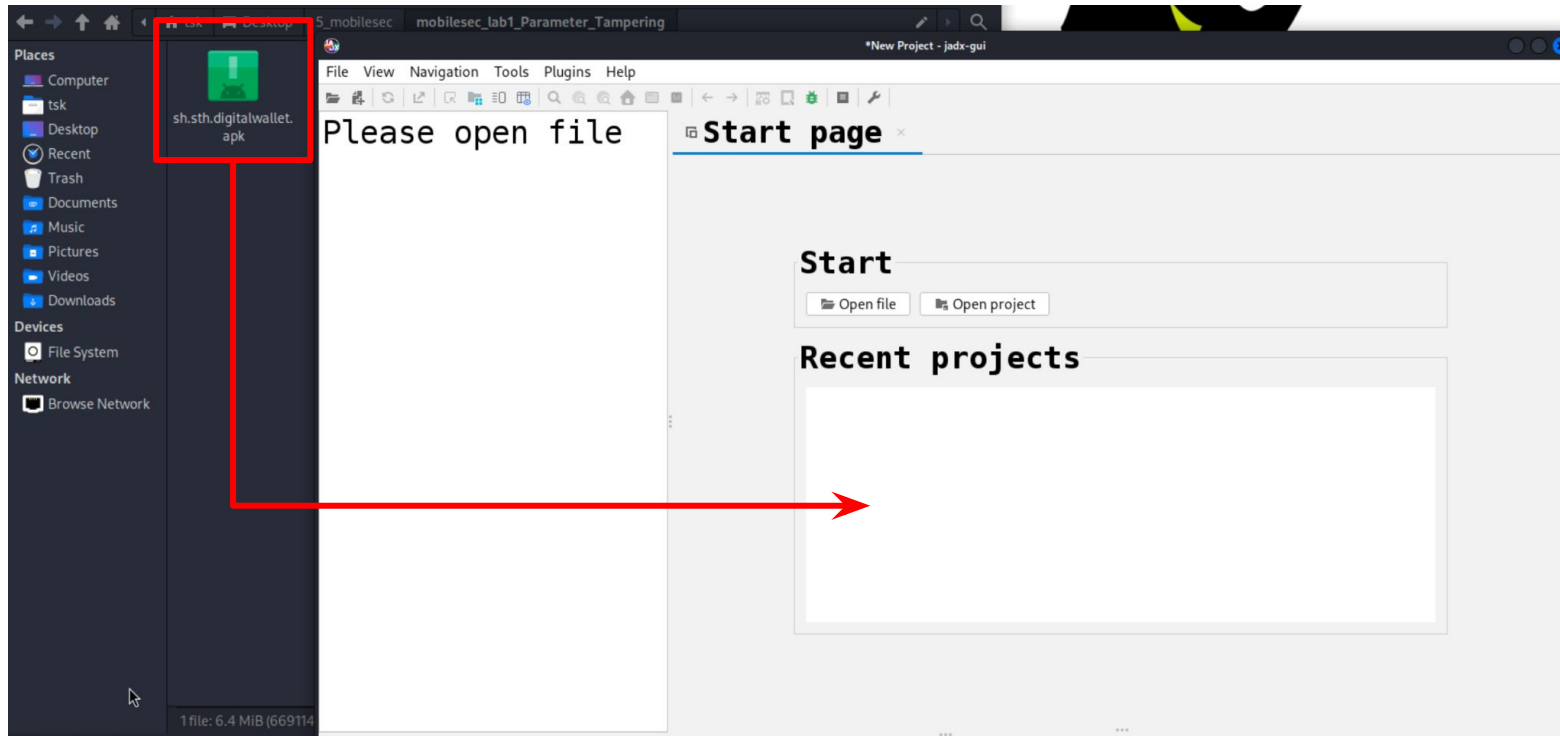
รายได้

รับสิทธิ์

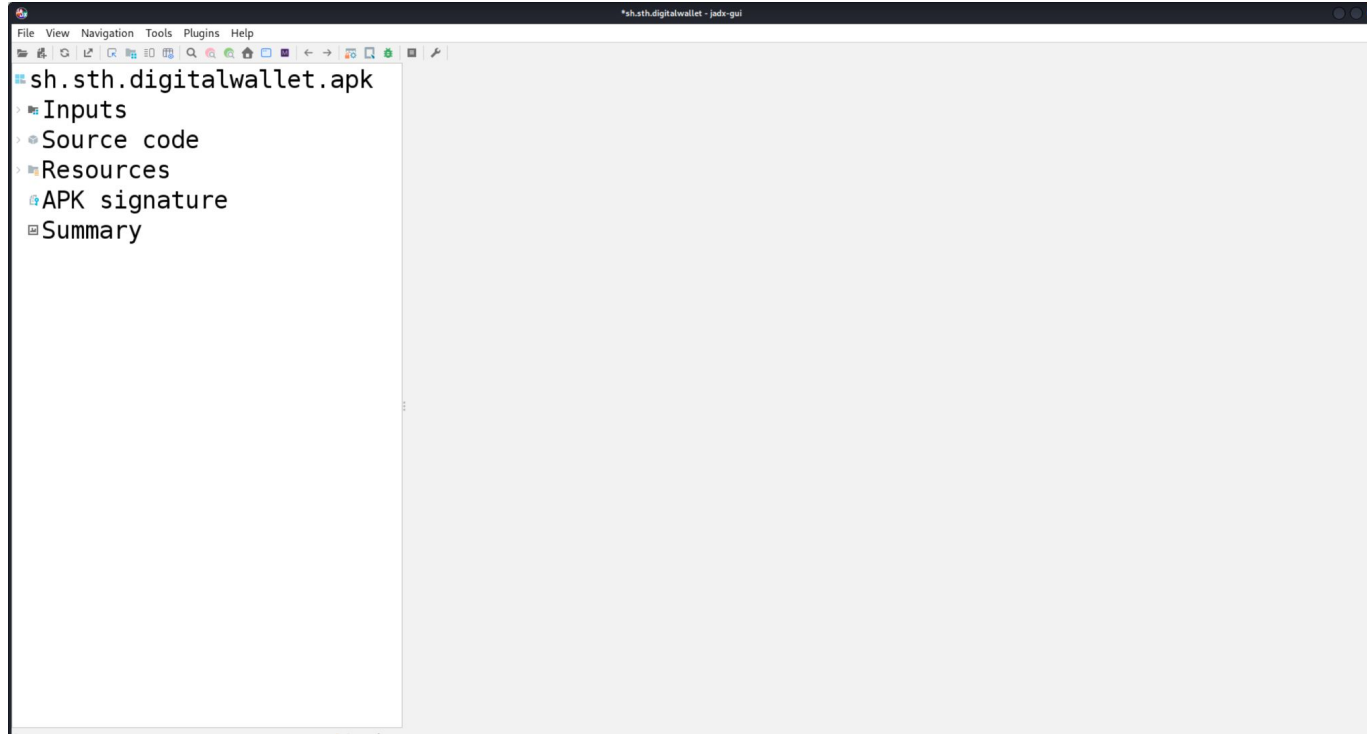
เงื่อนไขของแอปพลิเคชันมือถือ

- เปิดแอปพลิเคชันขึ้นมาจะเจอว่าต้องกรอกข้อมูลลงทะเบียนรับเงิน 10,000 บาท
- UI ของแอปจะไม่สามารถใส่อายุมากกว่า 15 ปี และ รายได้มากกว่า 999 ได้

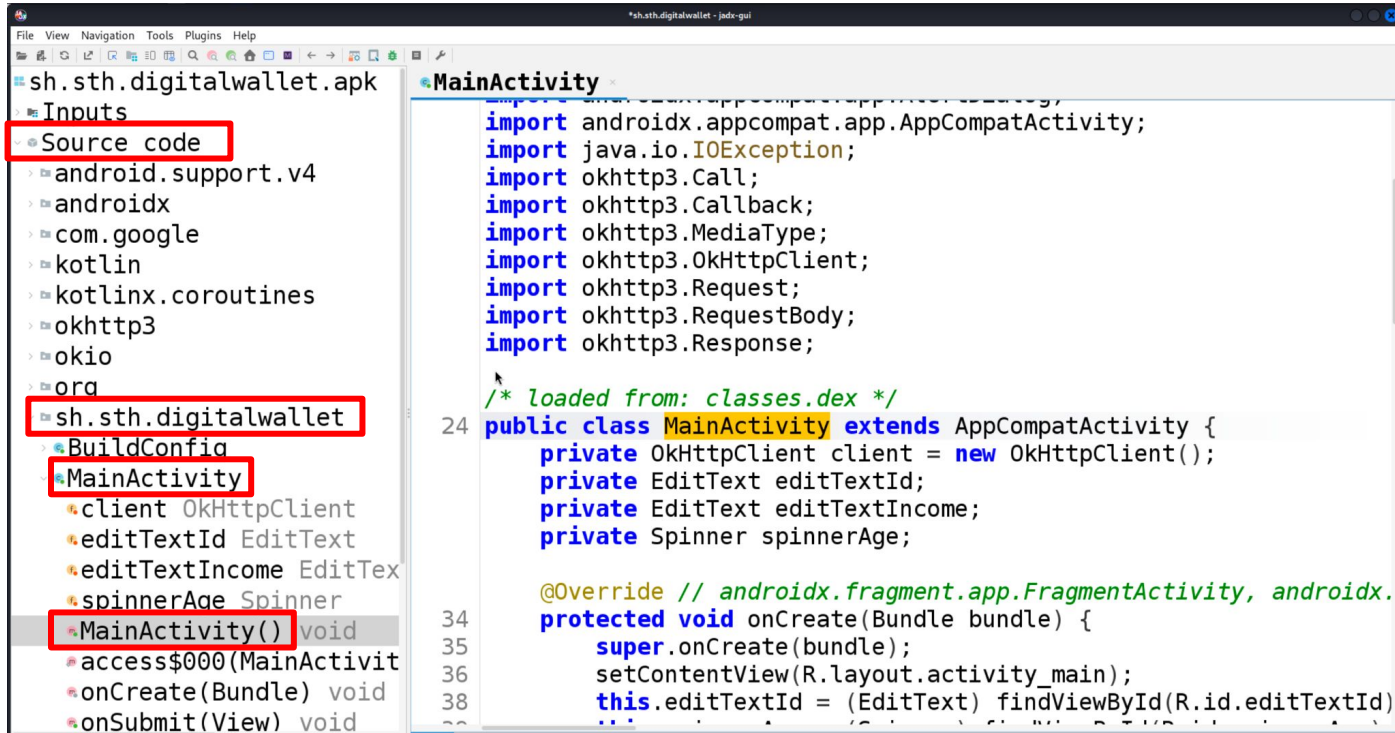
Lab 1 - Parameter Tampering (Digital Wallet) (easy)



Lab 1 - Parameter Tampering (Digital Wallet) (easy)



Lab 1 - Parameter Tampering (Digital Wallet) (easy)



```

sh.sth.digitalwallet.apk
├── Inputs
├── Source code
├── android.support.v4
├── androidx
├── com.google
├── kotlin
├── kotlinx.coroutines
├── okhttp3
├── okio
├── org
├── sh.sth.digitalwallet
│   ├── BuildConfig
│   ├── MainActivity
│   │   ├── client OkHttpClient
│   │   ├── editTextId EditText
│   │   ├── editTextIncome EditText
│   │   ├── spinnerAge Spinner
│   │   └── MainActivity() void
│   ├── access$000(MainActivity)
│   ├── onCreate(Bundle) void
│   └── onSubmit(View) void
└── ...

```

```

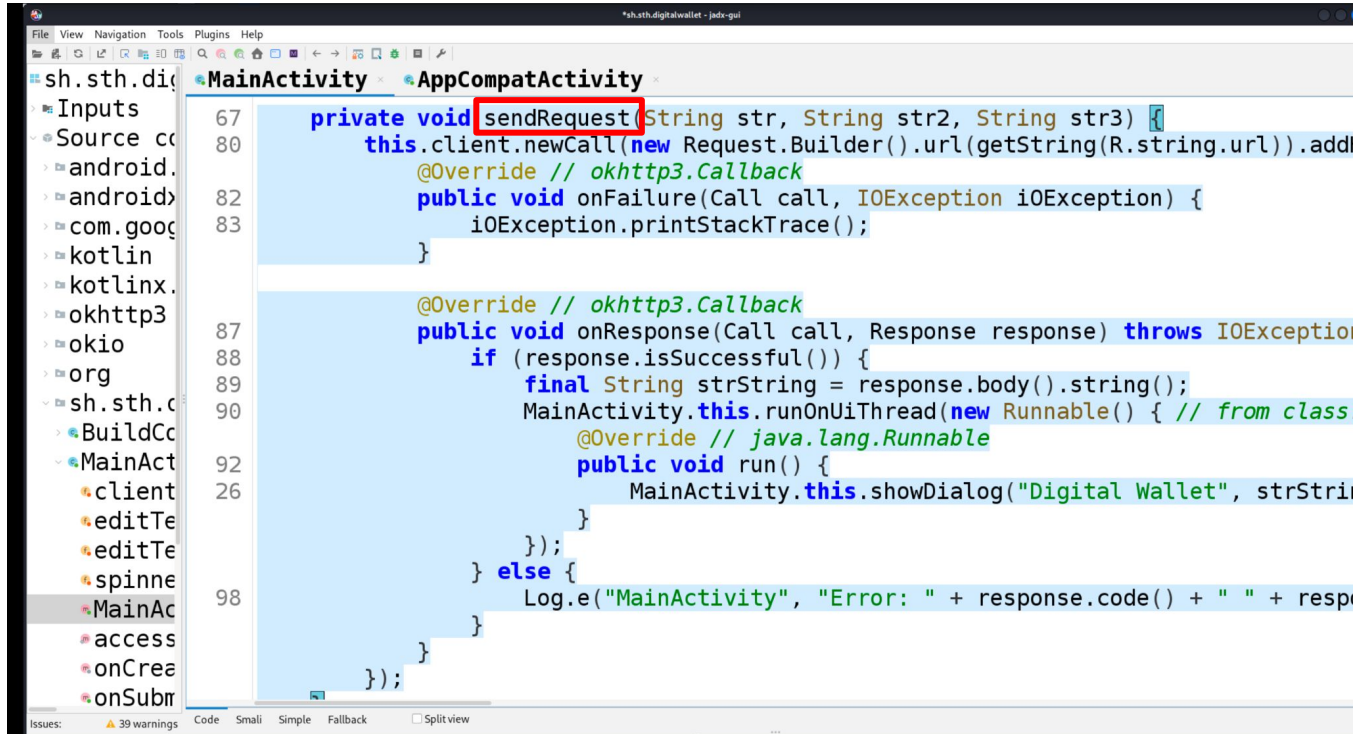
import androidx.appcompat.app.AppCompatActivity;
import java.io.IOException;
import okhttp3.Call;
import okhttp3.Callback;
import okhttp3.MediaType;
import okhttp3.OkHttpClient;
import okhttp3.Request;
import okhttp3.RequestBody;
import okhttp3.Response;

/* loaded from: classes.dex */
24 public class MainActivity extends AppCompatActivity {
    private OkHttpClient client = new OkHttpClient();
    private EditText editTextId;
    private EditText editTextIncome;
    private Spinner spinnerAge;

    @Override // androidx.fragment.app.FragmentActivity, androidx.
    34 protected void onCreate(Bundle bundle) {
    35     super.onCreate(bundle);
    36     setContentView(R.layout.activity_main);
    37     this.editTextId = (EditText) findViewById(R.id.editTextId)
    38     ...

```

Lab 1 - Parameter Tampering (Digital Wallet) (easy)



```

sh.sth.dig
  Inputs
  Source co
  android.
  android.
  com.goog
  kotlin
  kotlinx.
  okhttp3
  okio
  org
  sh.sth.c
  BuildCo
  MainAct
  client
  editTe
  editTe
  spinne
  MainActivity
  access
  onCrea
  onSubr

MainActivity
67 private void sendRequest(String str, String str2, String str3) {
80     this.client.newCall(new Request.Builder().url(getString(R.string.url)).add
      @Override // okhttp3.Callback
82     public void onFailure(Call call, IOException iOException) {
83         iOException.printStackTrace();
      }

      @Override // okhttp3.Callback
87     public void onResponse(Call call, Response response) throws IOException
88         if (response.isSuccessful()) {
89             final String strString = response.body().string();
90             MainActivity.this.runOnUiThread(new Runnable() { // from class
91                 @Override // java.lang.Runnable
92                 public void run() {
26                     MainActivity.this.showDialog("Digital Wallet", strStri
                }
            });
98         } else {
            Log.e("MainActivity", "Error: " + response.code() + " " + respo
        }
    }
}
  
```

Lab 1 - Parameter Tampering (Digital Wallet) (easy)

```

1      private void sendRequest(String str, String str2, String str3) {
2          this.client.newCall(new Request.Builder().url(getString(
            R.string.url)).addHeader("X-API-KEY",
              "2e884ae579d93a0b9fc419196da7527b").post(RequestBody.create(
                MediaType.parse("application/json; charset=utf-8"), "{\\"cid\\":\\" + str +
                  "\\","age\\":\\" + str2 + "\\","income\\":\\" + str3 +
                    "\\"}")).build()).enqueue(new Callback() { // from class:
                      sh.sth.digitalwallet.MainActivity.1
3              @Override // okhttp3.Callback
4              public void onFailure(Call call, IOException iOException) {
5                  iOException.printStackTrace();
6              }
7          }
8
9      curl -X POST "<URL>" \
10         -H "X-API-KEY: 2e884ae579d93a0b9fc419196da7527b" \
11         -H "Content-Type: application/json; charset=utf-8" \
12         -d '{"cid": "exampleCID", "age": "30", "income": "50000"}'
13

```

Lab 1 - Parameter Tampering (Digital Wallet) (easy)

```

1      private void sendRequest(String str, String str2, String str3) {
2          this.client.newCall(new Request.Builder().url(getString(
            R.string.url)).addHeader("X-API-KEY",
            "2e884ae579d93a0b9fc419196da7527b").post(RequestBody.create(
            MediaType.parse("application/json; charset=utf-8"), "{\"cid\": \"" + str +
            "\", \"age\": \"" + str2 + "\", \"income\": \"" + str3 +
            "\"}")).build()).enqueue(new Callback() { // from class:
            sh.sth.digitalwallet.MainActivity.1
3              @Override // okhttp3.Callback
4              public void onFailure(Call call, IOException iOException) {
5                  iOException.printStackTrace();
6              }
7          }
8
9      curl -X POST "<URL>" \
10         -H "X-API-KEY: 2e884ae579d93a0b9fc419196da7527b" \
11         -H "Content-Type: application/json; charset=utf-8" \
12         -d '{"cid": "exampleCID", "age": "30", "income": "50000"}'
13

```

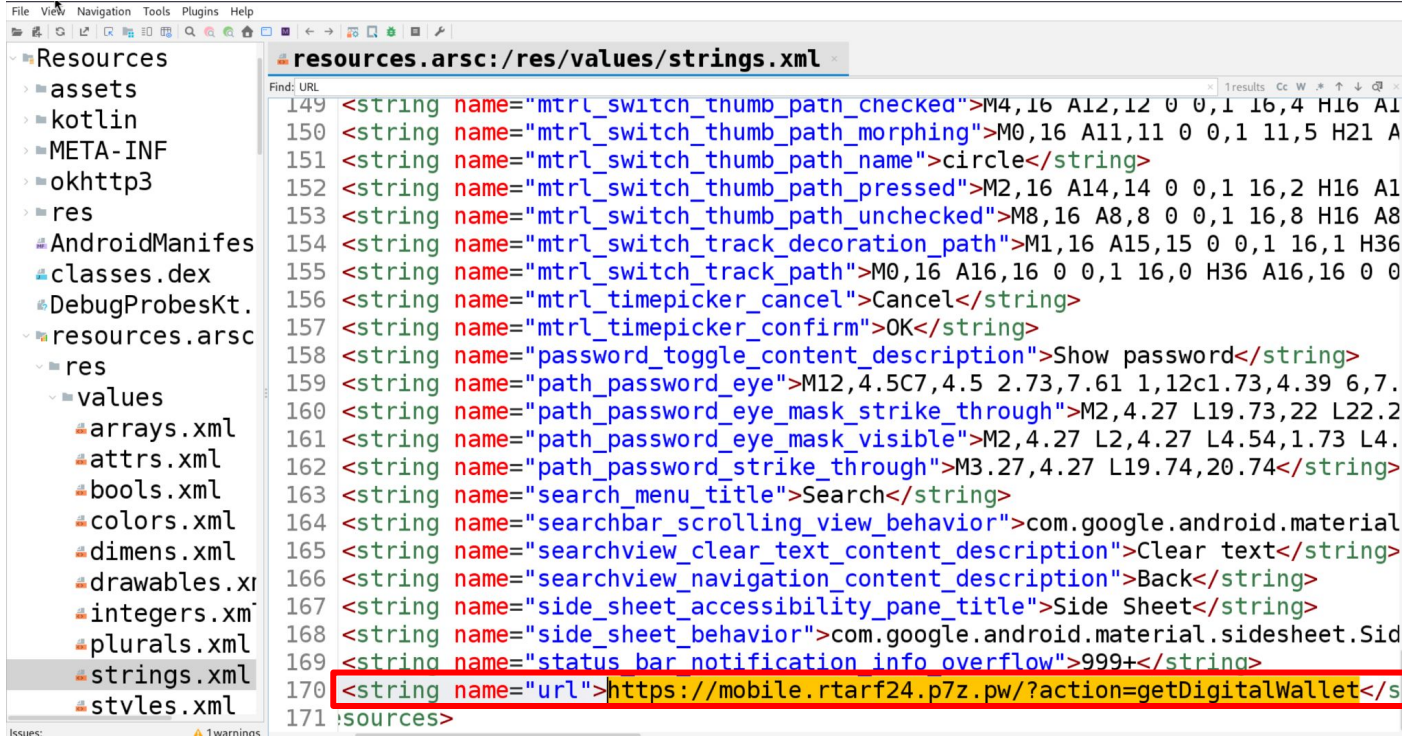

Lab 1 - Parameter Tampering (Digital Wallet) (easy)



```

1 <?xml version="1.0" encoding="utf-8"?>
2 <resources>
3     <string name="abc_action_bar_home_description">Navigate home</string>
4     <string name="abc_action_bar_up_description">Navigate up</string>
5     <string name="abc_action_menu_overflow_description">More options</string>
6     <string name="abc_action_mode_done">Done</string>
7     <string name="abc_activity_chooser_view_see_all">See all</string>
8     <string name="abc_activitychooserview_choose_application">Choose an app</string>
9     <string name="abc_capital_off">OFF</string>
10    <string name="abc_capital_on">ON</string>
11    <string name="abc_menu_alt_shortcut_label">Alt+</string>
12    <string name="abc_menu_ctrl_shortcut_label">Ctrl+</string>
13    <string name="abc_menu_delete_shortcut_label">delete</string>
14    <string name="abc_menu_enter_shortcut_label">enter</string>
15    <string name="abc_menu_function_shortcut_label">Function+</string>
16    <string name="abc_menu_meta_shortcut_label">Meta+</string>
17    <string name="abc_menu_shift_shortcut_label">Shift+</string>
18    <string name="abc_menu_space_shortcut_label">space</string>
19    <string name="abc_menu_sym_shortcut_label">Sym+</string>
20    <string name="abc_prepend_shortcut_label">Menu+</string>
21    <string name="abc_search_hint">Search...</string>
22    <string name="abc_searchview_description_clear">Clear query</string>
23    <string name="abc_searchview_description_query">Search query</string>
  
```


Lab 1 - Parameter Tampering (Digital Wallet) (easy)



```

resources.arsc:/res/values/strings.xml
Find: URL
149 <string name="mtrl_switch_thumb_path_checked">M4,16 A12,12 0 0,1 16,4 H16 A1
150 <string name="mtrl_switch_thumb_path_morphing">M0,16 A11,11 0 0,1 11,5 H21 A
151 <string name="mtrl_switch_thumb_path_name">circle</string>
152 <string name="mtrl_switch_thumb_path_pressed">M2,16 A14,14 0 0,1 16,2 H16 A1
153 <string name="mtrl_switch_thumb_path_unchecked">M8,16 A8,8 0 0,1 16,8 H16 A8
154 <string name="mtrl_switch_track_decoration_path">M1,16 A15,15 0 0,1 16,1 H36
155 <string name="mtrl_switch_track_path">M0,16 A16,16 0 0,1 16,0 H36 A16,16 0 0
156 <string name="mtrl_timepicker_cancel">Cancel</string>
157 <string name="mtrl_timepicker_confirm">OK</string>
158 <string name="password_toggle_content_description">Show password</string>
159 <string name="path_password_eye">M12,4.5C7,4.5 2.73,7.61 1,12c1.73,4.39 6,7.
160 <string name="path_password_eye_mask_strike_through">M2,4.27 L19.73,22 L22.2
161 <string name="path_password_eye_mask_visible">M2,4.27 L2,4.27 L4.54,1.73 L4.
162 <string name="path_password_strike_through">M3.27,4.27 L19.74,20.74</string>
163 <string name="search_menu_title">Search</string>
164 <string name="searchbar_scrolling_view_behavior">com.google.android.material
165 <string name="searchview_clear_text_content_description">Clear text</string>
166 <string name="searchview_navigation_content_description">Back</string>
167 <string name="side_sheet_accessibility_pane_title">Side Sheet</string>
168 <string name="side_sheet_behavior">com.google.android.material.sidesheet.Sid
169 <string name="status_bar_notification_info_overflow">999+</string>
170 <string name="url">https://mobile.rtarf24.p7z.pw/?action=getDigitalWallet</s
171 </resources>
  
```

Lab 1 - Parameter Tampering (Digital Wallet) (easy)

```
tanakorn.sk@Admins-MacBook-Pro mob_rtarf_deploy %
curl -X POST "http://172.16.201.129:8085/?action=getDigitalWallet" \
  -H "X-API-KEY: 2e884ae579d93a0b9fc419196da7527b" \
  -H "Content-Type: application/json; charset=utf-8" \
  -d '{"cid": "123456789123", "age": "1", "income": "1"}'
```

คุณอายุไม่ถึง 16 ปีหมดสิทธิ์%

```
tanakorn.sk@Admins-MacBook-Pro mob_rtarf_deploy %
curl -X POST "http://172.16.201.129:8085/?action=getDigitalWallet" \
  -H "X-API-KEY: 2e884ae579d93a0b9fc419196da7527b" \
  -H "Content-Type: application/json; charset=utf-8" \
  -d '{"cid": "123456789123", "age": "17", "income": "1"}'
```

คุณรายได้ไม่ถึง 10,000 บาท หมดสิทธิ์%

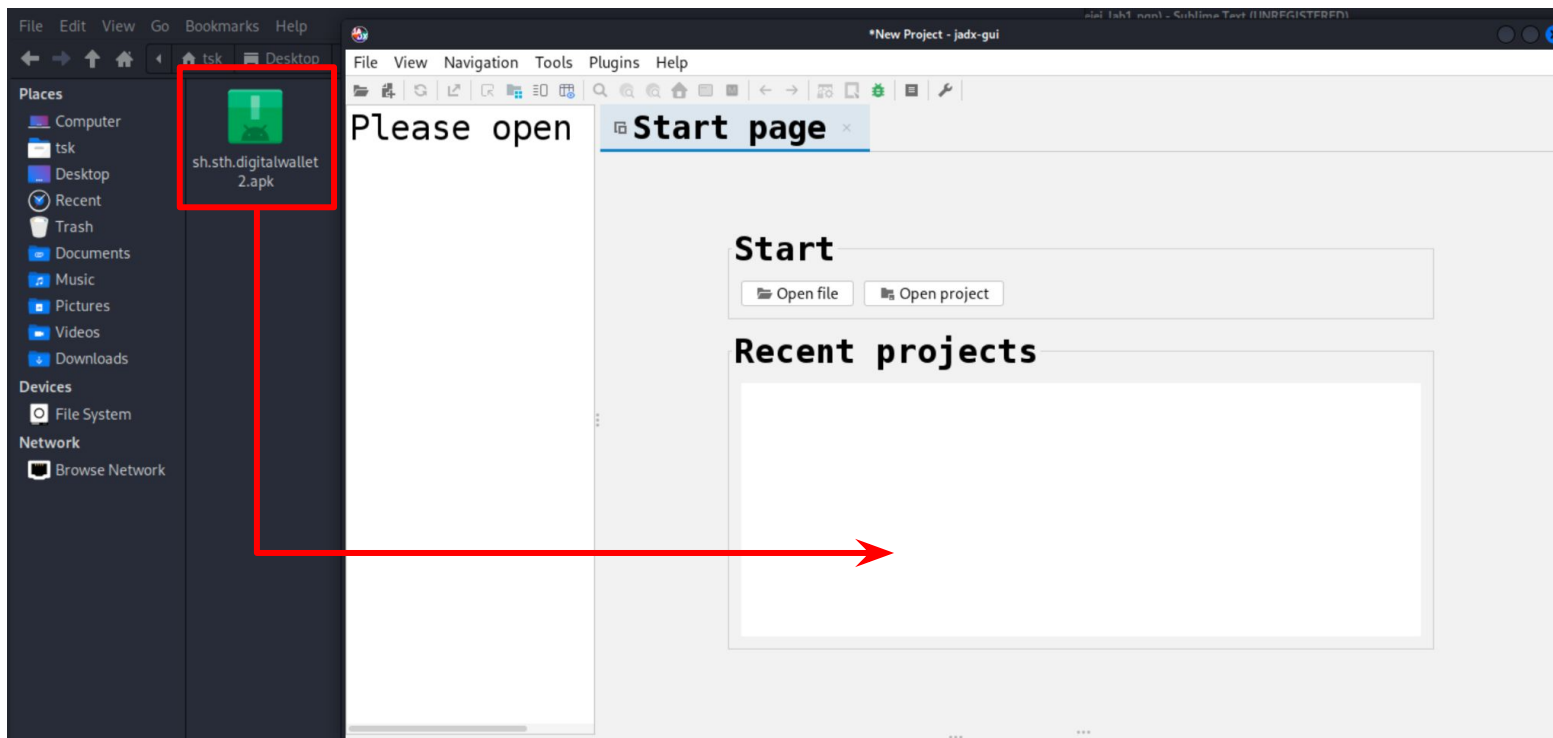
Lab 1 - Parameter Tampering (Digital Wallet) (easy)

```
tanakorn.sk@Admins-MacBook-Pro mob_rtarf_deploy %  
curl -X POST "http://172.16.201.129:8085/?action=getDigitalWallet" \  
  -H "X-API-KEY: 2e884ae579d93a0b9fc419196da7527b" \  
  -H "Content-Type: application/json; charset=utf-8" \  
  -d '{"cid": "1234567890123", "age": "17", "income": "100000"}'  
FLAG{10000thb}%
```

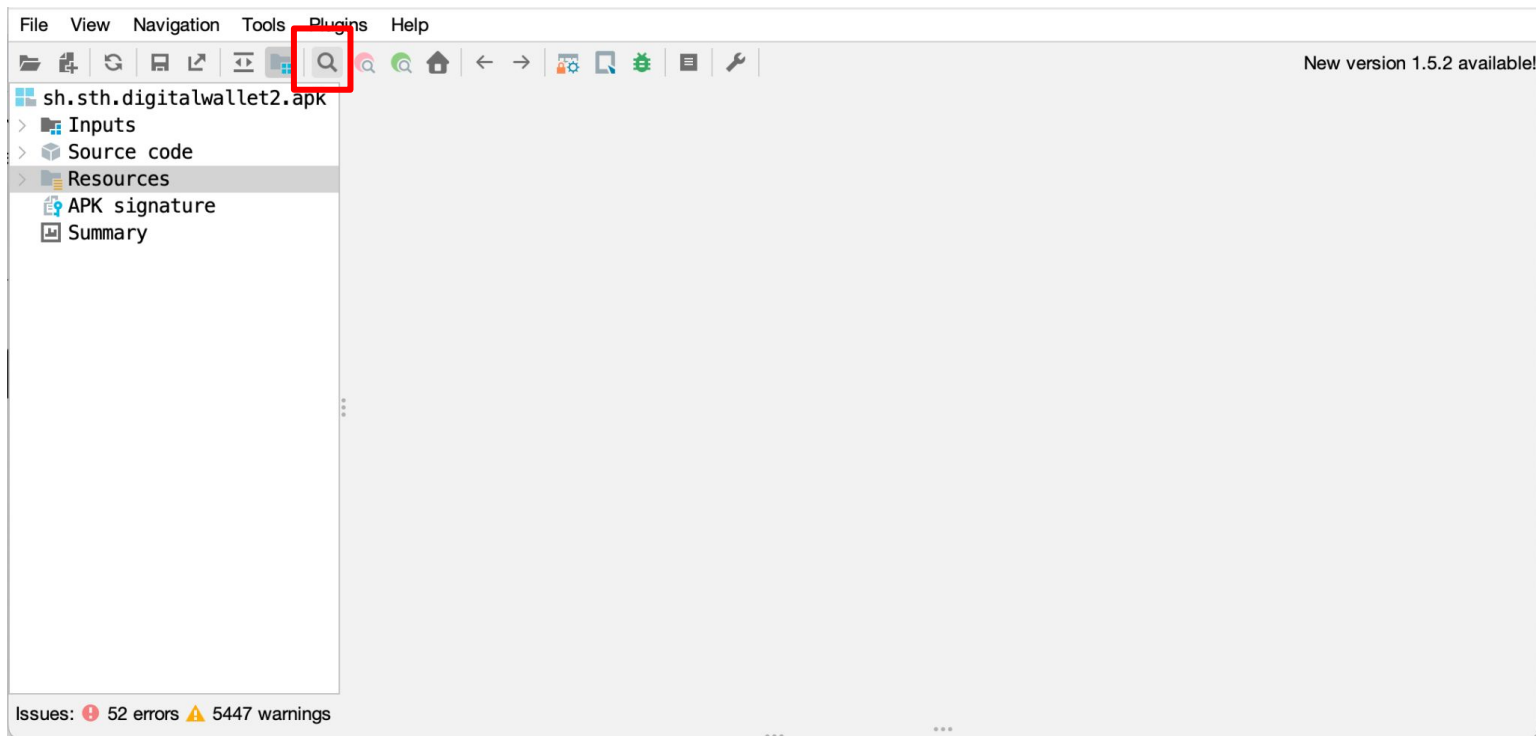
```
$ curl -X POST "https://mobile.rtarf24.p7z.pw/?action=getDigitalWallet" \  
-H "X-API-KEY: 2e884ae579d93a0b9fc419196da7527b" \  
-H "Content-Type: application/json; charset=utf-8" \  
-d '{"cid": "1234567890123", "age": "100", "income": "100000"}'
```

Lab 2 - Hardcoded Secret (Digital Wallet v2) (medium)

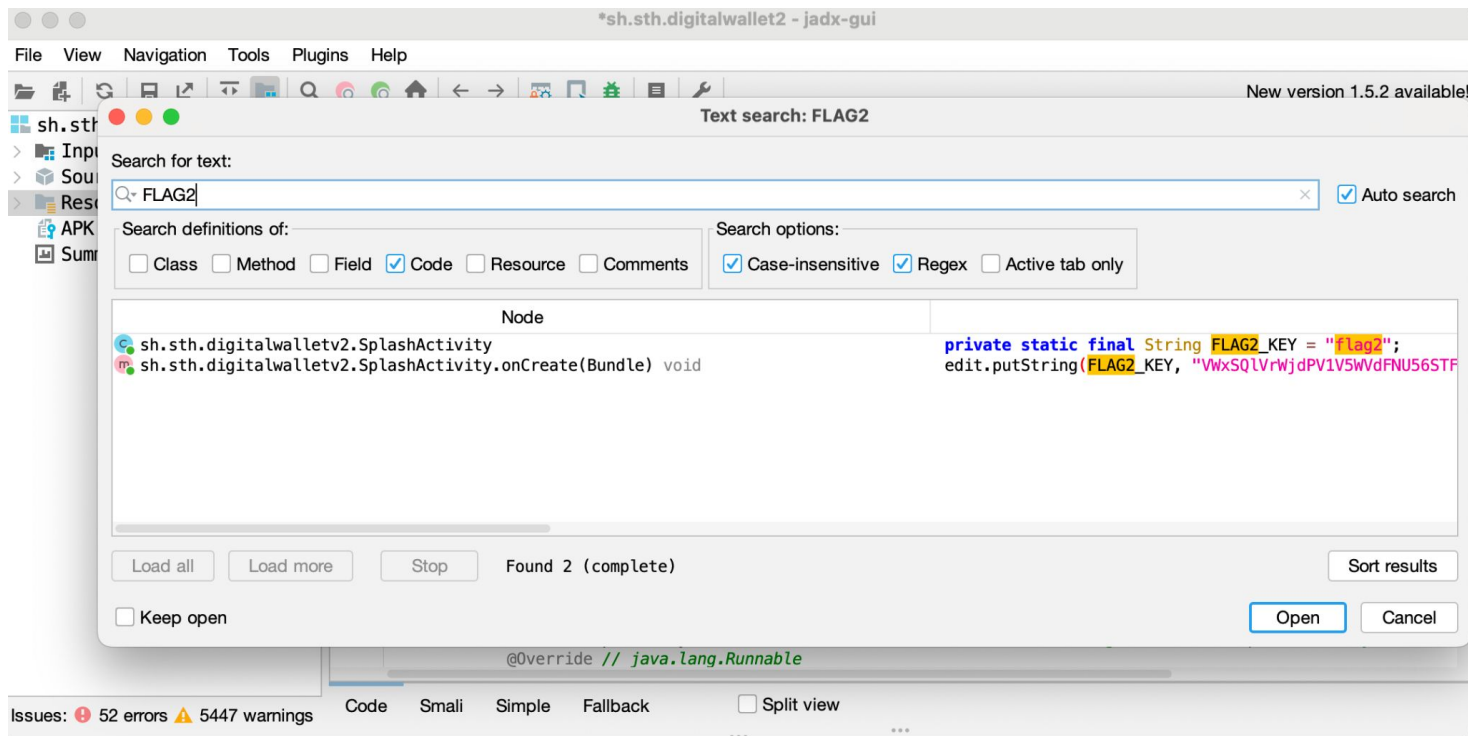
Lab 2 - Hardcoded Secret (Digital Wallet v2) (medium)



Lab 2 - Hardcoded Secret (Digital Wallet v2) (medium)



Lab 2 - Hardcoded Secret (Digital Wallet v2) (medium)



Lab 2 - Hardcoded Secret (Digital Wallet v2) (medium)

File View Navigation Tools Plugins Help

sh.sth.digitalwallet2.apk

- Inputs
- Source code
- Resources
- APK signature
- Summary

SplashActivity

```

/* loaded from: classes.dex */
19 public class SplashActivity extends AppCompatActivity {
    private static final String FLAG2_KEY = "flag2";
    private static final String PREFS_NAME = "wallet";
    private static final String SECRET_KEY = "secret_key";

    /* JADX INFO: Access modifiers changed from: protected */
    @Override // androidx.fragment.app.FragmentActivity, androidx.activity.ComponentActivity, androidx.core.app.
20 public void onCreate(Bundle bundle) {
21     super.onCreate(bundle);
22     setContentView(R.layout.splash_screen);
25     SharedPreferences.Editor edit = getSharedPreferences(PREFS_NAME, 0).edit();
26     edit.putString(FLAG2_KEY, "VwXSQLVrWjdPV1V5WVdFNU56STFaV1kzWLRnNE16azV0akJoWwPJMFLXRXdOMkZpTkdG0Q==");
27     edit.putString(SECRET_KEY, "b2491621ac4b01a99f759e00edc2752d");
28     edit.apply();
30     new Handler().postDelayed(new Runnable() { // from class: sh.sth.digitalwalletv2.SplashActivity.1
        @Override // java.lang.Runnable
32     public void run() {
34         SplashActivity.this.startActivity(new Intent(SplashActivity.this, (Class<?>) MainActivity.class)
35         SplashActivity.this.finish();
        }, 1000L);
    }
}

```

Issues: 13 errors 5406 warnings

Code Small Simple Fallback Split view

Lab 2 - Hardcoded Secret (Digital Wallet v2) (medium)

```
1 FLAG2_KEY: VwxSQtVrWjdPV1V5WVdFNU56STFaV1kzWlRnNE16azV0akJoWwPJMFlXRXd0MkZpTkdG0Q==
2 SECRET_KEY: b2491621ac4b01a99f759e00edc2752d
```



ดูจากการจัดรูปแบบของ **FLAG2_KEY** ที่ลงท้ายด้วย == เป็นไปได้สูงว่าเป็นการเข้ารหัสแบบ **Base64**

Lab 2 - Hardcoded Secret (Digital Wallet v2) (medium)

```
1 FLAG2_KEY: VWxSQLvRwjdpV1V5WVdFNU56STFaV1kzWlRnNE16azV0akJoWWpJMF\LRXd0MkZpTkdGOQ==
2 SECRET_KEY: b2491621ac4b01a99f759e00edc2752d
```



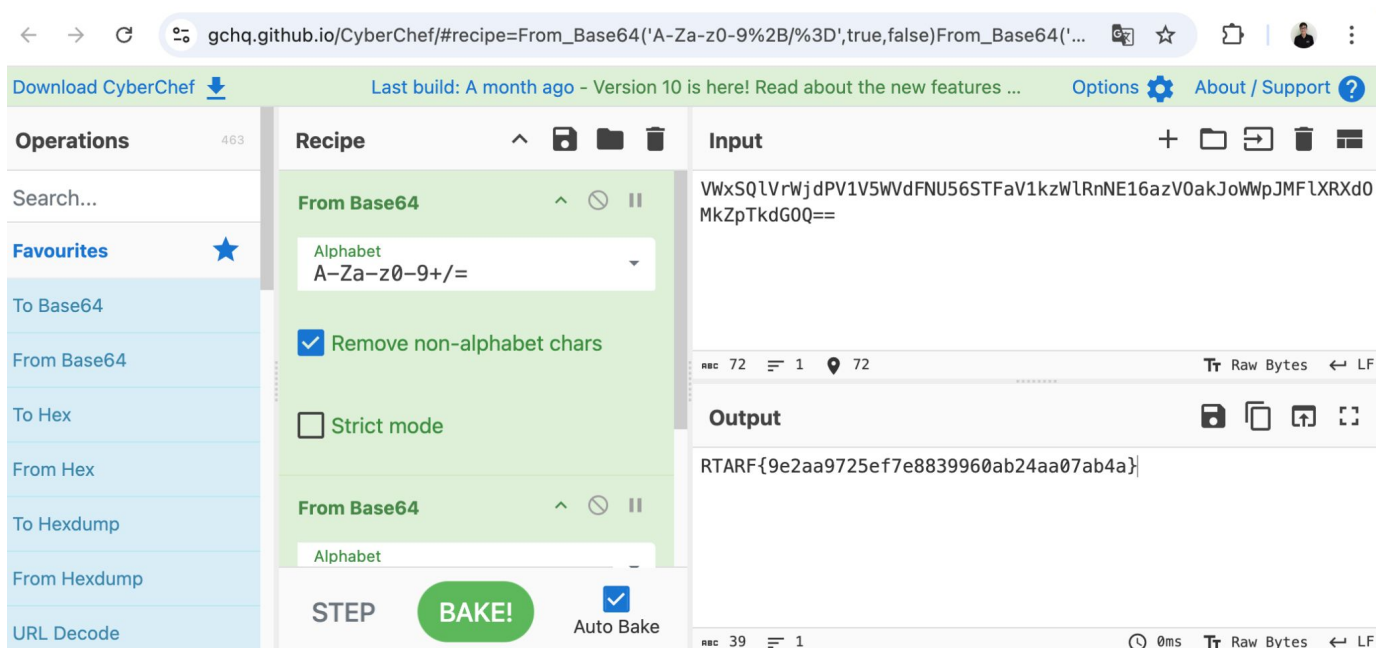
ดูจากการจัดรูปแบบของ **FLAG2_KEY** ที่ลงท้ายด้วย == เป็นไปได้สูงว่าเป็นการเข้ารหัสแบบ **Base64**



```
(tsk@kali)-[~/Desktop/5_mobilesec/mobilesec_lab2_Hardcoded_Secret]
$ echo VWxSQLvRwjdpV1V5WVdFNU56STFaV1kzWlRnNE16azV0akJoWWpJMF\LRXd0MkZpTkdGOQ== | base64 -d
U\RBukZ7OWUyYWE5NzI1ZWY3ZTg4Mzk5NjBhYjI0YWUwN2FiNGF9

(tsk@kali)-[~/Desktop/5_mobilesec/mobilesec_lab2_Hardcoded_Secret]
$ echo U\RBukZ7OWUyYWE5NzI1ZWY3ZTg4Mzk5NjBhYjI0YWUwN2FiNGF9 | base64 -d
RTARF{9e2aa9725ef7e8839960ab24aa07ab4a}
```

Lab 2 - Hardcoded Secret (Digital Wallet v2) (medium)



gchq.github.io/CyberChef/#recipe=From_Base64('A-Za-z0-9%2B/%3D',true,false)From_Base64('...'

Download CyberChef Last build: A month ago - Version 10 is here! Read about the new features ... Options About / Support

Operations 463

Search...

Favourites ★

- To Base64
- From Base64
- To Hex
- From Hex
- To Hexdump
- From Hexdump
- URL Decode

Recipe

From Base64

Alphabet
A-Za-z0-9+/=

☒ Remove non-alphabet chars

☐ Strict mode

From Base64

Alphabet

STEP **BAKE!** ☒ Auto Bake

Input

VWxSQ1VrWjdPV1V5WVdFNU56STFaV1kzWlRnNE16azV0akJowWpJMF1XRXd0MkZpTkdg0Q==

Output

RTARF{9e2aa9725ef7e8839960ab24aa07ab4a}

[https://gchq.github.io/CyberChef/#recipe=From_Base64\('A-Za-z0-9%2B/%3D',true,false\)From_Base64\('A-Za-z0-9%2B/%3D',true,false\)&input=Vld4U1FsVnJXamRQVjFWNVdWZEZOVTU2U1RGYVYxa3pXbFJuTkUxNmF6Vk9ha0pvV1dwSk1GbFhSWGRPTWtacFRrZEdPUT09](https://gchq.github.io/CyberChef/#recipe=From_Base64('A-Za-z0-9%2B/%3D',true,false)From_Base64('A-Za-z0-9%2B/%3D',true,false)&input=Vld4U1FsVnJXamRQVjFWNVdWZEZOVTU2U1RGYVYxa3pXbFJuTkUxNmF6Vk9ha0pvV1dwSk1GbFhSWGRPTWtacFRrZEdPUT09)

Thank you !!